

TECNOLOGIA DA INFORMAÇÃO

Procedimentos de Segurança



Presidente: Gabriel Granjeiro

Vice-Presidente: Rodrigo Calado

Diretor Pedagógico: Erico Teixeira

Diretora de Produção Educacional: Vivian Higashi

Gerente de Produção Digital: Bárbara Guerra

Todo o material desta apostila (incluindo textos e imagens) está protegido por direitos autorais do Gran. Será proibida toda forma de plágio, cópia, reprodução ou qualquer outra forma de uso, não autorizada expressamente, seja ela onerosa ou não, sujeitando-se o transgressor às penalidades previstas civil e criminalmente.

CÓDIGO:

250610189029



PATRÍCIA QUINTÃO

Mestre em Engenharia de Sistemas e computação pela COPPE/UFRJ, Especialista em Gerência de Informática e Bacharel em Informática pela UFV. Atualmente é professora no Gran Cursos Online; Analista Legislativo (Área de Governança de TI), na Assembleia Legislativa de MG; Escritora e Personal & Professional Coach. Atua como professora de Cursinhos e Faculdades, na área de Tecnologia da Informação, desde 2008. É membro: da Sociedade Brasileira de Coaching, do PMI, da ISACA, da Comissão de Estudo de Técnicas de Segurança (CE-21:027.00) da ABNT, responsável pela elaboração das normas brasileiras sobre gestão da Segurança da Informação. Autora dos livros: Informática FCC – Questões comentadas e organizadas por assunto, 3ª. edição e 1001 questões comentadas de informática (Cespe/UnB), 2ª. edição, pela Editora Gen/Método. Foi aprovada nos seguintes concursos: Analista Legislativo, na especialidade de Administração de Rede, na Assembleia Legislativa do Estado de MG; Professora titular do Departamento de Ciência da Computação do Instituto Federal de Educação, Ciência e Tecnologia; Professora substituta do DCC da UFJF; Analista de TI/Suporte, PRODABEL; Analista do Ministério Público MG; Analista de Sistemas, DATAPREV, Segurança da Informação; Analista de Sistemas, INFRAERO; Analista – TIC, PRODEMGE; Analista de Sistemas, Prefeitura de Juiz de Fora; Analista de Sistemas, SERPRO; Analista Judiciário (Informática), TRF 2ª Região RJ/ES, etc.

GRAN
CONCURSOS

SUMÁRIO

Apresentação	4
Procedimentos de Segurança	5
1. Adotar Estratégias para Redução de Spams.....	5
2. Cuidados com Contas e Senhas	6
3. Política de Segurança da Informação (PSI)	7
4. Cuidados com Malware	10
5. Backup (Cópia de Segurança)	11
6. Autenticação.....	16
7. Plano de Segurança da Informação	18
8. Classificação das Informações	22
9. Aplicativos e Mecanismos de Segurança	23
Resumo	62
Questões Comentadas em Aula	67
Exercícios	71
Gabarito	85
Gabarito Comentado.....	86
Referências	122

APRESENTAÇÃO

Patrícia Quintão é Mestra em Engenharia de Sistemas e computação pela COPPE/UFRJ, Especialista em Gerência de Informática e Bacharel em Informática pela UFV (Universidade Federal de Viçosa).

Atualmente é professora no Gran e leciona também na pós-graduação e na graduação da Gran Faculdade. Ainda é Analista Legislativo (Área de Governança de TI), na Assembleia Legislativa de MG e escritora e *Personal & Professional Coach*.

Atua como professora de Cursinhos e Faculdades, na área de Tecnologia da Informação, desde 2008.

É membro: da Sociedade Brasileira de Coaching, do PMI, da ISACA, da Comissão de Estudo de Técnicas de Segurança (CE-21:027.00) da ABNT, responsável pela elaboração das normas brasileiras sobre gestão da Segurança da Informação.

Autora dos livros:

- Informática FCC – Questões comentadas e organizadas por assunto, 3ª. Edição; e
- 1001 questões comentadas de informática (Cespe/UnB), 2ª. edição, pela Editora Gen/Método.

Foi aprovada nos seguintes concursos:

- Analista Legislativo, na especialidade de Administração de Rede, na Assembleia Legislativa do Estado de MG;
- Professora titular do Departamento de Ciência da Computação do Instituto Federal de Educação, Ciência e Tecnologia;
- Professora substituta do DCC da UFJF;
- Analista de TI/Suporte, PRODABEL;
- Analista do Ministério Público MG;
- Analista de Sistemas, DATAPREV, Segurança da Informação;
- Analista de Sistemas, INFRAERO;
- Analista – TIC, PRODEMGE;
- Analista de Sistemas, Prefeitura de Juiz de Fora;
- Analista de Sistemas, SERPRO;
- Analista Judiciário (Informática), TRF 2ª Região RJ/ES etc.

Feliz em estar aqui com vocês!

À luta, guerreiro(a)! É um prazer revê-lo(a).

Rumo então à aula sobre **Procedimentos de segurança**, com foco nas diversas medidas de proteção.

Sucesso nos estudos!

Profª Patrícia Lima Quintão

PROCEDIMENTOS DE SEGURANÇA

Uma série de procedimentos, considerados como “**boas práticas de segurança**”, podem ser implementados **pela organização** para salvaguardar os **ativos** (que é o que a segurança da informação busca proteger) da organização (CertBR, 2006).

Vamos então à descrição dessas práticas principais!

1. ADOTAR ESTRATÉGIAS PARA REDUÇÃO DE SPAMS

Como podemos reduzir o volume de spam que chega até nossas caixas postais?

A resposta é bem simples! Basta **navegar de forma consciente na rede**. Este conselho é o mesmo que recebemos para zelar pela nossa segurança no trânsito ou ao entrar e sair de nossas casas.

A seguir destacamos as principais dicas que foram reportadas pelo CertBr (2012) para que os usuários da Internet desfrutem dos recursos e benefícios da rede, com segurança:

- **Preservar as informações pessoais**, tais como: endereços de e-mail, dados pessoais e, principalmente, cadastrais de bancos, cartões de crédito e senhas. **Um bom exercício é pensar que ninguém forneceria seus dados pessoais a um estranho na rua, ok? Então, por que liberá-la na Internet?**
- **Ter, sempre que possível, e-mails separados para assuntos pessoais, profissionais, para as compras e cadastros on-line**. Certos usuários mantêm um e-mail somente para assinatura de listas de discussão.

- Obs.:** No caso das promoções da Internet, geralmente, será necessário preencher formulários. **Ter um e-mail para cadastros on-line é uma boa prática para os usuários com o perfil descrito**. Ao preencher o cadastro, procure desabilitar as opções de recebimento de material de divulgação do site e de seus parceiros, pois justamente nesse item é que muitos usuários atraem spam, inadvertidamente!
- Não ser um “clicador compulsivo”, ou seja, o usuário deve procurar controlar a curiosidade de verificar sempre a indicação de um site em um e-mail suspeito de spam. **Pensar, analisar as características do e-mail e verificar se não é mesmo um golpe ou código malicioso.**
 - Não ser um “caça-brindes”, “papa-liquidações” ou “destruidor-de-promoções”, rs! Ao receber e-mails sobre brindes, promoções ou descontos, reserve um tempo para analisar o e-mail, sua procedência e verificar no site da empresa as informações sobre a promoção em questão. Vale lembrar que os sites das empresas e instituições financeiras têm mantido alertas em destaque sobre os golpes envolvendo seus serviços. Assim, a visita ao site da empresa pode confirmar a promoção ou alertá-lo sobre o golpe que acabou de receber por e-mail!

- **Ferramentas de combate ao spam (anti-spams)** são geralmente disponibilizadas do lado dos servidores de *e-mail*, filtrando as mensagens que são direcionadas à nossa caixa postal. Importante que se tenha um filtro *anti-spam* instalado, ou ainda, usar os recursos *anti-spam* oferecidos por seu provedor de acesso.
- Além do *anti-spam*, existem outras ferramentas bastante importantes para o usuário da rede: *antispyware*, *firewall* pessoal, antivírus, etc.

2. CUIDADOS COM CONTAS E SENHAS

Uma senha pode ser descoberta ao ser usada em computadores infectados; ao ser usada em *sites* falsos; por meio de tentativas de adivinhação; ao ser capturada enquanto trafega na rede, sem estar criptografada; por meio do acesso ao arquivo onde a senha foi armazenada caso ela não tenha sido gravada de forma criptografada; com o uso de técnicas de engenharia social, como forma a persuadi-lo a entregá-la voluntariamente; pela observação da movimentação dos seus dedos no teclado ou dos cliques do *mouse* em teclados virtuais (CERT.BR,2012).

Uma senha boa, bem elaborada, é aquela que é difícil de ser descoberta (forte) e fácil de ser lembrada. Não convém que você crie uma senha forte se, quando for usá-la, não conseguir

recordá-la. Também não convém que você crie uma senha fácil de ser lembrada se ela puder ser facilmente descoberta por um atacante.

Alguns elementos que você **não deve** usar na elaboração de suas senhas são: **qualquer tipo de dado pessoal** (jamais utilizar como senha seu nome, sobrenomes, números de documentos, placas de carros, números de telefones, datas que possam ser relacionadas com você, etc.); **sequências de teclado; palavras que façam parte de listas.**

Alguns elementos que você deve usar na elaboração de suas senhas são: números aleatórios; grande quantidade de caracteres; diferentes tipos de caracteres (CERT.BR,2013).

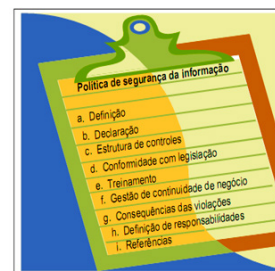
Mais dicas:

- crie uma senha que contenha pelo menos oito caracteres, compostos de letras, números e símbolos;
- utilize uma senha diferente para cada serviço (por exemplo, uma senha para o banco, outra para acesso à rede corporativa da sua empresa, outra para acesso a seu provedor de Internet etc.);
- altere a senha com frequência;
- crie tantos usuários com privilégios normais, quantas forem as pessoas que utilizam seu computador;
- utilize o usuário *Administrator* (ou *root*) somente quando for estritamente necessário.

3. POLÍTICA DE SEGURANÇA DA INFORMAÇÃO (PSI)

Obs.: A **política de segurança da informação** é a fundação da segurança de informação de uma organização (Neto, 2011).

- Ela busca “prover uma orientação e apoio da direção para a segurança da informação de acordo com os requisitos do negócio e com as leis e regulamentações relevantes” (ABNT NBR ISO/IEC 27002:2005).
- Uma política adequada e efetiva contém informação suficiente sobre **o que deve ser feito** para proteger a informação e as pessoas de uma organização. Além disso, é importante observar que o sucesso do processo de identificar e implementar **controles** de segurança adequados exige a participação efetiva de todos os empregados da organização (Neto, 2011).

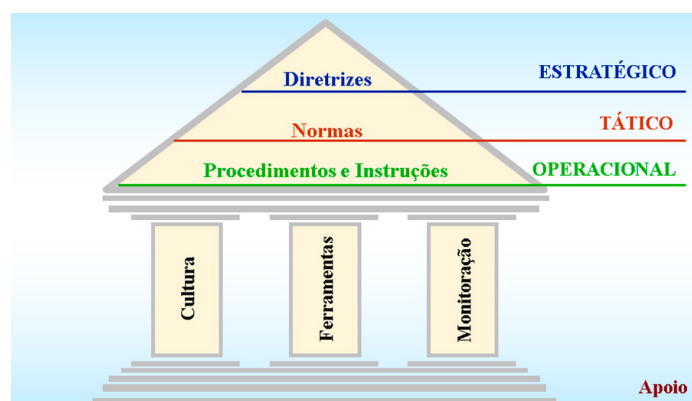


São **objetivos** da Política de Segurança da Informação:

- Alinhar as ações em segurança da informação com as **estratégias de negócio** da organização;
- Explicitar a visão da **alta direção** em relação à segurança da informação;
- Expressar o comprometimento da alta direção com a manutenção da segurança da informação;
- Direcionar e normatizar as ações referentes à segurança da informação;
- Alinhar as ações em segurança da informação com as Leis e Regulamentações pertinentes;
- Buscar conformidade com Normas externas e cláusulas contratuais;
- Instruir sobre procedimentos relativos à segurança da informação;
- Delegar responsabilidades;
- Definir requisitos de Conscientização, Educação e Treinamentos;
- Definir ações disciplinares; dentre outros.

Obs.: Pode ser conceituada como um conjunto de **diretrizes** e **normas** que traduz as necessidades e práticas da organização quanto à segurança da informação, objetivando a **normalização** das ações necessárias para levar a organização a um nível de segurança da informação aceitável.

Figura. Modelo de Estruturação da Política de Segurança



A seguir, vamos destacar os principais elementos dessa figura:

Diretrizes (Estratégico)	- Valores que devem ser seguidos, para que o principal patrimônio – a informação – tenha o nível de segurança exigido. - Devem permitir que sejam aplicadas a qualquer ambiente existente, não devendo conter termos técnicos. - Ex.: “A informação deve ser tratada como um patrimônio, devendo ser protegida no uso, acesso, tráfego e armazenamento, de acordo com sua classificação em graus de confidencialidade e criticidade” (DATAPREV, 10/09/2004).
Normas (Tático)	- Conjunto de regras gerais e específicas da segurança das informações que devem ser usadas por todos os segmentos envolvidos nos processos comerciais da instituição. - Podem ser elaboradas por ativo, área, tecnologia, processo comercial, público a que se destina, etc. - A norma é mais detalhada, sendo desenvolvida para os itens críticos da Política.
Procedimentos (Nível Operacional)	- Conjunto de orientações para realizar atividades operacionais de segurança. Detalhe dos cursos de ação a seguir pelo pessoal diante de diversas situações que surgem das atividades operacionais. - Ex1: Procedimentos para realização de suporte no BD, quem são os responsáveis, a periodicidade, o armazenamento; - Ex2: Procedimentos para instalação de estações de trabalho dos usuários.
Instruções ou Padrões Técnicos (Nível Operacional)	Conjunto de comandos operacionais a serem executados no momento de realização de um procedimento de segurança. Ex.: Instruções para criar conta de usuário no Linux.

Bases de Sustentação da Política de Segurança

Cultura	O treinamento de todas as pessoas deve ser contínuo, para atualizá-las nos conceitos e sedimentar a consciência da segurança.
Ferramentas	Uso de ferramentas para melhoria da segurança, como <i>backups</i> programados, controle de acessos, etc.
Monitoramento/ Administração	A implementação da Política de Segurança deve ser monitorada. Efetuar um ciclo de manutenção para acertos decorrentes de problemas encontrados, reclamações de funcionários ou resultados de auditoria. Efetuar um ciclo de melhorias para adaptar a segurança às novas tecnologias, às mudanças administrativas e ao aparecimento de novas ameaças.

As etapas do processo de implantação de uma política de segurança da informação, conforme destacadas por (Neto, 2011) envolvem:

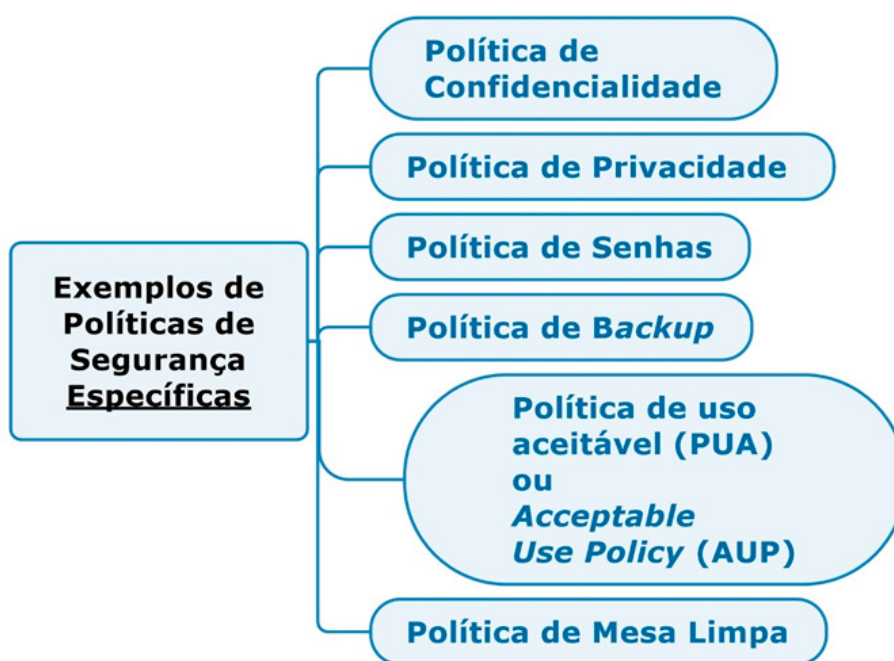
- **Desenvolvimento da Política:** definir os requisitos corporativos da política de segurança da informação e estabelecer padrões para documentação da política;
- **Aprovação da Política:** gerenciar a transição da identificação das necessidades da política até a obtenção da autorização por meio de uma diretiva gerencial;
- **Implementação da Política:** solicitar e receber apoio executivo e contar com o envolvimento das áreas de negócio, e desenvolver um programa de conscientização de segurança corporativo;

- **Conformidade com a Política:** avaliar a conformidade e a efetividade da política estabelecida e ter ações corretivas para a não conformidade; e
- **Manutenção da Política:** conduzir revisões formais da política e estabelecer um processo de gestão de mudanças. Nesse contexto, é importante também abordarmos a hierarquia de documentos de uma organização. No caso específico da segurança da informação, essa hierarquia permite à organização apresentar os documentos de segurança que foram implementados ou que ainda estão na fase de planejamento e relacioná-los de acordo com um tema de risco ou de segurança.

É importante, então, elaborar uma Política de Segurança com o objetivo de solucionar ou minimizar as vulnerabilidades encontradas na organização.

CertBR (2012) destaca que **a política de segurança pode conter outras políticas específicas**, como:

Figura. Exemplos de Políticas de Segurança Específicas



(QUINTÃO, 2024)

POLÍTICAS DE SEGURANÇA ESPECÍFICAS	
Política de Confidencialidade	Define como são tratadas as informações institucionais , ou seja, se elas podem ser repassadas a terceiros.
Política de Privacidade	Define como são tratadas as informações pessoais , sejam elas de clientes, usuários ou funcionários.
Política de Senhas	Define as regras sobre o uso de senhas nos recursos computacionais , como tamanho mínimo e máximo, regra de formação e periodicidade de troca.

Política de Backup	Define as regras sobre a realização de cópias de segurança , como tipo de mídia utilizada, período de retenção e frequência de execução.
Política de uso aceitável (PUA) ou Acceptable Use Policy (AUP)	Também chamada de “Termo de Uso” ou “Termo de Serviço”, define as regras de uso dos recursos computacionais, os direitos e as responsabilidades de quem os utiliza e as situações que são consideradas abusivas.
Política de Mesa Limpa	Conjunto de medidas para deixar o espaço de trabalho organizado , de forma que senhas, dados ou arquivos confidenciais não sejam deixados à vista por descuido, promovendo a confidencialidade dos documentos.

É fundamental elaborar uma **Política de Segurança** com o objetivo de solucionar ou minimizar as vulnerabilidades encontradas na organização.

Nesse contexto, destacamos os principais itens necessários para uma boa política de segurança:

- possuir instalações físicas adequadas que ofereçam o mínimo necessário para garantia da integridade dos dados;
- controle de umidade, temperatura e pressão;
- sistema de aterramento projetado para suportar as descargas elétricas, extintores de incêndio adequados para equipamentos elétricos/eletrônicos;
- uso adequado de equipamentos de proteção e segurança tais como: UPS (“no-break”), filtro de linha, estabilizador de tensão;
- manutenção do computador, limpeza e política da boa utilização;
- utilização de sistemas operacionais que controlem o acesso de usuários e que possuem um nível de segurança bem elaborado, juntamente com o controle de senhas;
- utilização de sistemas de proteção de uma rede de computadores, tais como **Firewall** (sistema que filtra e monitora as ações na rede);
- software antivírus atualizado constantemente;
- sistema de criptografia (ferramenta que garante a segurança em todo ambiente computacional que precise de sigilo em relação às informações que manipula). No envio de mensagens uma mensagem é criptografada e se for interceptada dificilmente poderá ser lida, somente o destinatário possui o código necessário;
- **treinamento** e conscientização de funcionários para diminuir as falhas humanas;
- realização de **backups** (cópia de segurança **para salvar os dados, geralmente mantida em CDs, DVDs, fitas magnéticas, pendrives, etc., para que possam ser restaurados em caso de perda dos dados originais**).

4. CUIDADOS COM MALWARE

O **combate a códigos maliciosos** poderá envolver uma série de ações, como:

- instalação de ferramentas antivírus e *antispyware* no computador, lembrando de mantê-las atualizadas frequentemente. A banca pode citar ferramentas *antimalware* nesse contexto também;

- não realizar abertura de arquivos suspeitos recebidos por *e-mail*;
- fazer a instalação de *patches* de segurança e atualizações corretivas de *softwares* e do sistema operacional quando forem disponibilizadas (proteção contra *worms* e *bots*), etc.

***Vírus**

- Instale e mantenha atualizado um bom programa antivírus;
- atualize as assinaturas do antivírus, de preferência diariamente;
- configure o antivírus para verificar os arquivos obtidos pela Internet, discos rígidos (HDs), flexíveis (disquetes) e unidades removíveis, como CDs, DVDs e *pen drives*;
- desabilite no seu programa leitor de *e-mails* a auto-execução de arquivos anexados às mensagens;
- não execute ou abra arquivos recebidos por *e-mail* ou por outras fontes, mesmo que venham de pessoas conhecidas. Caso seja necessário abrir o arquivo, certifique-se que ele foi verificado pelo programa antivírus;
- utilize na elaboração de documentos formatos menos suscetíveis à propagação de vírus, tais como RTF, PDF ou *PostScript* etc.

*** Worms, Bots e Botnets**

- Siga todas as recomendações para prevenção contra vírus listadas no item anterior;
- mantenha o sistema operacional e demais *softwares* sempre atualizados;
- aplique todas as correções de segurança (*patches*) disponibilizadas pelos fabricantes, para corrigir eventuais vulnerabilidades existentes nos *softwares* utilizados;
- instale um *firewall* pessoal, que **em alguns casos** pode evitar que uma vulnerabilidade existente seja explorada (**observe que o firewall não corrige as vulnerabilidades!**) ou que um *worm* ou *bot* se propague.

***Cavalos de Troia, Backdoors, Keyloggers e Spywares**

- Siga todas as recomendações para prevenção contra vírus, *worms* e *bots*;
- instale um *firewall* pessoal, que **em alguns casos** pode evitar o acesso a um *backdoor* já instalado em seu computador etc.;
- utilize pelo menos uma ferramenta *antispyware* e mantê-la sempre atualizada.

5. BACKUP (CÓPIA DE SEGURANÇA)

O procedimento de **backup (cópia de segurança)** pode ser descrito de forma simplificada como copiar dados de um dispositivo para o outro com o objetivo de posteriormente recuperar as informações, caso haja algum problema.

Obs.: **Backup ou cópia de segurança:** é uma cópia de informações importantes que está guardada em um local seguro. **Objetivo:** recuperação de dados em caso de falha (perda dos dados originais); acesso a versões anteriores das informações.

Um **backup** envolve cópia de dados em um meio fisicamente separado do original, regularmente, de forma a protegê-los de qualquer eventualidade.

Para a realização de um **backup**, podemos utilizar: *pendrive*, CD, DVD, HD externo, pastas compartilhadas na rede, armazenamento na nuvem ou *cloud storage* (uso do OneDrive – antigo SkyDrive, Dropbox, ou outro ambiente), Fitbit-Dat, etc.

Seja ele qual for a sua escolha, todos têm a mesma finalidade. **A diferença está na capacidade, vida útil e segurança de cada um.** Não é aconselhável o uso de outra partição do HD principal ou HD Interno, pois se acontecer algum problema com a máquina, todos os dados (originais e *backup*) serão perdidos.

Assim, copiar nossas fotos digitais, armazenadas no HD (disco rígido), para um DVD é fazer **backup**. Se houver algum problema com o HD ou se acidentalmente apagarmos as fotos, podemos então restaurar os arquivos a partir do DVD. Nesse exemplo, chamamos as cópias das fotos no DVD de cópias de segurança ou backup.

Bem, pessoal, é importante destacar também que a proteção das informações é fundamental para o funcionamento cotidiano de qualquer empresa. Na era digital, a **informação** é um dos ativos mais valiosos, e **ter uma estratégia de backup e recuperação eficiente e gerenciável tornou-se vital para o negócio.**

Atributos de Arquivos

- São informações associadas a **arquivos** e **pastas**.
- Definem o comportamento do **sistema de arquivos**.
- Podem ser acessados por meio das propriedades (**Alt+Enter** ou clique com botão direito do mouse no ícone do arquivo ou pasta pelo Windows).

Ao clicar com o botão direito do mouse no ícone de um arquivo do Windows, e selecionar a opção **Propriedades**; em seguida, guia **Geral** -> **Avançados**, será exibida uma caixa “**o arquivo está pronto para ser arquivado**”, marcada como padrão (No **Windows XP**, leia-se **arquivo morto**).

Em uma pasta irá aparecer a caixa “**Pasta pronta para arquivamento**”, conforme ilustrado nas figuras seguintes.

Figura. Atributos de arquivos, no Windows 7

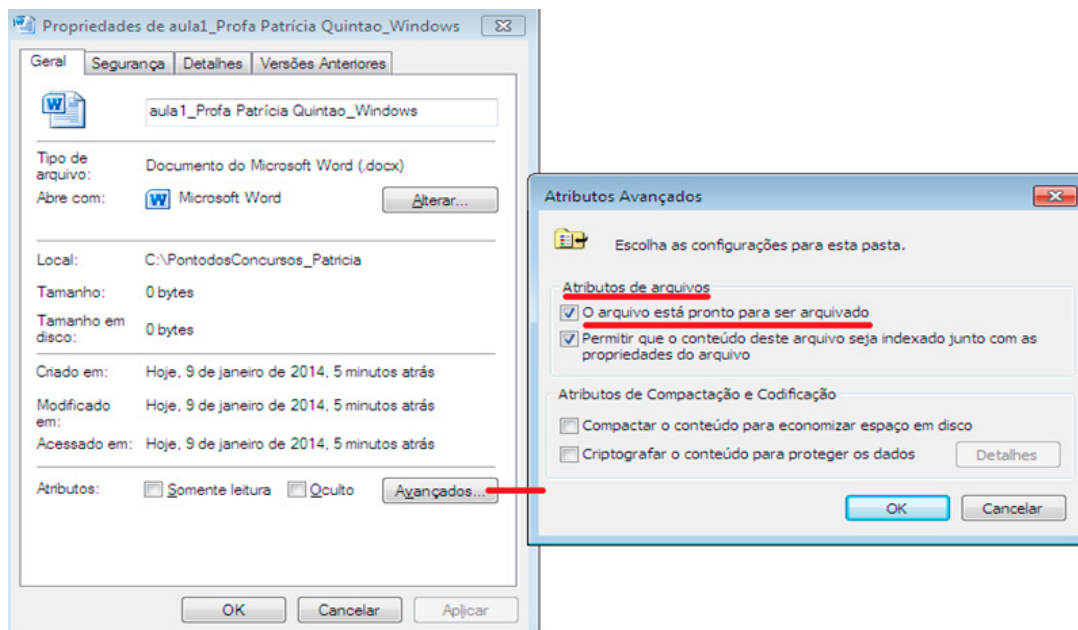
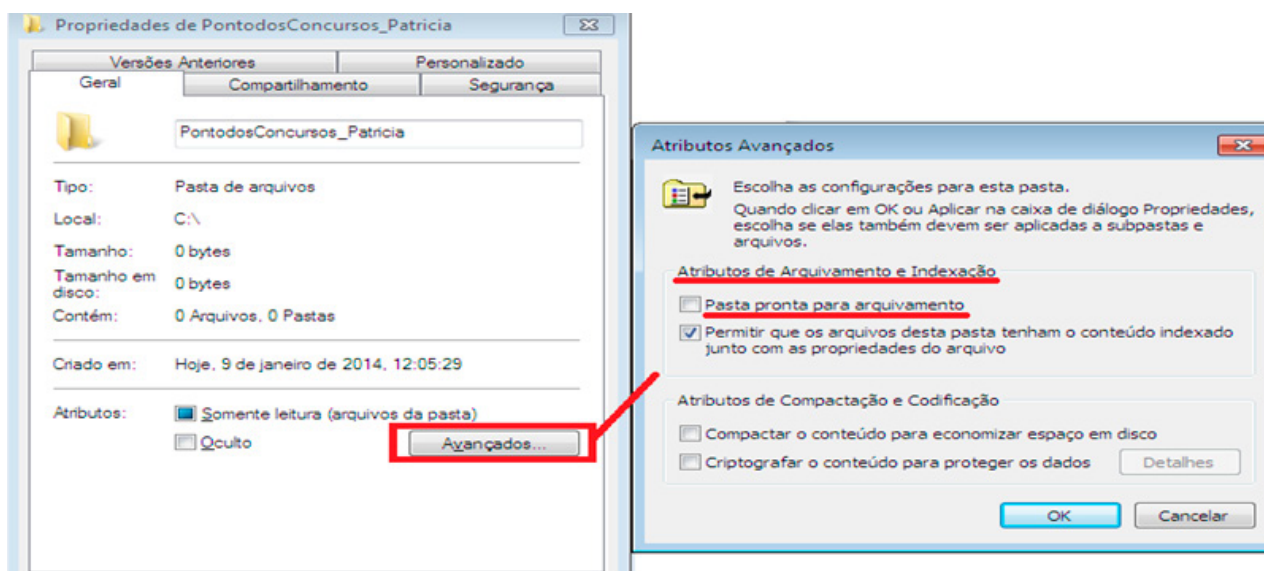


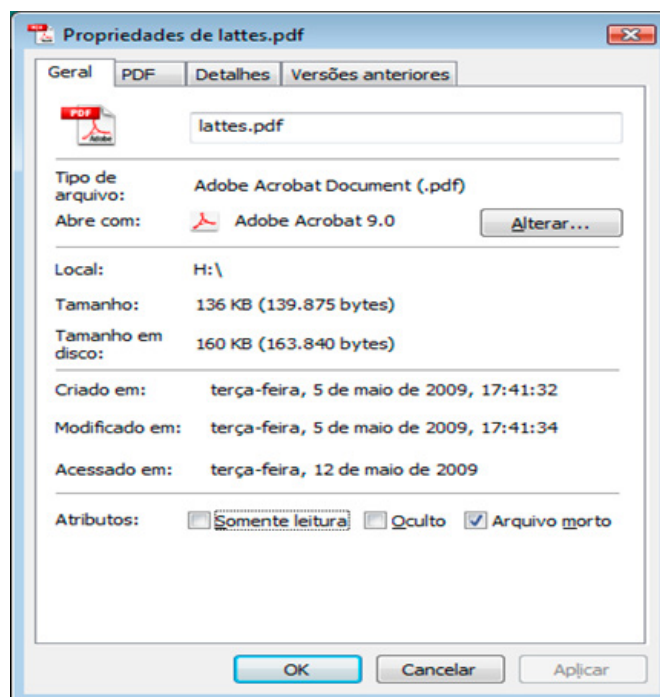
Figura. Windows XP



Figura. Atributos de uma pasta no Windows 7



A tela seguinte destaca opção de “**arquivo morto**” obtida ao clicar com o botão direito do mouse no arquivo intitulado lattes.pdf, do meu computador que possui o sistema operacional Windows Vista.



Assim temos:

- Quando um arquivo/pasta está com o atributo marcado, significa que ele deverá ser copiado no próximo backup.
- Se estiver desmarcado, significa que, provavelmente, já foi feito um backup deste arquivo.

Técnicas (Tipos) de Backup

As principais **técnicas (tipos) de backup**, que podem ser combinadas com os mecanismos de **backup** dinâmico (*on-line*) e estático (*off-line*), estão listadas a seguir:

NorMal (Total ou Global ou Full ou Completo)	• COPIA TODOS os arquivos e pastas selecionados. • DESMARCA o atributo de arquivamento (arquivo morto): limpa os marcadores. • Caso necessite restaurar o <i>backup</i> normal, você só precisa da cópia mais recente. • Normalmente, este <i>backup</i> é executado quando se cria um conjunto de <i>backup</i> pela 1ª vez. • Agiliza o processo de restauração, pois somente um <i>backup</i> será restaurado.
IncreMental	• Copia somente os arquivos CRIADOS ou ALTERADOS desde o último <i>backup</i> normal ou incremental, o que for mais recente. • O atributo de arquivamento (arquivo morto) É DESMARCADO: limpa os marcadores. Resumindo: A estratégia do backup INCREMENTAL é: – mais rápida para fazer o backup, pois copia apenas os arquivos modificados (geralmente poucos arquivos por dia); – mais demorada para fazer a restauração, visto que é necessário restaurar diversas fitas.

Diferencial	• Gravam-se, a cada <i>backup</i> as diferenças entre os dados salvos no último <i>backup</i> normal (<i>Full</i> ou <i>Completo</i>) e a data de gravação do <i>backup</i> diferencial. • Faz <i>backup</i> de todos os dados alterados desde o último <i>backup</i> completo. • O atributo de arquivamento (arquivo morto) NÃO É ALTERADO: não limpa os marcadores. Note que o <i>backup</i> diferencial é <u>acumulativo</u>, ou seja, em cada fita de <i>backup</i> sempre estarão inclusos os arquivos que foram modificados desde o último <i>backup full</i> (normal). Resumindo: A estratégia do backup DIFERENCIAL é: – mais demorada para fazer o backup, pois copia cada arquivo que foi alterado do último backup normal realizado; – mais rápida para fazer a restauração, pois é necessário restaurar somente dois dias de backup (o normal e o do dia anterior ao crash).
Cópia (Auxiliar ou Secundária)	• Faz o <i>backup</i> de arquivos e pastas selecionados. • O atributo de arquivamento (arquivo morto) NÃO É ALTERADO: não limpa os marcadores!

Resumindo...

Tipo de backup	Dados copiados	Ação após a cópia
NorMal (Global ou Total ou Full ou Completo)	Copia TODOS os arquivos selecionados.	Marca todos os arquivos como copiados (ou seja, apaga o <i>Flag archive</i> após o becape).
IncreMental	Copia os arquivos novos ou alterados desde o último <i>backup</i> normal ou incremental. Mais rápido de processar e mais lento de restaurar; os arquivos de <i>backup</i> são menores.	Marca todos os arquivos como copiados (ou seja, apaga o <i>Flag archive</i> após o becape).
Diferencial	Faz <i>backup</i> de todos os dados alterados desde o último <i>backup</i> completo. Mais lento de processar e mais rápido de restaurar. Os arquivos de <i>backup</i> são maiores.	Não marca nada, ou seja, não apaga o atributo de marcação (ou o <i>Flag archive</i>).
Diário	Copia os arquivos criados ou alterados no dia.	Não marca nada, ou seja, não apaga o atributo de marcação.
Cópia	Copia todos os arquivos selecionados.	Não marca nada, ou seja, não apaga o atributo de marcação.

Recuperação do Backup (Restauração de Arquivos e Pastas)

Quanto à **RECUPERAÇÃO** do backup:

- Para recuperar um backup normal, será necessária a cópia mais recente do arquivo ou da fita de backup para restaurar todos os arquivos. Geralmente, o backup normal é executado quando você cria um conjunto de backup pela primeira vez.
- Se você estiver executando uma combinação dos backups normal e diferencial, a restauração de arquivos e pastas exigirá o último backup normal e o último backup diferencial, já que este contém tudo que é diferente do primeiro.

- Se você utilizar uma combinação dos backups normal e incremental, precisará do último conjunto de **backup** normal e de todos os conjuntos de **backups** incrementais para restaurar os dados, deixando a recuperação lenta e com uma maior probabilidade de erros.



O backup dos dados que utiliza uma combinação de backups normal e incremental exige menos espaço de armazenamento e é o método mais rápido. No entanto, a recuperação de arquivos pode ser difícil e lenta porque o conjunto de backup pode estar armazenado em vários discos ou fitas.



O backup dos dados que utiliza uma combinação dos backups normal e diferencial é mais longo, principalmente se os dados forem alterados com frequência, mas facilita a restauração de dados, porque o conjunto de backup geralmente é armazenado apenas em alguns discos ou fitas.

Fonte: [http://technet.microsoft.com/pt-r/library/cc784306\(v=ws.10\).aspx](http://technet.microsoft.com/pt-r/library/cc784306(v=ws.10).aspx)

Plano de segurança para a política de **backup**

É importante estabelecer uma **política de backup** que obedeça a critérios bem definidos sobre a segurança da informação envolvida, levando-se em consideração os **serviços** que estarão disponíveis; **quem** pode acessar (perfis de usuários) as **informações**; como realizar o acesso (acesso remoto, local, senhas, etc.); o que fazer em caso de falha; quais os mecanismos de segurança (antivírus), dentre outros.

Em suma, o objetivo principal dos **backups** é garantir a **disponibilidade** da informação. Por isso a política de backup é um processo relevante no contexto de segurança dos dados.

6. AUTENTICAÇÃO

Conforme destaca Stallings (2008), “o serviço de **autenticação** refere-se à **garantia de que uma comunicação é autêntica**.”

No caso de uma única mensagem, como uma advertência ou um sinal de alarme, a função do serviço de autenticação é **garantir ao destinatário que a mensagem é proveniente de onde ela afirma ter vindo**.

No caso de uma interação de saída, como a conexão de um terminal com um hospedeiro, dois aspectos estão envolvidos. **Primeiro, no momento do início da conexão, o serviço garante que as duas entidades são autênticas**, ou seja, que cada uma é a entidade que afirma ser. **Segundo, o serviço precisa garantir que a conexão não sofra interferência de modo que um terceiro possa fingir ser uma das duas partes legítimas**, para fins de transmissão ou recepção não autorizada”.



Obs.: IDENTIFICAÇÃO: é a capacidade de extrair informações de um usuário ou aplicação as quais o identifiquem unicamente.

AUTENTICAÇÃO: é a capacidade de garantir que um usuário, sistema ou informação é mesmo quem alega ser. A autenticação é essencial para a segurança dos sistemas, ao validar a identificação dos usuários, concedendo-lhes a **AUTORIZAÇÃO** para o acesso aos recursos.

Conforme Stallings, podemos dividir os mecanismos de autenticação em **grupos básicos**:

- **"O que você é" ou autenticação baseada na característica (biometria estática)** – tipo de autenticação que considera informações relacionadas a características físicas e comportamentais, também chamadas de características biométricas, como a impressão digital, a retina e a face;
- **"O que você faz" ou autenticação baseada em padrões (biometria dinâmica):** esse tipo de autenticação considera o reconhecimento de padrões do indivíduo previamente salvos (em algum servidor, etc.). A autenticação ocorre comparando **os padrões envolvidos na resolução de determinada atividade ou desafio**, no reconhecimento de voz, escrita manual, ritmo de digitação, etc.
- **"O que você possui" ou autenticação baseada na propriedade – tipo de autenticação caracterizado por objetos físicos que o usuário possui**, podendo ser cartões, chaves, *tokens*, ou qualquer outro dispositivo físico eletrônico.
- **"O que apenas você sabe" ou autenticação baseada no conhecimento** – nesse tipo de autenticação é preciso saber alguma informação que será cadastrada na base de informações e todas as vezes que necessário precisará ser validada. Como exemplo temos as senhas, chaves de criptografia, PIN (*Personal Identification Number*).

A **autenticação**, em regra, **depende** de um ou mais **modos ou fatores de autenticação**, listados a seguir:

Algo que o usuário TEM	São utilizados objetos específicos como cartões de identificação, <i>smart cards</i> , <i>tokens</i> USB.
Algo que o usuário CONHECE	São utilizadas senhas fixas, <i>one-time passwords</i> , sistemas de desafio-resposta.
Algo que o usuário É	Geralmente são usados <u>meios biométricos</u> , como impressão digital, padrão retinal, padrão de voz, reconhecimento de assinatura, reconhecimento facial.
ONDE o usuário ESTÁ	Quando o acesso a sistemas só pode ser realizado em uma máquina específica, cujo acesso é restrito.

Autenticação forte consiste na autenticação por mais de um modo, ou seja, da **combinação de mais de uma maneira de autenticação**. Um exemplo disso são as transações de saque num caixa rápido. Em regra, se utiliza:

- algo que você **TEM**: um cartão da conta bancária; e
- algo que você **SABE**: a senha do cartão.

7. PLANO DE SEGURANÇA DA INFORMAÇÃO

A **gestão de segurança da informação** pode ser definida como um processo administrativo voltado para o gerenciamento da salvaguarda da informação numa organização. Envolve os processos de planejamento, organização, direção e controle das melhores práticas de segurança da informação (MARCONDES,2020). Trata-se de um conjunto de processos, planos, políticas, normas, procedimentos e boas práticas de segurança, para gerir sistematicamente os dados e informações sensíveis de uma organização (MARCONDES,2020).

Vamos então aos conceitos relacionados ao **Plano de segurança da Informação (PSI)**, conforme Marcondes (2020):

- **PSI é o resultado do planejamento de ações estruturantes** que alicerçam e amparam o **Sistema de Gestão da Segurança da Informação (SGSI)** de uma organização.
- Traz o resultado do estudo prévio de **cenário**, das **avaliações de riscos**, e dos **objetivos e medidas de segurança pretendidas** para garantir a Segurança da Informação (SI) na organização.
- Principais **objetivos do PSI**:
 - identificar e unificar objetivos no tocante à segurança da informação;
 - avaliar e controlar riscos potenciais;
 - identificar, priorizar, padronizar e implementar normas, procedimentos, ações e atividades;
 - elevar o grau de consciência quanto à segurança da informação;

- implantar mecanismos de monitoramento, controle e resposta nos processos de gestão da segurança da informação;
- minimizar os **riscos** e maximizar os pontos fortes da organização.
- **Benefícios** esperados:
 - **alinhamento dos objetivos da Segurança da Informação com as diretrizes do Planejamento Estratégico** da organização;
 - **conhecimento dos riscos de segurança** da informação que podem afetar ambientes e processos de trabalho da empresa;
 - capacidade de **identificar, avaliar e tratar os riscos** aos quais a informação possa estar exposta;
 - **melhora na alocação dos recursos para o tratamento de riscos**;
 - **proteção da informação**, de forma a preservar sua disponibilidade, sua integridade e, quando for o caso, sua confidencialidade, no grau que atenda às necessidades da organização;
 - **aprimoramento dos controles**, reduzindo riscos identificados, mediante o estabelecimento de nível de segurança adequado à criticidade dos processos de negócio envolvidos;
 - **melhoria na conscientização dos colaboradores** quanto à sua responsabilidade, à conduta adequada e ao comportamento desejável em relação à preservação da Segurança da Informação;
 - **criação de regulamentos e procedimentos** com o objetivo de orientar os usuários quanto às melhores práticas de uso e proteção da informação;
 - **prevenção de incidentes de segurança** da informação que possam ser danosos aos processos da empresa e sua imagem;
 - **preservação da disponibilidade dos serviços de TI** usados pela organização;
 - **atendimento aos requisitos de governança corporativa** relacionados à segurança da informação e à gerenciamento de riscos organizações;
 - **atendimento às legislações, às normas e as cláusulas contratuais**;
 - adoção dos controles e processos necessários para a certificações;
 - **fortalecimento da imagem da instituição** perante a sociedade, seus clientes, colaboradores, prestadores de serviço, parceiros e demais instituições com as quais interage.

Vamos às principais etapas para se fazer um **plano de segurança da informação**, conforme Marcondes (2020):

Etapa	Descrição
Selecionar Participantes para o Processo Planejamento	Envolve a definição de quem irá participar do planejamento da segurança da informação.
Elaborar a Política de Segurança da Informação	Com base nas melhores práticas e normas de segurança da informação, deve-se definir a Política de Segurança da Informação a ser adotada por toda a organização.

Etapa	Descrição
Realizar inventário de ativos	Inventariar os ativos (tangíveis/intangíveis) associados a informação e classificá-los de acordo com sua relevância para a organização e seus processos de trabalho.
Edição de Norma sobre Classificação de Informações	Editar norma que estabeleça critérios, procedimentos e responsabilidades para a classificação das informações segundo o grau de proteção requerido, além de criar os controles voltados a garantir que o grau de proteção atribuído à informação seja efetivamente observado ao longo de seu ciclo de vida.
Implantação Sistema de Gerenciamento de Risco de Segurança da Informação	Tem como objetivo gerir os riscos relativos à segurança da informação , visando à redução da incerteza decorrente de ameaças a que a informação está exposta.
Implantação de Sistema de Gestão da Segurança da Informação (SGSI)	Busca dotar a instituição de meios para acompanhar e gerir as iniciativas em Segurança da Informação que permeiam todas as áreas, visando minimizar a ocorrência de incidentes, tais como indisponibilidade, perda, acesso indevido ou alteração indevida da informação, com foco nos controles apropriados aos processos de trabalho da organização.
Campanha de Conscientização em Segurança da Informação	Visa assegurar a conscientização dos empregados, prestadores de serviço e fornecedores em relação a responsabilidades e atitudes no sentido de preservar a Segurança da Informação no âmbito da organização.

DIRETO DO CONCURSO

001. (CESGRANRIO/PROFISSIONAL PETROBRÁS DE NÍVEL TÉCNICO/PETROBRAS/INFORMÁTICA/PSP-RH-1/2011) Considere as afirmativas a seguir sobre segurança da informação.

I – Os softwares de segurança como firewalls e antivírus são o principal patrimônio de uma empresa, e os investimentos devem ser predominantes nesses produtos.

II – O plano de segurança da informação tem que contemplar os aspectos legais da informação, tais como propriedade intelectual e política de privacidade, entre outros.

III – O plano de segurança da informação é um processo que depende da visão estratégica do negócio e visa a proteger a rede interna de invasões indesejadas.

É correto APENAS o que se afirma em

- a) I
- b) II
- c) III
- d) I e II
- e) II e III



I – Errada. Todos os ativos envolvidos (hardware, software, pessoas, etc.) são relevantes no cenário em análise.

II – Certa. O plano de segurança da informação também irá contemplar os aspectos legais da informação, tais como propriedade intelectual e política de privacidade, etc. para atendimento às legislações, às normas e as cláusulas contratuais.

III – Certa. O plano de segurança da informação é o **resultado do planejamento de ações estruturantes** que alicerçam e amparam o **Sistema de Gestão da Segurança da Informação (SGSI)** de uma organização. PSI depende da visão estratégica do negócio e visa a proteger os ativos da empresa contra invasões indesejadas, acessos indevidos, etc.

Letra e.

002. (CEBRASPE-CESPE/ATIVIDADES TÉCNICAS DE COMPLEXIDADE INTELECTUAL/MEC/ANALISTA DE SEGURANÇA/2015) A equipe de analistas apresentou um plano de segurança da informação a um dos mais tradicionais e capilarizados ministérios do Brasil, desenvolvido após um extenso trabalho de pesquisa, ao longo de alguns meses. O documento, que aborda um grande número de tópicos sobre segurança da informação no ministério, contém análises, diagnósticos, problemas, soluções possíveis e propostas, organizados na forma de capítulos. Alguns dos capítulos são listados a seguir.

- < Conceitos de segurança da informação
- < Proposta de política de segurança
- < Classificação de informações
- < Auditoria e conformidade
- < Controle de acessos físicos e lógicos
- < Indicadores e métricas
- < Gestão de vulnerabilidades
- < Gestão de riscos
- < Criptografia
- < Gestão de continuidade de negócio
- < Terceirização de atividades ligadas à segurança da informação
- < Segurança em bancos de dados
- < Segurança no desenvolvimento de aplicações web
- < Segurança em redes de computadores
- < Resposta a incidentes computacionais em redes

O plano também contém um capítulo de revisão de normas brasileiras de segurança da informação, da série NBR da ABNT, tais como NBR 27001, NBR 27002 e NBR 27005.

Após a apresentação do plano de segurança à administração superior do ministério, aos assessores e aos convidados por meio de chamada pública, vários debates foram realizados, e foi variado o grau de conhecimento sobre os conceitos e as características do plano, de sua elaboração e do projeto de implantação.

Tendo como referência a situação hipotética apresentada, julgue o item a seguir, acerca de conceitos de segurança da informação possivelmente articulados no plano.

Os procedimentos de auditoria interna de segurança da informação precisam levar em consideração não só os requisitos normatizados em normas aplicáveis como a NBR 27001:2006, mas também a legislação aplicável e existente sobre o tema, no âmbito da administração pública federal.



Trecho extraído da norma ISO/IEC 27001:200. De acordo com a norma, “a organização deve conduzir auditorias internas do SGSI a intervalos planejados para determinar se os objetivos de controle, controles, processos e procedimentos do seu SGSI:

- **atendem aos requisitos desta Norma e à legislação ou regulamentações pertinentes;**
- atendem aos requisitos de segurança da informação identificados;
- estão mantidos e implementados eficazmente;
- são executados conforme esperado.

Certo.

8. CLASSIFICAÇÃO DAS INFORMAÇÕES

- Tem como objetivo **assegurar que a informação receba um nível adequado de proteção.**
- Convém que:
 - a informação seja classificada para indicar o nível esperado de proteção (prioridades sejam apontadas);
 - níveis de sensibilidade e criticidade sejam definidos para determinar medidas especiais de tratamento.
- Nem toda informação é crucial ou essencial a ponto de merecer proteções especiais de segurança, motivo pelo qual as informações devem ser analisadas e **classificadas** de acordo com suas **características** e **grau de criticidade** para o bom andamento dos negócios da organização.

Secreta	Informação <u>crítica para as atividades da organização</u> , cuja integridade deve ser preservada a qualquer custo e cujo acesso deve ser restrito a um número bastante reduzido de pessoas.
Confidencial	Informação <u>restrita aos limites da organização</u> , cuja divulgação ou perda pode levar a desequilíbrio operacional, e eventualmente, perdas financeiras, ou de confiabilidade perante o cliente externo, além de permitir vantagem expressiva ao concorrente.
Interna	<u>O acesso livre a esse tipo de informação deve ser evitado</u> , embora as consequências do uso não autorizado não sejam por demais sérias. Sua integridade é importante, mesmo que não seja vital.
Pública	<u>São informações que podem vir a público sem maiores consequências</u> danosas ao funcionamento normal da organização, e cuja integridade não é vital.

Política de Classificação da Informação

Refere-se ao conjunto de **normas, procedimentos e instruções** existentes que tratam sobre como proteger as informações.

9. APLICATIVOS E MECANISMOS DE SEGURANÇA

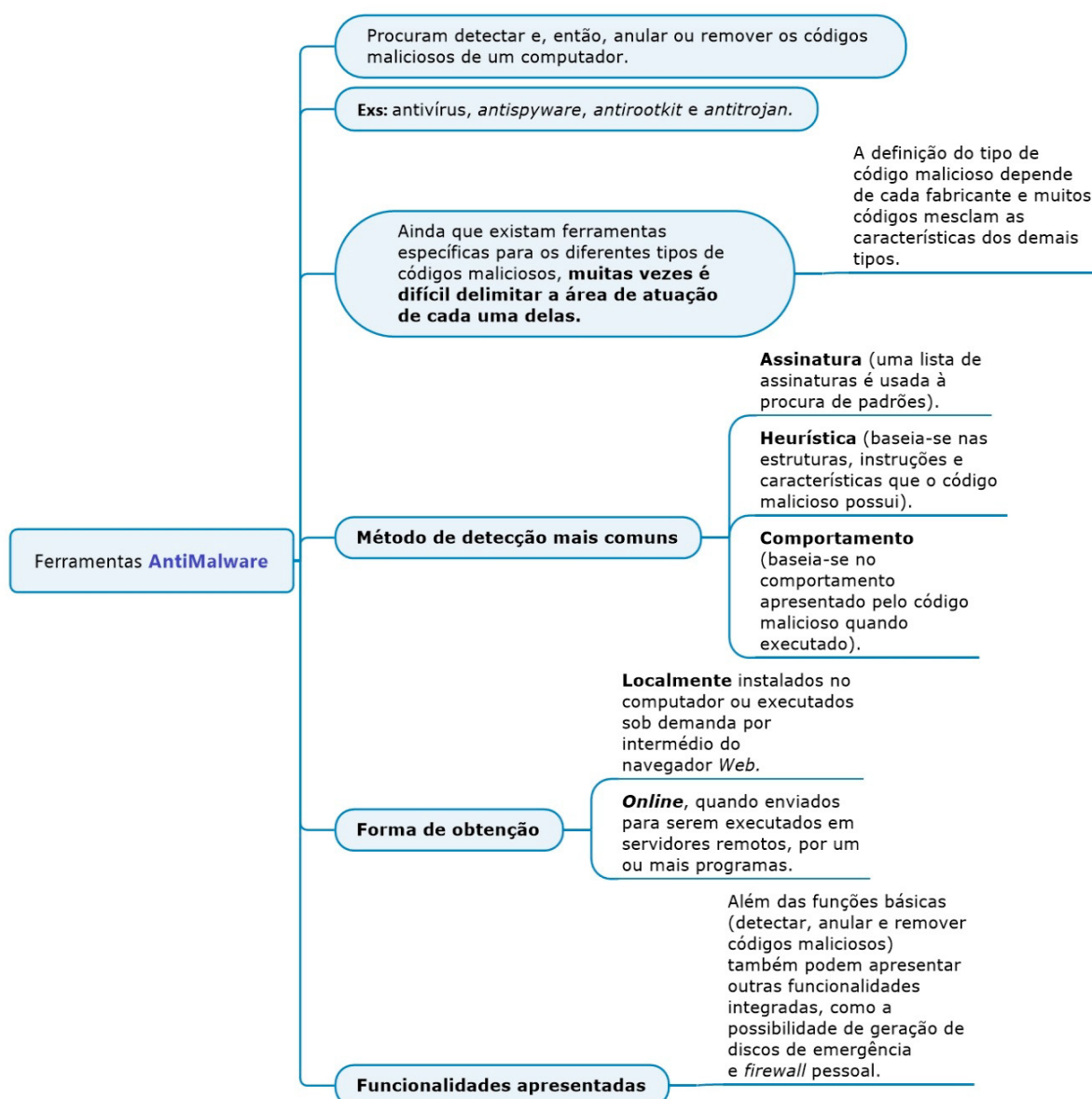
A proteção contra ameaças cibernéticas exige a implementação de uma série de procedimentos e o uso de ferramentas e mecanismos de segurança (CertBR, 2006). A evolução constante das ameaças digitais impulsiona o desenvolvimento de soluções cada vez mais avançadas, especialmente aquelas voltadas para a defesa dos dispositivos de acesso e processamento de dados, conhecidos como **endpoints**.

**** Ferramentas Antimalware, Antivírus e Antispyware: A Evolução para Proteção Abrangente**

Historicamente, o combate a softwares maliciosos (*malware*) teve início com ferramentas desenvolvidas para detectar e neutralizar tipos específicos de ameaças.

Antivírus, por exemplo, surgiram com o objetivo de identificar e remover vírus e outros programas maliciosos executáveis.

Já as ferramentas **antispyware** foram criadas para combater programas espiões (CertBR, 2013).



Exemplo de *antimalware online*:

VirusTotal – Free Online Virus, Malware and URL Scanner

<https://www.virustotal.com/>



Figura. VirusTotal

- Não há relação entre o custo e a eficiência de um programa, pois há versões gratuitas que apresentam mais funcionalidades que versões pagas de outros fabricantes (CertBr, 2013).
- **Cuidados a serem tomados**, conforme destaca CertBR (2013):
 - **tenha um antimalware instalado no computador** (programas *online*, apesar de bastante úteis, exigem que o computador esteja conectado à Internet para que funcionem corretamente e podem conter funcionalidades reduzidas);
 - **utilize programas online quando suspeitar que o antimalware local esteja desabilitado/comprometido** ou quando quiser confirmar o estado de um arquivo que já foi verificado pelo *antimalware* local;
 - **configure o antimalware para verificar toda e qualquer extensão de arquivo**, bem como os arquivos anexados aos *e-mails* e aqueles obtidos pela Internet;
 - configure o *antimalware* para **verificar automaticamente os discos rígidos e as unidades removíveis** (como *pen-drives*, DVDs e discos externos);
 - mantenha o *antimalware* e o **arquivo de assinaturas** sempre atualizado;
 - **evite executar simultaneamente diferentes programas antimalware** (pois podem entrar em conflito, afetar o desempenho do computador e interferir na capacidade de detecção um do outro);
 - **crie um disco de emergência e o utilize-o quando desconfiar que o antimalware instalado está desabilitado/ comprometido** ou que o comportamento do computador está estranho (mais lento, gravando ou lendo o disco rígido com muita frequência, etc.).

**** Antivírus**

Ferramentas preventivas e corretivas, que **detectam (e, em muitos casos, removem) vírus de computador e outros programas maliciosos (como spywares e cavalos de troia).**

Não impedem que um atacante explore alguma vulnerabilidade existente no computador.

Também **não** evita o acesso não autorizado a um *backdoor* instalado no computador.

Entre as diferentes ferramentas *antimalware* existentes, a que engloba a maior quantidade de funcionalidades é o **antivírus**. Apesar de inicialmente eles terem sido criados para atuar especificamente sobre vírus, com o passar do tempo, passaram também a englobar as funcionalidades dos demais programas, fazendo com que alguns deles caíssem em desuso (CertBr,2013).

O **programa antivírus** verifica se existem vírus conhecidos ou desconhecidos no computador:

- o vírus **conhecido** é aquele que pode ser detectado e identificado pelo nome;
- o vírus **desconhecido** é o que ainda não foi definido pelo programa antivírus.

O programa antivírus monitora continuamente o computador a fim de protegê-lo contra ambos os tipos de vírus.

Para isso, quanto ao **método de detecção**, os antivírus geralmente utilizam:

- **assinatura**: uma lista de assinaturas é usada à procura de padrões;
- **heurística**: baseia-se nas estruturas, instruções e características que o código malicioso possui; e
- **comportamento**: baseia-se no comportamento apresentado pelo código malicioso quando executado.

Todos esses recursos podem ser empregados nas verificações agendadas e manuais, além de serem usados pelo **auto-protect** para monitorar constantemente um computador. O auto-protect do programa antivírus é carregado na memória durante a inicialização do Sistema Operacional, fornecendo proteção constante enquanto se trabalha. Usando o *auto-protect*, o programa antivírus automaticamente:

- elimina quaisquer *worms*, Cavalos de Troia e vírus, inclusive os de macro, e repara arquivos danificados;
- verifica a existência de vírus cada vez que se utiliza programas, discos flexíveis ou outras mídias removíveis em um computador ou utiliza documentos criados ou recebidos;
- monitora o computador em busca de sintomas atípicos que possam indicar a existência de um vírus em ação;
- protege o computador contra vírus provenientes da Internet.

Obs.: É interessante manter, em seu computador:

- um antivírus funcionando constantemente (preventivamente).
- esse programa antivírus verificando os *e-mails* constantemente (preventivo).
- o recurso de atualizações automáticas das definições de vírus habilitado;
- as definições de vírus atualizadas constantemente (nem que para isso seja necessário, todos os dias, executar a atualização manualmente).

Os aplicativos de antivírus com escaneamento de segunda geração utilizam **técnicas heurísticas** para identificar códigos maliciosos.

Com o aumento de ataques sofisticados, como *ransomware* polimórfico, ataques *fileless* (ou *Sem Arquivo*) e *Advanced Persistent Threats* (APT), as defesas baseadas apenas em assinaturas ou na detecção comportamental mais básica tornaram-se menos eficazes contra ameaças desconhecidas ou muito evasivas.

Alguns autores já citam as tecnologias de detecção que usam **assinaturas e comportamento** posterior ao ataque para proteger os computadores como “envelhecidas”. Já se fala em **NGAV (Next-Generation Antivírus)** que redefine o que o antivírus (AV) pode e deve fazer pela sua organização, alavancando **inteligência artificial, ciência algorítmica e aprendizado de máquina (*machine learning*)** para detectar e impedir a execução do malware em seus endpoints em tempo real. Ex.: Cylance.

**** Next Generation Antivírus (NGAV)**

Os **antivírus de última geração (NGAV)** evitam todos os tipos de ataques, conhecidos e desconhecidos, por meio de **inteligência artificial** usando conceito de *sandbox*, monitorando e respondendo às táticas, técnicas e procedimentos de invasão (AUDERE, 2021).

De modo abrangente o NGAV possui tecnologias de (AUDERE, 2021):

- *Anti-Ransomware;*
- *Anti-Exploit Prevention;*
- *ATP – Advanced Threat Protection;*
- *DLP – Data Loss Prevention;*
- *Mitigação;*
- *Proteção preventiva com Deep Learning;*
- *Resposta a Incidentes instantânea;*
- *EDR – Endpoint Detection and Response.*

Se algum *malware* conseguir infectar rede, Audere (2021) destaca que o **NGAV** mostrará, por exemplo, os arquivos comprometidos e o que se deve fazer para isolar a máquina afetada, deixando-a em seu estado original, enquanto se analisa a vulnerabilidade.

A habilidade em reconhecer e lidar com ameaças de segurança por conta própria é mais eficaz ao invés de depender de um banco de dados de assinaturas, cita Audere (2021).

**** Antispyware**

O *malware* do tipo *spyware* pode se instalar no computador sem o seu conhecimento e a qualquer momento que você se conectar à Internet, e pode infectar o computador quando instalamos alguns programas usando um CD, DVD ou outra mídia removível. Um *spyware* também pode ser programado para ser executado em horários inesperados, não apenas quando é instalado.

A ferramenta **antispyware** é uma forte aliada do antivírus, permitindo a localização e bloqueio de *spywares* conhecidos e desconhecidos. Exemplo de ferramentas antispyware: Windows Defender, Spybot etc.

Apesar do surgimento de ameaças mais complexas, as **ferramentas antispyware** continuam importantes para proteger os usuários contra programas que coletam informações sem permissão (CertBR, 2013). Muitas **suítes de segurança modernas combinam as funcionalidades de antivírus e antispyware em uma única aplicação**.

Obs.: Nem toda ferramenta antispyware é necessariamente antivírus e vice-versa.

Há programas que apresentam as duas funções, mas isso nem sempre acontece!

**** Proxy**

É um servidor que atua como um intermediário entre a estação de trabalho e a Internet **realizando filtros nos acessos da Internet**. Também guarda informações sobre as páginas visitadas anteriormente em cache.

Normalmente, a comunicação com um **proxy** utiliza o protocolo HTTP. Também deve ser definida uma porta de comunicação, já que um proxy recebe e envia dados por uma porta específica.

**** Firewall**

A RFC 2828 (*Request for Comments* n. 2828) define o termo **firewall** como sendo uma ligação entre redes de computadores que restringe o tráfego de comunicação de dados entre a parte da rede que está “dentro” ou “antes” do firewall, protegendo-a assim das ameaças da rede de computadores que está “fora” ou depois do firewall. Esse mecanismo de proteção geralmente é utilizado para proteger uma rede menor (como os computadores de uma empresa) de uma rede maior (como a Internet).

Um *firewall* deve ser instalado no ponto de conexão entre as redes, onde, por meio de regras de segurança, controla o tráfego que flui para dentro e para fora da rede protegida.

Pode ser:

- apenas um software sendo executado no ponto de conexão entre as redes de computadores (ex.: firewall do Windows, Iptables no Linux, etc.); ou
- um conjunto de hardware e software (esse cenário é o mais comum de se encontrar!). O Cisco ASA é um exemplo de um firewall de hardware, que possui um software internamente para aplicação das regras de segurança que serão aplicadas a esse dispositivo.

Obs.: Vide entendimento da banca na prova (CESPE/PF/Perito/2019): um firewall é uma combinação de hardware e software que isola da Internet a rede interna de uma organização, permitindo o gerenciamento do fluxo de tráfego e dos recursos da rede e o controle, pelo administrador de rede, do acesso ao mundo externo.

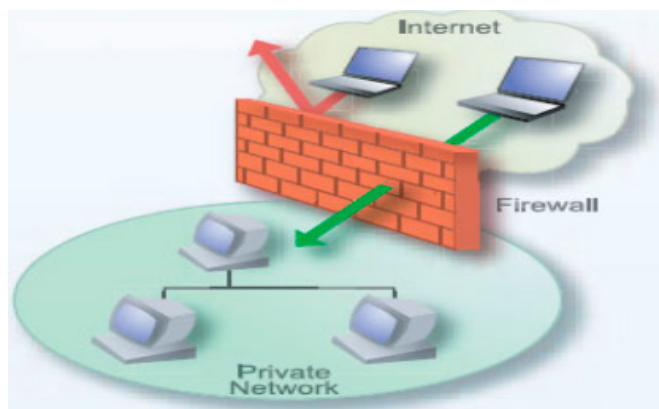


Figura. Firewall

Deve-se observar que isso o torna um potencial gargalo para o tráfego de dados e, caso não seja dimensionado corretamente, poderá causar atrasos e diminuir a *performance* da rede.

Os *firewalls* são implementados, em regra, em dispositivos que fazem a separação da rede interna e externa, chamados de **estações guardiãs (*bastion hosts*)**. Quando o *bastion host* cai, a conexão entre a rede interna e externa deixa de funcionar.

As principais **funcionalidades oferecidas pelos *firewalls*** são:

- **regular o tráfego de dados** entre uma rede local e a rede externa não confiável, por meio da introdução de filtros para pacotes ou aplicações;
- **impedir a transmissão e/ou recepção de acessos nocivos ou não autorizados** dentro de uma rede local;
- mecanismo de **defesa que restringe o fluxo de dados entre redes**, podendo criar um “log” do tráfego de entrada e saída da rede;
- **proteção de sistemas vulneráveis ou críticos**, ocultando informações de rede como nome de sistemas, topologia da rede, identificações dos usuários etc.

A seguir, alguns exemplos de situações que um firewall **NÃO** poderá impedir:

Vírus de E-mail	Os vírus de e-mail são anexos às mensagens de e-mail. Segundo Microsoft (2013), o firewall NÃO pode determinar o conteúdo das mensagens e, portanto, não pode protegê-lo contra esses tipos de vírus . Você deve usar um programa antivírus para examinar e excluir anexos suspeitos de uma mensagem de e-mail antes de abri-la. Mesmo tendo um programa antivírus, você não deve abrir um anexo de e-mail se não estiver completamente certo de que ele é seguro.
Tentativas de Phishing	Phishing é uma técnica usada para induzir usuários de computador a revelar informações pessoais ou financeiras, como uma senha de conta bancária. Uma tentativa de phishing online comum começa com um e-mail recebido de uma fonte aparentemente confiável, mas que, na verdade, orienta os destinatários a fornecerem informações para um site fraudulento. O firewall NÃO pode determinar o conteúdo das mensagens de e-mail e, portanto, NÃO pode protegê-lo contra esse tipo de ataque (Microsoft, 2013).

O firewall **não** tem a função de procurar por ataques. Ele realiza a filtragem dos pacotes e, então, bloqueia as transmissões não permitidas. Dessa forma, atua entre a rede externa e interna, controlando o tráfego de informações que existem entre elas, procurando certificar-se de que este tráfego é confiável, em conformidade com a política de segurança do site acessado. Também pode ser utilizado para atuar entre redes com necessidades de segurança distintas. Também, **o firewall não é antivírus nem antispyware**.

Firewall (pessoal): software que controla o acesso e as comunicações **entre um computador e a Internet ou uma rede local**. Bloqueia hackers e outros tráfegos não autorizados e permite o tráfego autorizado.

Firewall (rede): um dispositivo de *hardware*, *software* ou ambos que controla o acesso à rede e as comunicações **entre uma rede e a Internet ou entre duas partes diferentes de uma rede**.

Existem várias **técnicas** usadas na implementação de *firewalls*, dentre as quais pode-se citar:

- **Filtragem de pacotes (mais simples, menos seguro):** permite ou não o acesso baseado no endereço origem / destino ou na porta origem / destino do protocolo de comunicação utilizado. Utiliza-se de uma relação de endereços confiáveis para permitir ou não o acesso. Por filtrar apenas os endereços, está sujeito a ataques de *Spoofing*. Trabalha na **terceira** camada do modelo OSI (IP);

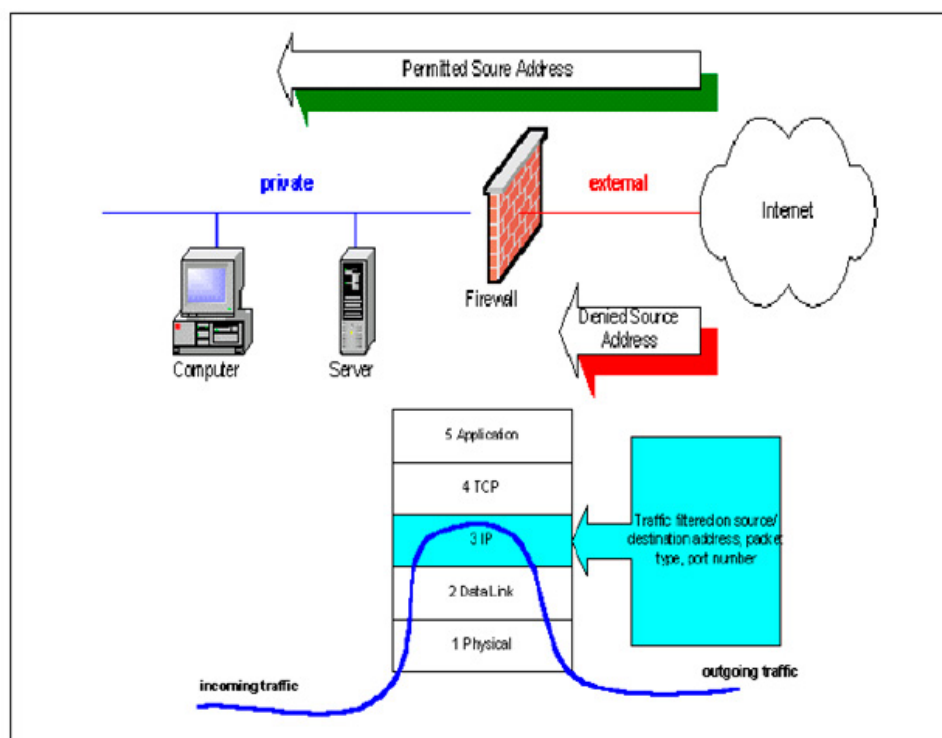


Figura. Esquema de Firewall por Filtragem de Pacotes

O uso mais genérico está em evitar que usuários externos acessem recursos particulares de uma rede de computadores. Uma das tarefas de um firewall é garantir que as comunicações de / para a Internet estejam de acordo com preceitos de segurança. Da mesma maneira devem ser colocados Firewalls dentro da rede local de computadores de forma a proteger os dados da corporação (financeiros, pessoais, de pesquisas, etc.) contra invasões internas.

Todavia, um Firewall **não** poderá proteger uma rede contra conexões que não passam por ele ou contra novas ameaças que não estejam previstas na sua programação.

- **Stateful Packet Inspection (Inspeção de Estado de Pacote):** permite ou não o acesso, analisando não apenas as informações utilizadas na filtragem de pacotes, mas também analisa o cabeçalho de cada pacote de informação que chega, verificando se pertence a uma conexão interna. Assim, se chegar ao firewall um pacote que não foi solicitado por algum terminal de dentro da área protegida, o pacote é bloqueado. Trabalha na **quarta** camada do modelo OSI (TCP);

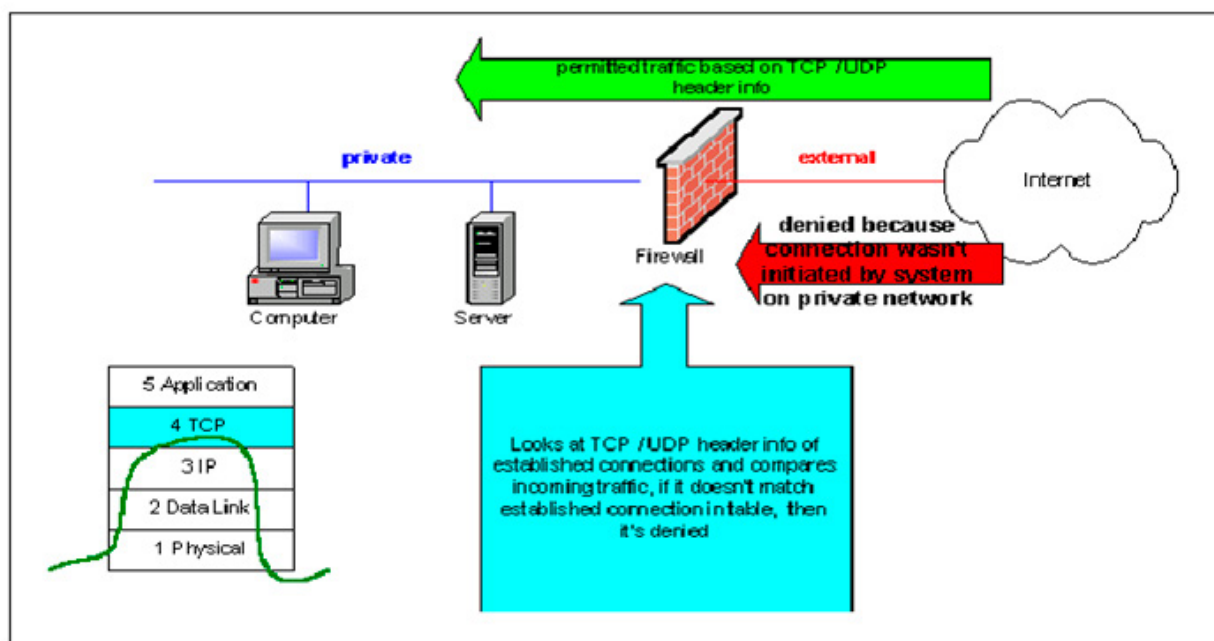


Figura. Esquema de Firewall por Stateful Inspection (RABENER, 2001)

- Proxy Firewall: nesse tipo de implementação, toda a comunicação é direcionada ao *firewall*. Este, recebendo uma solicitação de pacote para ser enviada a rede externa, examina suas políticas de segurança. Se o pacote as atender, envia-o para o destino, mas, com o endereço IP do firewall, protegendo o verdadeiro endereço de origem da solicitação. Ao receber um pacote de respostas, examina seu conteúdo e em seguida verifica se o pacote pertence a uma solicitação interna. Em caso positivo, repassa-o então ao solicitante. Trabalha na **quinta** camada do modelo OSI.

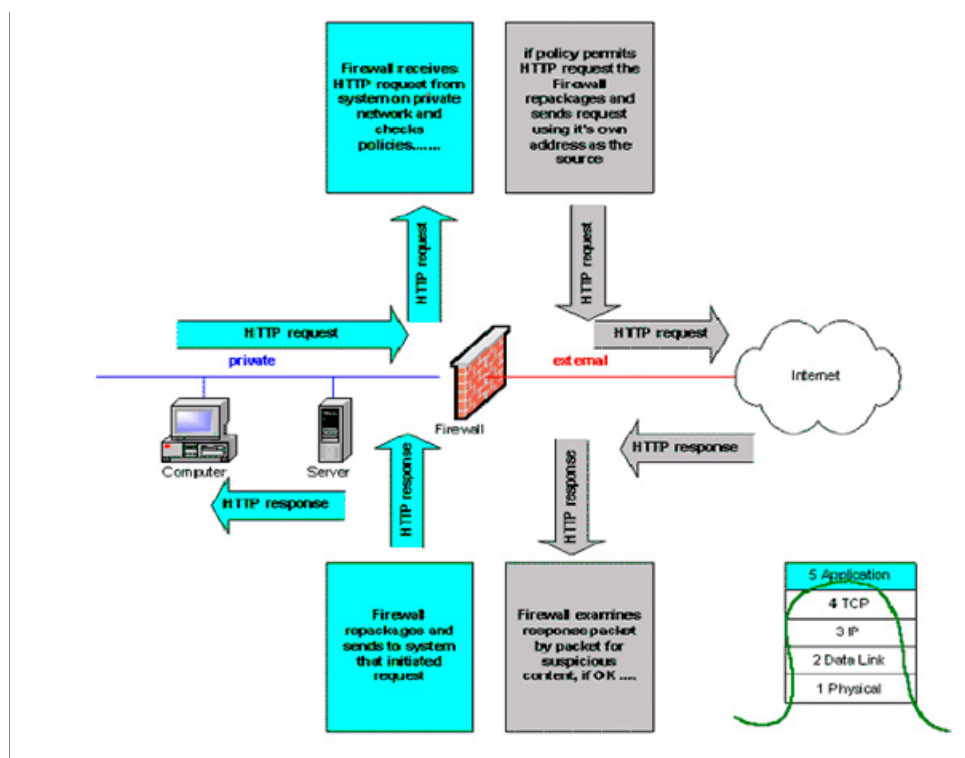


Figura. Esquema de Firewall Proxy (RABENER, 2001)

Categorias de Firewall

Os sistemas de Firewall disponíveis comercialmente se diferenciam de **duas maneiras**: quanto ao seu **conjunto de características** e quanto à sua **arquitetura básica**.

Quanto às características, os Firewalls geralmente são divididos em duas categorias:

Firewall em nível de aplicação

Um Firewall de aplicação (*Application-level* ou "proxy" server), também conhecido como **Bastion Host** (gateway de aplicação) não permite que nenhum pacote passe diretamente da rede externa para a rede corporativa. A RFC 2828 (Request for Comments n. 2828) define como sendo um computador fortemente protegido contra ataques, podendo ser parte de um firewall, sendo o único computador da rede que pode ser acessado diretamente pelo lado de fora do firewall. Geralmente, está localizado no perímetro da rede entre a parte interna e protegida e a Internet, por exemplo.

Primeiramente verifica se um pedido de acesso realizado por um usuário a um site ou serviço disponível na Internet é permitido – validação de usuário e senha para acesso, por exemplo, de sites de pornografia. Todos os pacotes são enviados a um servidor de proxy. O proxy determina quando se deve ou não estabelecer a conexão e deve conhecer a aplicação e, se uma nova aplicação for necessária na rede, deve obter com o fornecedor um novo código que a contemple. Se o acesso é autorizado, o firewall realiza o papel de intermediário, realizando a conexão com o site ou serviço na Internet conforme solicitado pelo usuário, repassando-o as páginas, imagens e outras informações provenientes da Internet.

Um firewall ou um roteador funcionando como **bastion host**, pode ser projetado com a finalidade de ser um servidor Web, servidor FTP, dentre outras funções que estiverem disponíveis a usuários de fora da proteção da interna da rede. Também pode ser projetado como chamariz em *honeypots*. Sua função é justamente atrair a atenção dos invasores com vulnerabilidades propositadamente deixadas para que se possam coletar dados de eventuais tentativas de invasão e posterior proteção.

A sua configuração é totalmente diferente de um computador comum. Devido ao seu papel específico dentro da rede, todos os protocolos, programas e portas são removidos se não forem estritamente necessários ao funcionamento. A figura seguinte representa uma rede protegida por dois *bastion hosts*, um com a função de servidor WWW e FTP e outro com a função de servidor SMTP e DNS.

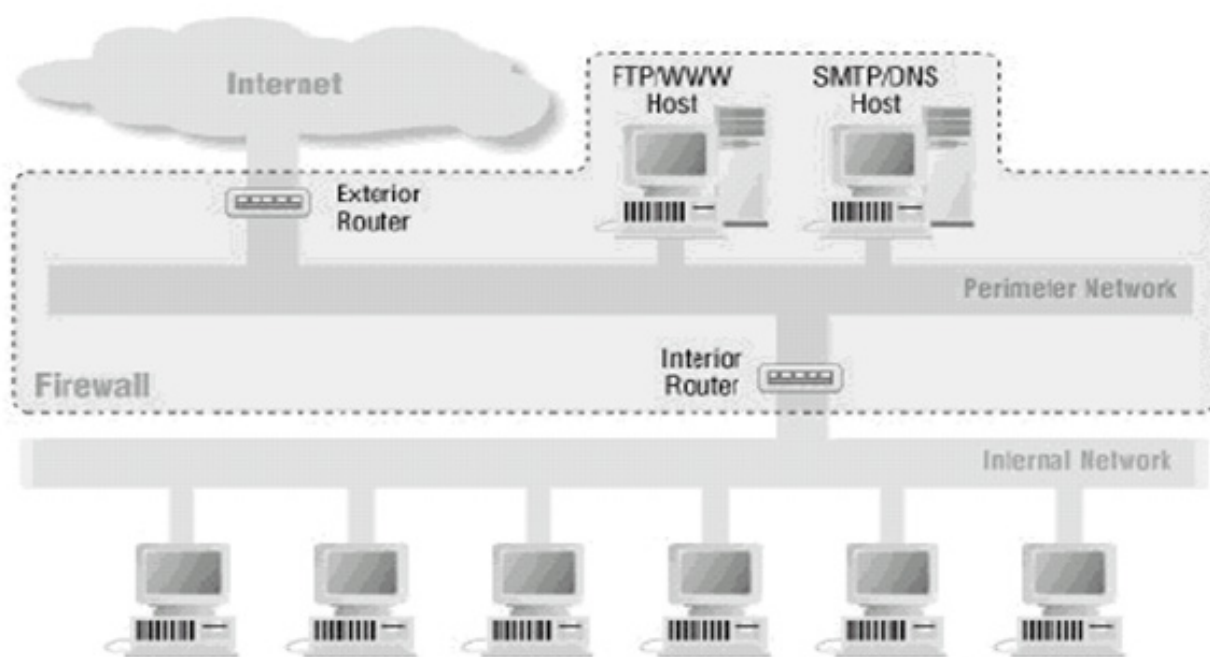
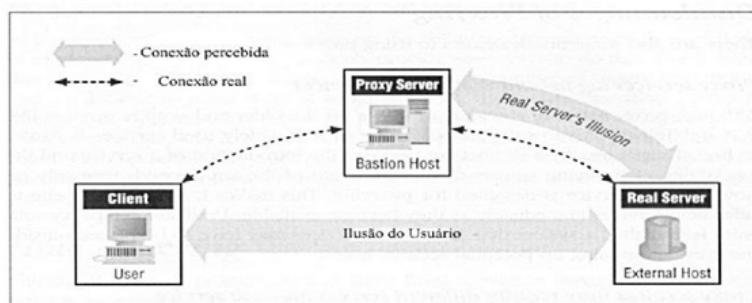


Figura. Arquitetura Usando Dois Bastion Hosts (JENKINS, 2001)

As características principais de um Bastion Host são as seguintes:

- Gateway de aplicação (verifica protocolos da camada de aplicação);
- papel crítico na segurança da rede interna, funcionando como intermediário entre o cliente da rede interna e o servidor remoto;
- recurso de controle de acesso;
- registro do tráfego.

Bastion Host - Proxy Server



As características principais do **Proxy Server** são as seguintes:

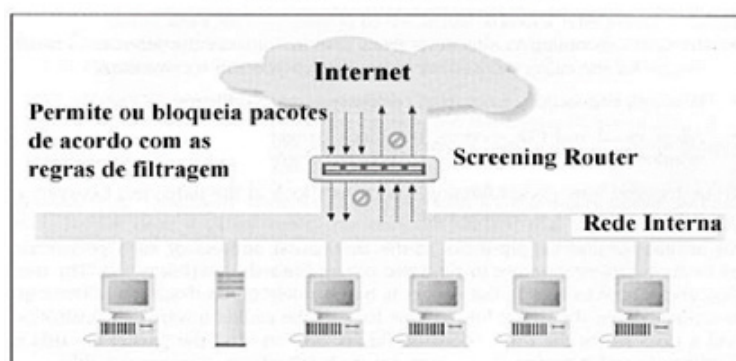
- Atua como um procurador;
- Cliente não necessita DNS;
- Cliente deve suportar Proxy;
- Geralmente implementa recurso de Cache;
- Necessidade de somente um IP válido;
- Pode possuir recursos para verificação de vírus.

Firewall em nível de rede

Um Firewall de Rede (*Network-level* ou "*packet-filtering*" firewall) também conhecido como *Packet Filter* (filtro de pacotes) atua ao nível de rede examinando as informações solicitadas pelos usuários da Internet, servindo como intermediário entre a corporação e a Internet. No seu projeto, os dados (pacotes IP) chegam até ele. Dependendo de regras de filtragem embutidas em seu sistema operacional, ele decide se os deixa passar ou não para a rede local.

Cada solicitação é examinada, e, quando solicitações ilícitas são realizadas, essas são bloqueadas, para que não sejam encaminhadas para a estrutura interna da organização, evitando danos aos dados existentes na estrutura da empresa bem como a disponibilização de informações confidenciais da corporação à Internet.

Filtro de Pacote



Um filtro de pacotes atua até a camada de transporte e pode filtrar:

- Endereço de origem e destino;
- Protocolos: TCP, UDP ou ICMP;
- Portas de origem e destino: TCP ou UDP;
- Tipo de mensagem ICMP;
- Interface de rede de entrada e saída;
- TCP Flags (Ex. flag ACK)

As características desejáveis em um *Screening Router* são:

- Boa performance na filtragem;
- Hardware dedicado;
- Permitir especificação de regras;
- Aplicar regras na ordem especificada;
- Aplicar as regras nos pacotes que chegam e partem em cada interface de rede;
- Registro dos pacotes aceitos e rejeitados, bloqueando os que não satisfazem nenhuma regra.

Firewall Híbrido

Também são conhecidos como *Screened Host*. Embora o projeto de um Firewall de filtro de pacotes seja considerado o mais rápido e flexível em comparação com o Firewall de aplicação, muitas organizações combinam as vantagens de ambos para obterem um nível maior de segurança e performance em suas redes.

Arquitetura Básica

Os sistemas de *Firewall* disponíveis oferecem combinações de características variadas. Algumas são essenciais, outras necessárias apenas em circunstâncias especiais. A seguir, serão apresentadas as básicas que um Firewall deve apresentar em sua configuração:

- **Controle de acesso básico:** controlar o acesso à rede. Alguns Firewalls oferecem controles de acesso fáceis de administrar e difíceis de burlar;
- **Serviços suportados:** Protocolos (ao nível de aplicação) que o Firewall reconhece. Um Firewall ao nível de aplicação deve ter um serviço de proxy para cada aplicação. Os Firewalls filtros de pacotes suportam todos os serviços conhecidos (DNS, Finger, FTP, Gopher, ICMP, IRC, Mail, Telnet, WWW);
- **Autenticação de usuários:** os Firewalls ao nível de aplicação normalmente utilizam esse conceito, interrompendo aplicações e exigindo aos usuários que se autenticuem antes de continuarem a conexão no destino requisitado.
- **Redes privadas virtuais:** como o Firewall é a porta de entrada da corporação nada mais natural do que utilizá-lo como servidor VPN e ser o responsável pela autenticação dos usuários.
- **Administração:** oferecer uma interface gráfica com recursos de auxílio ao operador que permitam que mesmo uma pessoa não especializada possa gerenciá-lo facilmente;

- **Auditoria e alarmes:** os administradores de Firewall devem ser notificados quando da tentativa de uma invasão.
- **Alta performance:** Firewalls lentos podem ser um sério gargalo na rede.
- **Mapeamento de endereços:** alguns Firewalls trocam (dinamicamente) os endereços ilegais pelos endereços legais quando os pacotes saem para a Internet em uma operação chamada NAT;
- **Controle de quantidade máxima de conexões permitidas:** essa característica ajuda a evitar ataques do tipo sobrecarga da rede ("flooding attacks")

**** DMZ (Zona Desmilitarizada)**

Também chamada de **Rede de Perímetro**. Trata-se de uma pequena rede situada entre uma rede confiável e uma não confiável, geralmente entre a rede local e a Internet.

A função de uma **DMZ** é manter todos os serviços que possuem acesso externo (navegador, servidor de e-mails) separados da rede local limitando o dano em caso de comprometimento de algum serviço nela presente por algum invasor. Para atingir este objetivo os computadores presentes em uma DMZ não devem conter nenhuma rota de acesso à rede local. O termo possui uma origem militar, significando a área existente entre dois inimigos em uma guerra.

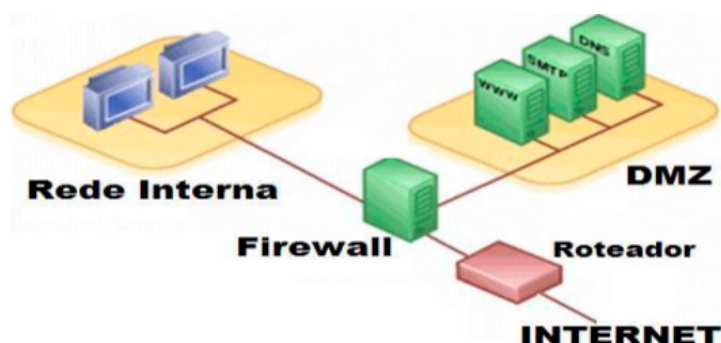


Figura. DMZ

**** WAF (Web Application Firewall – Firewall de Aplicação Web)**

Um **WAF**, ou **Web Application Firewall**, é um sistema que fica entre o seu site ou aplicativo(s) da web e o restante da internet, funcionando como uma barreira que bloqueia e protege o servidor da organização contra ataques de Hackers, Spammers, DDoS, Injeções SQL e muito outros tipos de Cyber Ataques (Gocache, 2020).

WAF tem sido muito utilizado atualmente para proteger sites, blogs, comércio eletrônico (e-commerce), aplicativos de celulares, etc (Gocache, 2020).

Enquanto os proxies geralmente protegem somente os clientes, o WAF protege os servidores. Um WAF é implementado para proteger um aplicativo da Web específico ou conjunto de aplicativos da Web, podendo ser considerado um proxy reverso (Gocache, 2020).

Obs.: O **WAF** monitora o tráfego HTTP **podendo filtrar o conteúdo de aplicações Web específicas**, o que o diferencia dos *firewalls* comuns que servem de segurança entre os servidores.

O **firewall de aplicação web** é um filtro altamente escalável, em que se aplica um conjunto de regras para uma conversa HTTP, com o **objetivo de proteger a aplicação de ataques** comuns, tais como *Cross-Site Scripting (XSS)* e *SQL Injection*, antes que alcancem os servidores de hospedagem (GOCACHE, 2020).

DIRETO DO CONCURSO

003. (CEBRASPE-CESPE/OFICIAL TÉCNICO DE INTELIGÊNCIA/ÁREA 8/2018) Acerca de sistemas de aplicação web, julgue o item a seguir.

O WAF (web application firewall) avalia o tráfego comparando assinaturas e comportamentos anômalos, enquanto o IPS (intrusion prevention system) avalia o comportamento e a lógica do que é solicitado e devolvido.



A banca inverteu os conceitos! O IPS (*intrusion prevention system*) avalia o tráfego comparando assinaturas e comportamentos anômalos, enquanto o WAF (*web application firewall*) avalia o comportamento e a lógica do que é solicitado e devolvido.

WAF (Web Application Firewall – Firewall de Aplicação Web) como o nome diz, é um firewall para aplicações web. Em outras palavras, um mecanismo de segurança que bloqueia ou permite acesso à pacotes de dados oriundos de web applications (aplicações Web) específicas.

Errado.

**** NAC (Network Access Control – Controle de Acesso à Rede)**

Com o crescimento exponencial do acesso de dispositivos móveis às redes e os riscos de segurança que isso traz, é importante ter ferramentas que forneçam visibilidade, controle de acesso e recursos de conformidade necessários para fortalecer a infraestrutura de segurança de rede.

Um sistema NAC pode negar acesso à rede a dispositivos que não estão de acordo, colocá-los em uma área de quarentena ou oferecer a eles apenas acesso restrito aos recursos de computação, impedindo que nós não seguros afetem a rede.

Obs.: As soluções **NAC** (ou **Controle de Acesso à Rede**) oferecem visibilidade à rede e o gerenciamento de acesso por meio da aplicação de políticas em **dispositivos** e **usuários** de redes corporativas (Cisco, 2020).

Cisco ainda destaca que essas soluções ajudam as organizações a controlar o acesso às suas redes, por meio de recursos tais como a política de gerenciamento do ciclo de vida, a criação de perfil e visibilidade e o acesso à rede de convidados.

DIRETO DO CONCURSO

004. (CEBRASPE-CESPE/PROFISSIONAL DE TECNOLOGIA DA INFORMAÇÃO (ME)/ATIVIDADES TÉCNICAS DE COMPLEXIDADE GERENCIAL, DE TECNOLOGIA DA INFORMAÇÃO E DE ENGENHARIA SÊNIOR/SEGURANÇA DA INFORMAÇÃO E PROTEÇÃO DE DADOS/2020) No que se refere a NAC (network access control) e NAP (network access protection), julgue o próximo item. As soluções NAC oferecem visibilidade à rede e gerenciamento de acesso por meio da aplicação de políticas em dispositivos e usuários de redes corporativas; essas soluções ajudam as organizações a controlar o acesso às suas redes, por meio de recursos tais como a política de gerenciamento do ciclo de vida, a criação de perfil e visibilidade e o acesso à rede de convidados.



Perfeito! Eis a principal função de NAC! **Soluções NAC ajudam as empresas a controlarem o acesso às redes por meio dos seguintes recursos (Cisco, 2020):**

- **gerenciamento do ciclo de vida de políticas:** aplica políticas em todos os cenários de operação sem exigir produtos diferentes ou módulos adicionais;
- **perfil e visibilidade:** reconhece e define usuários e dispositivos antes que o código mal-intencionado cause danos;
- **acesso de rede a visitante:** gerencie os visitantes por meio de um portal de serviço personalizado que inclui registro, autenticação e promoção de visitantes, além de um portal de gerenciamento de visitantes;
- **verificação de postura de segurança:** avalia o cumprimento da política de segurança pelo tipo de usuário, tipo de dispositivo e sistema operacional;
- **resposta a incidentes:** reduz as ameaças à rede ao aplicar **políticas de segurança que bloqueiam, isolam e reparam** máquinas incompatíveis sem a atenção do administrador;
- **integração bidirecional:** integre com outras soluções de segurança e rede por meio da API aberta/RESTful.

Certo.

005. (CEBRASPE-CESPE/PROFISSIONAL DE TECNOLOGIA DA INFORMAÇÃO (ME)/ATIVIDADES TÉCNICAS DE COMPLEXIDADE GERENCIAL, DE TECNOLOGIA DA INFORMAÇÃO E DE ENGENHARIA SÊNIOR/SEGURANÇA DA INFORMAÇÃO E PROTEÇÃO DE DADOS/2020) No que se refere a NAC (network access control) e NAP (network access protection), julgue o próximo item.

O NAP é um conjunto de componentes do sistema operacional que fornece uma plataforma para acesso protegido a redes públicas.



Proteção de Acesso à Rede (NAP) é um conjunto de componentes do sistema operacional que fornece uma plataforma para acesso protegido a **redes privadas**, conforme destaca https://www.cisco.com/c/pt_br/products/security/what-is-network-access-control-nac.html#~como-a-nac-funciona.

A plataforma NAP fornece uma maneira integrada de avaliar o estado de integridade do sistema de um cliente da rede que está tentando se conectar ou se comunicar em uma rede e restringir o acesso do cliente da rede até que os requisitos da política de integridade sejam atendidos (Cisco, 2020).

Errado.

**** IDS (Sistema de Detecção de Intrusão – *Intrusion Detection System*)**

Em um sistema em segurança de redes de computadores, a **intrusão** é qualquer conjunto de ações que tendem a comprometer a integridade, confidencialidade ou disponibilidade dos dados ou sistemas.

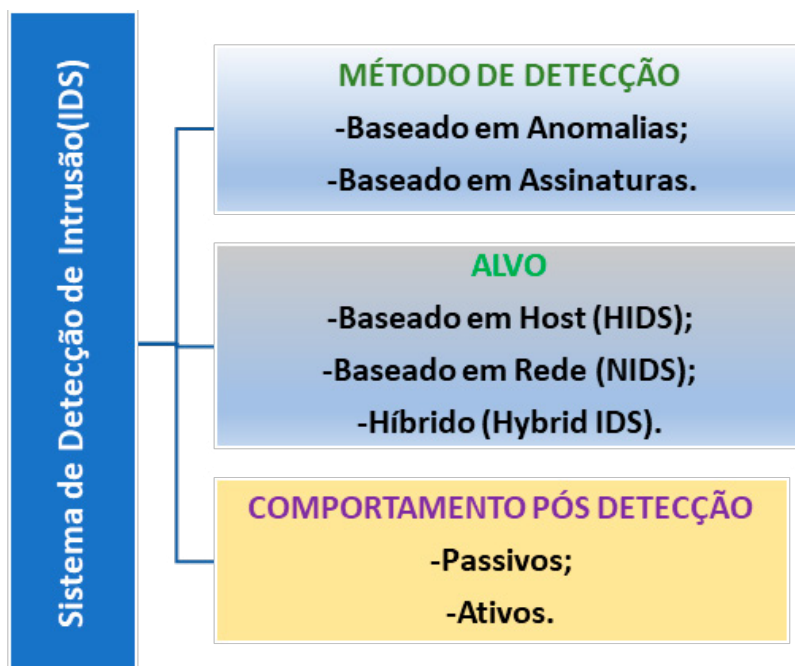
Os **intrusos** em uma rede podem ser de dois tipos: **internos** (que tentam acessar informações não autorizadas para ele); **externos** (tentam acessar informações via Internet).

IDS (Intrusion Detection Systems) são sistemas de detecção de intrusos, que têm por finalidade detectar atividades incorretas, maliciosas ou anômalas, em tempo real, permitindo que algumas ações sejam tomadas.

- Geram **logs** para casos de tentativas de ataques e para casos em que um ataque teve sucesso.
- Pode detectar ataques que são realizados por meio de portas legítimas permitidas e que, portanto, **não** podem ser protegidos pelo *firewall*.
- Mesmo sistemas com *firewall* devem ter formas para detecção de intrusos.
- Assim como os *firewalls*, os IDSs também podem gerar falsos positivos (uma situação em que o *firewall* ou IDS aponta uma atividade como sendo um ataque, quando na verdade não é).

Obs.: O IDS (***Intrusion Detection System***) procura por ataques já catalogados e registrados, podendo, em alguns casos, fazer análise comportamental do sistema.

O IDS pode ser **classificado** de acordo com o **método de detecção**, o **alvo** e o **comportamento após a detecção**.



Quanto ao **MÉTODO DE DETECÇÃO** utilizado, os IDS podem ser dos seguintes **tipos** (STRINGFIXER, 2020):

Baseado em Anomalias	Criado principalmente para detectar ataques desconhecidos, em parte devido ao rápido desenvolvimento de malwares. Um IDS baseado em anomalia monitorará o tráfego da rede e o comparará com uma linha de base estabelecida. A abordagem básica é utilizar o aprendizado de máquina para criar um modelo de atividade confiável e comparar o novo comportamento com o modelo confiável. <u>Vantagens:</u> • permite a detecção de ataques desconhecidos; • pode gerar informações que darão origem a uma assinatura. <u>Desvantagens:</u> • o comportamento normal da rede deve obedecer a padrões bem definidos; • gera grande número de falsos positivos; • gera relatórios pouco conclusivos quanto ao tipo de ataque.
Baseado em Assinaturas	Monitora pacotes na rede e os compara com padrões de ataques pré-configurados e predeterminados, conhecidos como assinaturas. Embora o IDS baseado em assinatura possa detectar facilmente ataques conhecidos, não é capaz de detectar novos ataques. <u>Vantagens:</u> • menor quantidade de falsos positivos; • alarmes mais precisos; • gera relatórios mais conclusivos quanto ao tipo de ataque; • facilita a tomada de contramedidas. <u>Desvantagens:</u> • não é capaz de detectar novos ataques, que não possuem assinatura; • é necessário atualizar constantemente a lista de assinaturas.

Quanto ao **ALVO**, os IDS podem ser dos seguintes **tipos**:

IDS baseado em host (HIDS)	São executados em hosts ou dispositivos individuais na rede. Um HIDS monitora apenas os pacotes de entrada e saída do dispositivo e alerta o usuário ou administrador se uma atividade suspeita for detectada. Faz o monitoramento do sistema, com base em informações de arquivos de logs ou de agentes de auditoria. Como exemplo, pode ser utilizado em máquinas de missão crítica, que não devem ter suas configurações alteradas.
IDS baseado em rede (NIDS)	São colocados em pontos estratégicos da rede para monitorar o tráfego da rede . A coleta, normalmente, é realizada por dispositivos dedicados que funcionam de forma similar a sniffers de pacotes . Monitora o tráfego do segmento da rede, geralmente com a interface de rede atuando em modo "promíscuo". A detecção é realizada com a captura e análise dos cabeçalhos e conteúdo dos pacotes. Observe que um NIDS opera na camada de rede do modelo OSI . Como a criptografia de dados ocorre na camada de apresentação do modelo OSI, o NIDS não consegue analisar informações criptografadas. <u>Vantagens</u> : diversas máquinas podem ser monitoradas utilizando-se apenas um agente (componente que coleta os dados). <u>Desvantagens</u> : o IDS "enxerga" apenas os pacotes trafegando, sem ter visão do que ocorre na máquina atacada.
Hybrid IDS	Combina os pontos fortes das 2 soluções anteriores, ou seja, do HIDS e do NIDS. Opera como o NIDS, coletando o tráfego da rede, processando os pacotes e detectando e respondendo a ataques. No entanto, ele faz isso como um HIDS, ou seja, processa os pacotes endereçados ao próprio sistema.

Quanto ao **COMPORTAMENTO APÓS DETECÇÃO**, os IDS podem ser dos seguintes **tipos**:

Passivos	Apenas detecta um comportamento malicioso, porém não é capaz de interromper o ataque. Faz a análise das informações recebidas, SEM interferir no funcionamento da rede, comunicando os administradores em caso de alerta.
Ativos	Ao detectar um comportamento malicioso realiza contramedidas para impedir o ataque de forma automática.

Obs.: Sniffers – Farejadores

"Por padrão, os computadores (pertencentes à mesma rede) escutam e respondem somente pacotes endereçados a eles. Entretanto, é possível utilizar um *software* que coloca a interface num estado chamado de modo promíscuo. Nessa condição o computador pode monitorar e capturar os dados trafegados através da rede, não importando o seu destino legítimo" (ANONYMOUS, 1999, p.194).

Os programas responsáveis por capturar os pacotes de rede são chamados **Sniffers**, **Farejadores** ou ainda **Capturadores de Pacote**. Eles exploram o fato do tráfego dos pacotes das aplicações TCP/IP não utilizar nenhum tipo de cifragem nos dados. Dessa maneira um *sniffer* pode obter nomes de usuários, senhas ou qualquer outra informação transmitida que não esteja criptografada.

A dificuldade no uso de um *sniffer* é que o atacante precisa instalar o programa em algum ponto estratégico da rede, como entre duas máquinas, (com o tráfego entre elas passando pela máquina com o farejador) ou em uma rede local com a interface de rede em modo promíscuo.

Os *sniffers* são difíceis de detectar, não consomem ou geram muito tráfego na rede trabalhando de forma passiva. Pode-se diminuir o sucesso dos *sniffers* com a utilização de criptografia, autenticação e *switches*.

**** IPS (Sistema de Prevenção de Intrusão – *Intrusion Prevention System*)**

O **IPS (Sistema de Prevenção de Intrusão)** é um sistema que detecta e obstrui automaticamente ataques computacionais a recursos protegidos. Diferente dos IDS tradicionais, que localizam e notificam os administradores sobre anomalias, um IPS defende o alvo sem uma participação direta humana.

DIRETO DO CONCURSO

006. (CESPE/MEC/ADMINISTRADOR DE REDE/2015) Julgue o item seguinte, referente a Firewall, VPN e sistemas de detecção de intrusão. Sistemas para detecção de intrusão são capazes de criar regras de bloqueio ou limitações para o tráfego de rede quando detectam anomalias com seus próprios recursos.



IDS e IPS são sistemas que protegem a rede de intrusões, diferindo no tratamento dado quando uma intrusão é detectada. **IDS limita-se a gerar alertas e ativar alarmes, e o IPS executa contramedidas, como interromper o fluxo de dados referente à intrusão detectada.**

Errado.

Um dos grandes desafios dos sistemas de detecção de intrusos é **minimizar FALSOS POSITIVOS e FALSOS NEGATIVOS!**

- **Falso Negativo:** o IDS não gera alarme na ocorrência de um evento ou tráfego mal intencionado.
- **Falso Positivo:** o IDS gera um alarme de ataque na ocorrência de um evento ou tráfego normal.

Cabe destacar que o falso positivo é um evento observável e relevante, que é classificado pelo IDS como um **evento intrusivo!**

Seu maior problema é a geração de um grande **número de alertas**, o que dificulta a administração e a análise das informações do IDS.

A ocorrência de falsos positivos normalmente acarreta consequências mais graves para as redes que utilizam IPS do que para aquelas que usam IDS!

As consequências mais graves ocorrerão com a utilização do **IPS**, já **que executa contramedidas**, como resetar conexões suspeitas e fazer reprogramações no firewall de acordo com a situação detectada.

O **IPS (Sistema de Prevenção de Intrusão)** é que faz a detecção de ataques e intrusões, e não o *firewall*!!! Um IPS é um sistema que detecta e obstrui automaticamente ataques computacionais a recursos protegidos. Diferente dos IDS tradicionais, que localizam e notificam os administradores sobre anomalias, um IPS defende o alvo sem uma participação direta humana.

**** UTM (Unified Threat Management)**

Gerenciamento Unificado de Ameaças (ou Unified Threat Management – UTM) pode ser considerado uma solução que é a **evolução do *firewall* tradicional, unindo a execução de várias funções de segurança em um único dispositivo**: firewall, prevenção de intrusões de rede, antivírus, VPN, filtragem de conteúdo, balanceamento de carga e geração de relatórios informativos e gerenciais sobre a rede.

Segundo Kaspersky (2020):

O **gerenciamento unificado de ameaças, normalmente abreviado como UTM** (Unified Threat Management), é um termo de segurança de informações que se refere a uma única solução de segurança, e normalmente é um único dispositivo de segurança que oferece várias funções de segurança em um único ponto na rede. Normalmente, um dispositivo de UTM inclui funções como: antivírus, **antispyware**, antispam, **firewall** de rede, detecção e prevenção de intrusão, filtragem de conteúdo e prevenção de vazamento. Algumas unidades também oferecem serviços como roteamento remoto, conversão de endereço de rede (NAT) e suporte de rede privada virtual (VPN). O fascínio da solução baseia-se na simplicidade, para que as organizações que já tiveram fornecedores ou dispositivos para cada tarefa de segurança possam agora tê-los todos sob o controle do mesmo fornecedor, com o suporte de uma equipe ou segmento de TI, e executados através de um console.”

DIRETO DO CONCURSO



007. (CESPE/POLÍCIA FEDERAL/PAPILOSCOPISTA POLICIAL FEDERAL/2018) No que se refere à segurança de computadores, julgue o item subsecutivo. Para a melhoria de desempenho, vários produtos de segurança (firewall e antispyware, por exemplo) podem ser substituídos por um sistema de gerenciamento unificado de ameaça (UTM – unified threat management).



O **Gerenciamento Unificado de Ameaças (ou Unified Threat Management – UTM)** conta com uma arquitetura inteligente e permite a **execução de várias funções de segurança em um único dispositivo**: firewall, antispyware, etc. de forma a se ter uma identificação de situações de risco mais rapidamente e com melhor desempenho.

Certo.

**** SIEM (Security Information and Event Management)**

SIEM, conforme destaca Fruhlinger (2022), é a combinação de **gerenciamento de informações de segurança (SIM – Security Information Management)** e **gerenciamento de eventos de segurança (SEM – Security Event Management)**.

Obs.: As **ferramentas SIEM** geralmente fornecem dois resultados principais: os **relatórios**, que agregam e exibem incidentes e eventos relacionados à segurança; e os **alertas**, que serão acionados se o mecanismo de análise da ferramenta detectar atividades que violam um conjunto de regras.

Plataformas SIEM geralmente **fornecem relatórios e alertas, por meio de análises de eventos e dados de registros (logs)** em tempo real para correlacionar eventos, monitorar ameaças e responder a incidentes (FRUHLINGER, 2022).

Basicamente, as **ferramentas SIEM** geralmente fornecem dois resultados principais: relatórios e alertas (Notificações).

- Os **relatórios** agregam e **exibem incidentes e eventos relacionados à segurança**, como **atividades maliciosas** e **tentativas de login malsucedidas**.
- Os **alertas** serão acionados se o mecanismo de análise da ferramenta detectar atividades que violam um conjunto de regras, sinalizando, consequentemente, um problema de segurança.

Os maiores **benefícios** que as ferramentas SIEM oferecem são **identificação aprimorada e tempo de resposta por meio da agregação e normalização de dados**. Além disso, e tão importante, eles aceleram a detecção de ameaças, alertas de segurança e atendimento aos requisitos de conformidade.

Geralmente, **as soluções SIEM são capazes de analisar e exibir as ameaças de segurança conhecidas, mas não conseguem prever as desconhecidas**, pois carecem de inteligência para assim fazer. No entanto, por meio de um **SIEM inteligente adequado, alimentado por uma análise de dados baseada em IA e machine learning**, é possível obter uma visão unificada dos dados, *insights* detalhados com base no contexto, *scores* de risco coerentes, análise de comportamento, maior visibilidade, busca proativa por ameaças, etc. (FRUHLINGER, 2022).

Uma **abordagem holística** facilita a análise de volumes maciços de dados, fornece relatórios em tempo real e torna a identificação de ameaças e a resposta altamente eficaz (FRUHLINGER, 2022).

DIRETO DO CONCURSO

008. (CEBRASPE-CESPE/PROFISSIONAL DE TECNOLOGIA DA INFORMAÇÃO (ME)/ATIVIDADES TÉCNICAS DE COMPLEXIDADE GERENCIAL, DE TECNOLOGIA DA INFORMAÇÃO E DE ENGENHARIA SÊNIOR/SEGURANÇA DA INFORMAÇÃO E PROTEÇÃO DE DADOS/2020) Em relação ao SIEM (security information and event management), julgue o item subsequente.

As ferramentas SIEM geralmente fornecem dois resultados principais: os relatórios, que agregam e exibem incidentes e eventos relacionados à segurança; e os alertas, que serão acionados se o mecanismo de análise da ferramenta detectar atividades que violam um conjunto de regras.



SIEM, conforme destaca Fruhlinger (2022), é a combinação de **gerenciamento de informações de segurança (SIM – Security Information Management)** e **gerenciamento de eventos de segurança (SEM – Security Event Management)**.

A tecnologia realiza **duas funções principais, fornece relatórios sobre incidentes e eventos relacionados à segurança**, tais como logins bem-sucedidos e fracassados, atividade malware e outras possíveis atividades maliciosas e envia alertas caso a análise indica que uma atividade contrária a um conjunto de regras predeterminado e, portanto, significa um potencial problema de segurança (FRUHLINGER, 2022).

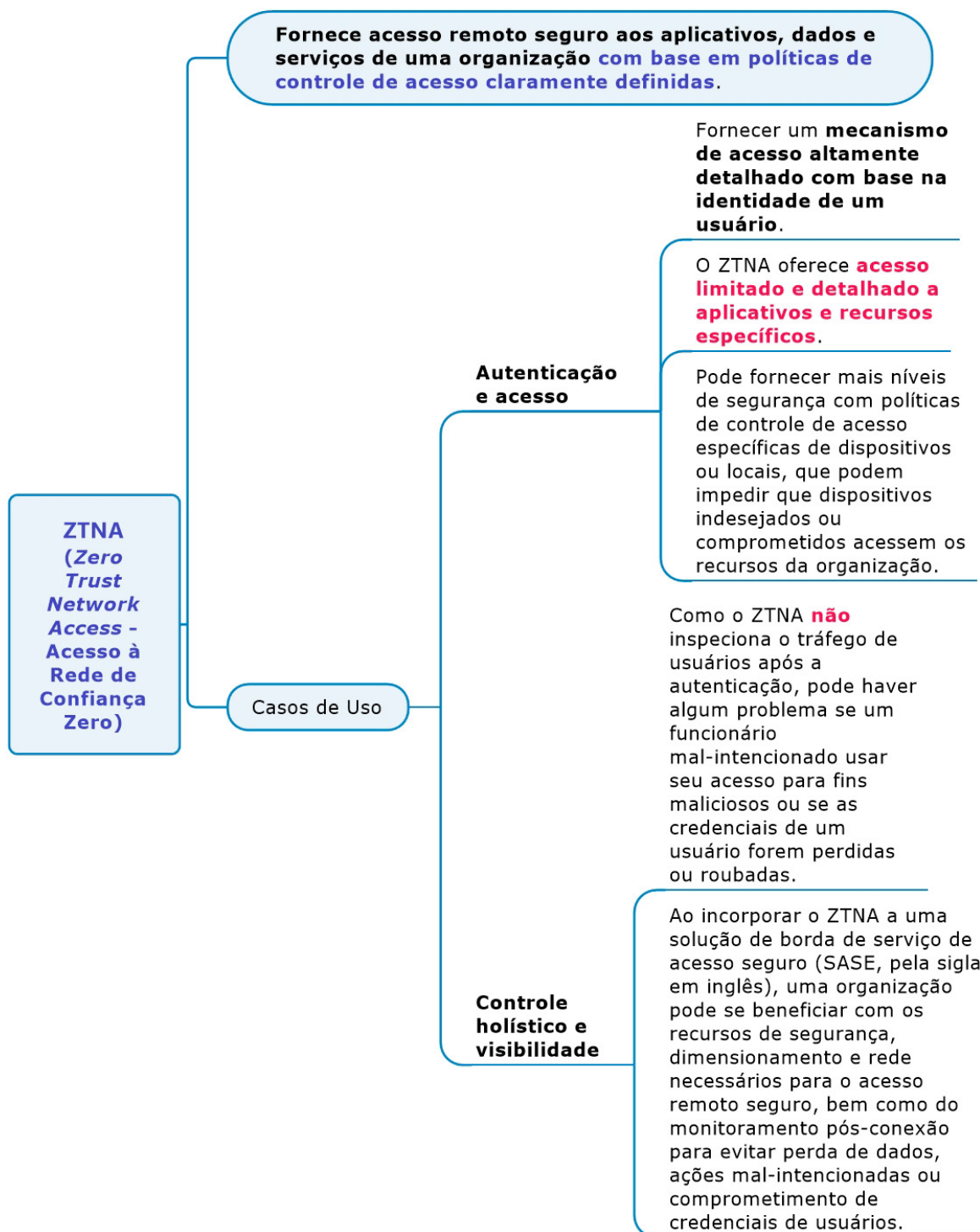
Certo.

**** ZTNA (Zero Trust Network Access – Acesso à Rede de Confiança Zero)**

- Conforme citado por Palo Alto, a **Confiança Zero** é uma abordagem estratégica de segurança cibernética que protege uma organização, eliminando a **confiança implícita** e **validando continuamente TODAS as etapas** de uma **interação digital**.

É para qualquer empresa que necessite de uma rede segura.

- VMWARE cita que o **“acesso de confiança zero à rede (ZTNA) é uma solução de segurança de TI que fornece acesso remoto seguro aos aplicativos, dados e serviços de uma organização com base em políticas de controle de acesso claramente definidas. O ZTNA difere das redes privadas virtuais (VPNs, pela sigla em inglês) porque concede acesso apenas a serviços ou aplicativos específicos, enquanto as VPNs concedem acesso a uma rede inteira. À medida que um número crescente de usuários acessa recursos em casa ou em outros locais, as soluções de ZTNA podem ajudar a eliminar lacunas de outras tecnologias e métodos de acesso remoto seguro”**.



**** PAM (Privileged Access Management – Gerenciamento de Acesso Privilegiado)**

- Permite proteger, controlar, monitorar, analisar e controlar o **acesso privilegiado** em vários ambientes e plataformas (ONEIDENTITY, 2022).
- É o mecanismo de proteção a informações que protege as identidades com recursos ou acesso especial além dos usuários normais (ONEIDENTITY, 2022).

**** Honeypot = “Pote de Mel”**

- É um sistema que possui falhas de segurança reais ou virtuais, colocadas de **maneira proposital**, a fim de que seja invadido e que o fruto desta invasão possa ser estudado.
- Um honeypot é um recurso de rede cuja função é de ser atacado e comprometido (invadido). Significa dizer que um Honeypot poderá ser testado, atacado e invadido. Os honeypots não fazem nenhum tipo de prevenção, os mesmos fornecem informações adicionais de valor inestimável (Lance Spitzner/2003).
- Não possui dados ou aplicações importantes para a organização.
- Objetivo: passar-se por equipamento legítimo. Não existem falsos positivos pois o tráfego é real.

**** Virtual Private Network (VPN)**

Virtual Private Network (VPN) ou **Rede Virtual Privada**: é uma **rede privada** (rede **com acesso restrito**) **construída sobre a estrutura de uma rede pública**, normalmente a Internet.

Criam “túneis” virtuais de transmissão de dados utilizando **criptografia** para garantir a privacidade e integridade dos dados, e a autenticação para garantir que os dados estão sendo transmitidos por entidades ou dispositivos autorizados e não por outros quaisquer.

Considere, por hipótese, que exista uma VPN em uma determinada organização, de forma a possibilitar o estabelecimento de uma ligação direta entre um computador e o servidor de destino, criando um tipo de túnel protegido na internet. Neste cenário, é possível que um usuário possa acessar seus documentos, *e-mails* corporativos e sistemas na nuvem, via VPN, sem se preocupar em ser interceptado.

Obs.: Redes Privadas Virtuais (*Virtual Private Network – VPN*): túneis de **criptografia** entre pontos autorizados, criados por meio da *Internet* ou outras redes públicas e/ou privadas para transferência de informações.

O uso de VPNs representa uma alternativa para a redução dos custos de redes corporativas oferecendo **confidencialidade**, **autenticação** e **integridade** no transporte de informação por meio de redes públicas.

Princípios Básicos

Uma VPN deve prover um conjunto de funções que garantam alguns princípios básicos para o tráfego das informações:

1. Confidencialidade – tendo-se em vista que estarão sendo usados meios públicos de comunicação, é imprescindível que a privacidade da informação seja garantida, de forma que, mesmo que os dados sejam capturados, não possam ser entendidos.

2. Integridade – na eventualidade da informação ser capturada, é necessário garantir que não seja alterada e reencaminhada, permitindo que somente informações válidas sejam recebidas.

3. Autenticidade – somente os participantes devidamente autorizados podem trocar informações entre si, ou seja, um elemento da VPN somente reconhecerá informações originadas por um segundo elemento que tenha autorização para fazer parte dela.

Elementos da VPN

Para implementar uma VPN é necessário conhecer os seus **elementos básicos constituintes**:

- **Servidor VPN:** responsável por aceitar as conexões dos clientes VPN. Esse servidor é o responsável por autenticar e prover as conexões da rede virtual aos clientes;
- **Cliente VPN:** é aquele que solicita ao servidor VPN uma conexão. Esse cliente pode ser um computador ou mesmo um roteador;
- **Túnel:** é o caminho por onde os dados passam pela rede pública. Comparando com as tecnologias orientadas à camada 2 (Enlace) do modelo OSI, um túnel é similar a uma sessão, em que as duas extremidades negociam a configuração dos parâmetros para o estabelecimento do túnel, como endereçamento, criptografia e parâmetros de compressão. Na maioria das vezes, são utilizados protocolos que implementam o serviço de datagrama.
- **Protocolos de tunelamento:** são os responsáveis pelo gerenciamento e encapsulamento dos túneis criados na rede pública;
- **Rede Pública:** efetua as conexões da VPN. Normalmente trata-se da rede de uma prestadora de serviços de telecomunicações.



Figura. Elementos da VPN

Transporte da informação

Alguns aspectos **negativos** também devem ser considerados sobre a utilização de VPNs:

- **Perda de velocidade de transmissão:** as informações criptografadas têm seu tamanho aumentado, causando uma carga adicional na rede.
- **Maiores exigências de processamento:** o processo de criptografar e decifrar as informações transmitidas gera um maior consumo de processamento entre os dispositivos envolvidos.

Protocolos de VPN

O protocolo da VPN estabelecerá a conexão e a criptografia entre os *hosts* da rede privada. Os protocolos normalmente utilizados em uma VPN são:

- **PPP – Point to Point Protocol:** responsável por verificar as condições da linha telefônica (no caso das conexões *dial up*), pela validação dos usuários na rede, além de estabelecer as configurações dos pacotes (tamanho, compressão utilizada etc.);
- **PPTP – Point to Point Tunneling Protocol:** uma variação do protocolo PPP, que encapsula os pacotes em um túnel fim-a-fim, porém não oferece os serviços de criptografia;
- **IPSec – Internet Protocol Security:** conjunto de padrões e protocolos para segurança relacionada com VPN IP. Trata-se de um protocolo padrão da camada 3 do modelo OSI, que oferece transparência segura de informações fim-a-fim por meio de rede IP pública ou privada. O IPSec especifica os cabeçalhos AH e ESP, que podem ser usados independentemente ou em conjunto. O **IPsec pode ser usado em dois modos:**
 - No modo de transporte, o cabeçalho IPsec é inserido logo depois do cabeçalho IP.
 - No **modo de túnel**, todo o **pacote IP**, incluindo o cabeçalho, **é encapsulado** no corpo de um **novo pacote IP** com um cabeçalho IP completamente novo.

O **L2TP/LSTP**, o **L2F** e o **GRE** **não fornecem, de forma nativa, o serviço de confidencialidade** dos dados por meio de criptografia, assim, geralmente, são usados em conjunto com o **IPsec**.

- **AH – Authentication Header:** utilizado para prover integridade e autenticidade dos dados presentes no pacote, incluindo a parte invariável do cabeçalho. Não provê confidencialidade;
- **ESP – Encapsulated Security Payload:** provê integridade, autenticidade e criptografia aos dados do pacote;
- **L2TP – Level 2 Tunneling Protocol:** faz o tunelamento de PPP utilizando vários protocolos de rede como IP, ATM etc., sendo utilizado para prover acesso discado a múltiplos protocolos;
- **Socks v5:** protocolo especificado pelo IETF que define como uma aplicação cliente-servidor, utilizando IP e UDP, irá estabelecer a comunicação por meio de um servidor proxy.

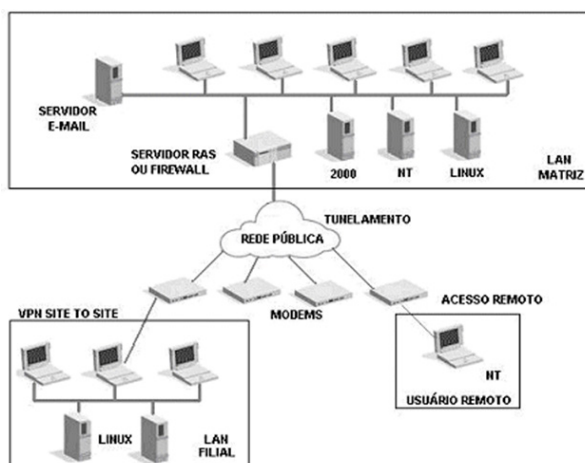


Figura. Tunelamento

DIRETO DO CONCURSO

009. (CESGRANRIO/PETROBRÁS – ANALISTA DE SISTEMAS JÚNIOR – INFRAESTRUTURA/REDES DE COMPUTADORES/2010) Uma vez que as VPNs (Virtual Private Networks) não utilizam linhas dedicadas nem links de rede remota e os dados corporativos precisam atravessar a Internet, as VPNs devem fornecer mecanismos para garantir a segurança dos dados. Os protocolos CHAP e RADIUS são utilizados pelas VPNs para fornecer

- a) autenticação e autorização.
- b) confidencialidade e autenticação.
- c) confidencialidade e integridade.
- d) autorização e confidencialidade.
- e) integridade e autorização.



Em linhas gerais, **autenticação** é o processo de provar que você é quem diz ser (visa confirmar a identidade do usuário ou processo (programa) que presta ou acessa as informações). **Autorização** é o processo de determinar o que é permitido que você faça depois que você foi autenticado!! O Protocolo de Autenticação por Desafios de Identidade – **CHAP** (*Challenge Handshake Authentication Protocol*) –, descrito na RFC 1994 (Simpson, 1996), é um método relativamente seguro de **autenticação**, em comparação a protocolos mais simples como o PAP.

O CHAP é bastante utilizado nos ambientes Linux, em que a senha real do usuário não atravessa o canal de comunicação (para ambientes Windows existe o MS-Chap) e verifica periodicamente a identidade do usuário, por meio de um reconhecimento em três vias (*three-way handshake*). GTA (2001) destaca que esta autenticação ocorre no estabelecimento da conexão, e também pode ocorrer a qualquer momento após o seu estabelecimento.

A verificação da autenticidade dos usuários é feita por meio do emprego de um segredo compartilhado (*shared secret*) entre o usuário e o servidor **RADIUS**.

Após a etapa de estabelecimento da conexão, o servidor RADIUS (*Remote Authentication Dial-In User Service*) envia um desafio para o usuário. O usuário então emite uma resposta que contém o *hash* do segredo compartilhado. O servidor de Autenticação então verifica o valor do *hash* enviado e o compara com o *hash* gerado por ele mesmo. Caso o valor esteja correto, o servidor envia um reconhecimento positivo (ACK). Caso contrário, o servidor finaliza a conexão. Em intervalos de tempo aleatórios, o servidor realiza novamente um desafio para o usuário.

O RADIUS, segundo Guimarães, Lima e Oliveira (2006) possui serviços de autenticação e autorização combinados, possibilitando que o cliente seja autenticado e que receba informações do servidor.

Letra a.

- Dependendo da técnica utilizada na implementação da VPN, a privacidade das informações poderá ser garantida apenas para os dados, ou para todo o pacote (cabeçalho e dados).
- **Quatro técnicas podem ser usadas para a implementação de soluções VPN:**

Modo Transmissão	Somente os dados são criptografados, não havendo mudança no tamanho dos pacotes. Geralmente são soluções proprietárias, desenvolvidas por fabricantes.
Modo Transporte	Somente os dados são criptografados, podendo haver mudança no tamanho dos pacotes. É uma solução de segurança adequada, para implementações nas quais os dados trafegam somente entre dois nós da comunicação.
Modo Túnel Criptografado	Tanto os dados quanto o cabeçalho dos pacotes são criptografados, sendo empacotados e transmitidos segundo um novo endereçamento IP, em um túnel estabelecido entre o ponto de origem e de destino.
Modo Túnel Não Criptografado	Tanto os dados quanto o cabeçalho são empacotados e transmitidos segundo um novo endereçamento IP, em um túnel estabelecido entre o ponto de origem e destino. No entanto, cabeçalho e dados são mantidos tal como gerados na origem, não garantindo a privacidade.

Fonte: https://www.gta.ufrj.br/seminarios/semin2002_1/Ivana/#intro

DIRETO DO CONCURSO

010. (CESPE/TRT-1ªR/ANALISTA JUDICIÁRIO/2008/ADAPTADA) Uma característica das redes do tipo VPN (virtual private networks) é que elas nunca devem usar criptografia, devido a requisitos de segurança e confidencialidade.



Uma **VPN (Virtual Private Network – Rede Privada Virtual)** é uma rede **privada** (não é de acesso público!) que usa a estrutura de uma rede pública (como por exemplo, a **Internet**) para transferir seus dados (os dados devem estar **criptografados** para passarem despercebidos e inacessíveis pela Internet). As VPNs são muito utilizadas para interligar filiais de uma mesma empresa, ou fornecedores com seus clientes (em negócios eletrônicos) por meio da estrutura física de uma rede pública.

O tráfego de dados é levado pela rede pública utilizando protocolos não necessariamente seguros. **VPNs seguras usam protocolos de criptografia por tunelamento** que fornecem a confidencialidade (sigilo), autenticação e integridade necessárias para garantir a privacidade das comunicações requeridas. Quando adequadamente implementados, estes protocolos podem assegurar comunicações seguras por meio de redes inseguras.

Errado.

011. (CESGRANRIO/PETROBRÁS/TÉCNICO EM INFORMÁTICA/SEGURANÇA DA INFORMAÇÃO/2010) A VPN (Virtual Private Network) é uma rede de comunicação privada que utiliza meios públicos. Com relação à segurança dos dados que trafegam por meio da VPN, afirma-se que

- a) muitos dados se perdem pela baixa qualidade dos meios públicos de comunicação, não sendo uma rede adequada para tráfego de aplicações críticas.
- b) os dados podem ser acessados por pessoas não autorizadas no caso de serem encapsulados sem criptografia.
- c) é uma rede segura de transmissão de dados onde, mesmo utilizando canais públicos de comunicação, usa-se o protocolo padrão da Internet.
- d) a segurança padrão oferecida pelos gestores da Internet torna viável o tráfego de dados críticos a baixos custos.
- e) a utilização de soluções de VPN comerciais garante a confidencialidade dos dados e a estabilidade das redes privadas.



O tráfego de dados é levado pela rede pública utilizando protocolos não necessariamente seguros, e, caso os dados sejam encapsulados sem criptografia, podem vir a ser acessados por pessoas não autorizadas.

VPNs seguras usam protocolos de criptografia por tunelamento que fornecem a confidencialidade (sigilo), autenticação e integridade necessárias para garantir a privacidade das comunicações requeridas. Quando adequadamente implementados, estes protocolos podem assegurar comunicações seguras por meio de redes inseguras.

Letra b.

**** Uso de Sistemas de Monitoramentos e Análises de pacotes**

1. Monitoramento

O **monitoramento** dos sistemas pode ser feito por meio de recursos como: *logs*, *scanners* (qualquer programa que verifica *hosts* em busca de vulnerabilidades), antivírus, **sniffers** (mecanismos que capturam pacotes nas redes), *SNMP*, *softwares* de monitoramento e detecção de intrusos (MELO, 2006).

Todos esses recursos são essenciais para que a equipe de segurança possa trilhar as tentativas de invasão e as anomalias da rede. Alguns destes recursos também podem ser usados por *hackers*.

Identificar problemas na rede nem sempre é uma tarefa fácil. Ter um bom conhecimento de redes, seus protocolos e dos tipos de ataques mais frequentes é requisito mínimo e fundamental. Ataques como: engenharia social, negação de serviços (DoS), personificação, código malicioso, etc.

A utilização de **ferramentas de monitoramento e detecção de intrusão** auxilia a tarefa da equipe de segurança.

Segundo Melo (2006), *softwares* como: **MRTG, Nagios, Iptraf, Ethereal, Nessus, Snort, Nmap** e programas antivírus são alguns dos vários existentes no mercado.

- **MRTG (Multi Router Traffic Grapher)**: é usado para analisar o tráfego em uma rede/link. O MRTG gera páginas HTML contendo gráficos sobre a utilização da rede/link.
- **Nagios**: com ele é possível verificar o *status* de equipamentos ou da rede toda. É possível criar grupos de usuários e receber alertas por e-mail. Por exemplo: um servidor com falta de memória ou desligado, isto será detectado pelo Nagios e o administrador será automaticamente alertado. Recursos como mensagens por telefone podem ser utilizadas.
- **Iptraf**: é um *sniffer* de rede que mostra estatísticas detalhadas sobre o que está circulando pela rede.
- **Nmap**: é um scanner de hosts que usa recursos avançados para verificar o estado do alvo.
- **Ethereal**: é um programa que analisa o tráfego de rede e o organiza por protocolos. É um *sniffer*.
- **Nessus**: é um *software* de verificação de vulnerabilidades de segurança. Ele é um scanner de segurança. Seus relatórios são completos e possuem sugestões de correção de falhas.
- **IDS** (Sistema de detecção de invasão).
- O **Snort** é um *software* livre de detecção de intrusão para rede, capaz de desenvolver análise de tráfego em tempo real e registro de pacote em redes IP. Executa análise de protocolo, busca/associa padrões de conteúdo e pode ser usado para detectar uma variedade de ataques.
- **SNMP (Simple Network Management Protocol)**: este protocolo permite aos gerentes de redes a gerência de vários dispositivos da rede, sejam eles *softwares* ou *hardwares*. Através deste protocolo é possível obter informações detalhadas sobre o sistema computacional da empresa.

Nada adianta a segurança física ou até a lógica se há corrupção das pessoas. A política social da empresa deve primar pela educação de seus funcionários. Responsabilidade e comprometimento são fundamentais. Como nem tudo é perfeito, não se pode abrir mão do monitoramento.

Segundo (BEAL, 107), uma vez estabelecidos os **mecanismos de proteção associados à segurança de redes, software, comunicação e usuário final**, é necessário **monitorá-los** para verificar se esses mecanismos realmente funcionam e para acompanhar quaisquer indícios de comportamento suspeito ao problema.

Para monitorar os ambientes é recomendado o uso de circuito fechado de TV, instalação de alarmes, sensores de movimento e temperatura. Mecanismos de alerta podem ser disparados para a equipe de segurança, avisando-a da ocorrência de incidentes. Tudo deve ser registrado e mantido em arquivo por tempo razoável.

2. Verificação de logs

Um dos métodos mais simples e mais difundidos de monitoramento é a **coleta de informações a respeito de eventos predeterminados em arquivos históricos, mais conhecidos como logs**. Com essas informações, a equipe de segurança é capaz de registrar eventos e detectar tentativa de acesso e atividades não autorizadas após sua ocorrência.

A verificação de arquivos de *logs* permite à equipe de segurança identificar e traçar os caminhos de possíveis tentativas de invasão. A análise do *log* das tentativas de acesso (*logon*) em um servidor pode mostrar um tipo de ataque conhecido como força bruta. Há um cuidado com a utilização destes arquivos de *log*. Os mesmos costumam crescer demasiadamente e podem facilmente comprometer o espaço em disco. Algumas ferramentas podem auxiliar no controle destes arquivos, compactando-os em intervalos de tempo. Outra medida interessante é que estes arquivos fossem gravados em servidores diferentes. Imagine um *hacker* experiente e esperto que ao conseguir a senha de administrador do servidor, altera os arquivos de *log*. Não seria possível identificar o ataque. Manter os *logs* protegidos e verificados constantemente são medidas de segurança importantes.

Arquivos de *log* podem ter outra função além de denunciar ataques. A gerência da empresa pode querer saber o que os funcionários andam acessando na Internet e quanto tempo gastam fazendo isto. Uma ferramenta interessante é o SARG.

O **SARG – interpretador de logs para o Squid** – é uma ferramenta de monitoramento de uso de rede que monta um relatório completo, em tempo real, dos acessos feitos à Internet através do Proxy. Sempre que executado ele cria um conjunto de páginas, divididas por dia, com uma lista de todas as máquinas que foram acessadas e a partir de cada máquina da rede veio cada acesso. Ele também mostra os usuários, caso o *Squid* esteja configurado para exigir autenticação.

A figura seguinte apresenta uma tela de monitoramento do *Squid* que destaca alguns relatórios diários gerado pelo SARG de todo o tráfego na rede.

ARQUIVO/PERÍODO	DATA CRIAÇÃO	USUÁRIOS	BYTES	MÉDIA
2005Oct23-2005Oct25	Tue Oct 25 10:00:50 BRST 2005	366	1.747.082.660	4.773.449
2005Oct23-2005Oct24	Tue Oct 25 04:30:38 BRST 2005	354	1.321.344.318	3.732.611
2005Oct23-2005Oct23	Mon Oct 24 00:00:03 BRST 2005	19	24.837.385	1.307.230
2005Oct16-2005Oct23	Sun Oct 23 04:07:08 BRST 2005	474	6.057.016.251	12.778.515
2005Oct16-2005Oct22	Sat Oct 22 23:33:58 BRST 2005	474	6.054.457.068	12.773.116
2005Oct16-2005Oct21	Fri Oct 21 23:33:43 BRST 2005	473	5.913.024.225	12.501.108
2005Oct16-2005Oct20	Thu Oct 20 23:33:23 BRST 2005	458	5.003.989.077	10.925.740
2005Oct16-2005Oct19	Wed Oct 19 23:32:31 BRST 2005	437	3.765.586.402	8.616.902
2005Oct16-2005Oct18	Wed Oct 19 00:01:36 BRST 2005	414	2.599.464.174	6.278.898
2005Oct16-2005Oct17	Mon Oct 17 23:30:55 BRST 2005	367	1.443.984.354	3.934.562

Figura – Relatórios Diários Emitidos no SARG

Já na próxima figura é mostrado um dia de monitoramento e os respectivos usuários que fizeram os acessos.

Squid User Access Report
Período: 2005Oct16-2005Oct17
Ordem: BYTES, reverse
Topuser Relatório

[REORA](#) Relatório
[Sites & Users](#) Relatório
[SQUIDGUARD](#) Relatório
[Falha de autenticação](#) Relatório

NUM	USUARIO	CONEXÃO	BYTES	% BYTES	IN-CACHE-OUT	TEMPO GASTO
1	data/hora/ralbuquerque	2.843	51.519.322	3.57%	1.56% 98.44%	03:00:45
2	data/hora/fmatos	8.458	47.367.691	3.28%	11.31% 88.69%	04:17:56
3	data/hora/spaula	8.350	43.413.222	3.01%	6.96% 93.04%	02:08:30
4	data/hora/cardoso	3.361	41.851.389	2.90%	1.89% 98.11%	02:53:12

Por fim, temos um exemplo do relatório gerado pelo SARG, mostrando os sites acessados por um usuário da rede interna. Veja que entre os dados fornecidos estão a quantidade de banda usada pelo usuário e o tempo que ele ficou em cada página.

Figura – Usuários que Acessaram a Rede em uma Data Específica

Squid User Access Report
Período: 2005Oct16-2005Oct17
Usuario: ralbuquerque
Ordem: BYTES, reverse
Usuario Relatório

LOCAL ACESSADO	CONEXÃO	BYTES	%BYTES	IN-CACHE-OUT	TEMPO GASTO	MILISEG	%TEMPO
data/hora/caseiras.webspacemania.com	486	15.018.871	29.15%	0.03% 99.97%	00:57:16	3.436.757	31.69%
data/hora/sandrinha2005.gratishost.com	475	12.777.434	24.80%	0.31% 99.69%	00:40:50	2.450.598	22.59%
data/hora/www.matkus.neostrada.pl	1	6.385.974	12.40%	0.00% 100.00%	00:14:52	892.082	8.23%
data/hora/xramador.webspacemania.com	197	5.677.280	11.02%	0.03% 99.97%	00:14:50	890.491	8.21%
data/hora/banners3.spacash.com	157	1.831.493	3.55%	9.43% 90.57%	00:08:02	482.549	4.45%

Figura – Relatório Diário de um Determinado Usuário Emitido pelo SARG

Medidas administrativas podem ser tomadas contra usuários que desobedecem as políticas de segurança e acessam sites indevidos.

** Planos de Continuidade de Negócios (PCN)

Os **planos de continuidade de negócios** devem coletivamente conter:

- **papéis e responsabilidades** definidos para pessoas e equipes com autoridade durante e após um incidente;
- um **processo** para ativar a estrutura de **resposta a incidentes**;
- detalhes para **gerenciar os impactos imediatos** de um incidente de interrupção, dando a devida atenção a:
 - bem-estar dos colaboradores;
 - alternativas estratégicas, táticas e operacionais para responder à interrupção; e
 - prevenção de novas perdas ou indisponibilidade de atividades prioritárias.
- detalhes sobre **como e em que circunstâncias a organização irá se comunicar com os funcionários e seus familiares**, os principais interessados e contatos de emergência;
- **como a organização vai continuar ou recuperar suas atividades prioritárias dentro de prazos predefinidos**;

- detalhes de resposta após incidente da organização **à mídia**, incluindo:
 - a estratégia de comunicação;
 - meio de comunicação preferido;
 - diretriz ou modelo para a elaboração de uma declaração para a mídia; e
 - porta-voz apropriado;
- um processo para **retorno à normalidade** quando o incidente terminar.

Cada plano deve definir:

- **propósito e escopo;**
- **objetivos;**
- **critérios** e procedimentos para sua **ativação;**
- **procedimentos** de implementação;
- **papéis, responsabilidades e autoridades;**
- requisitos e **procedimentos de comunicação;**
- **interdependências** internas, externas e suas interações;
- **recursos** necessários; e
- **fluxo** de informações e processos documentados.

O **Plano de Continuidade de Negócios (PCN)** estabelece critérios para prover a continuidade de negócios organizacionais **em momento de crise**. Em suma, o PCN tem como **finalidade** central criar **normas** e **padrões** para que, em situações adversas, **as empresas possam recuperar, retomar e dar prosseguimento aos seus mais cruciais processos de negócio**, evitando que eles sofram danos mais profundos que provoquem perdas financeiras.

Obs.: **Três pilares** são essenciais ao **elaborar o Plano de Continuidade de Negócios (PCN):**

- 1) **Análise de risco:** o que de ruim pode vir a acontecer? Ou seja, quais as principais ameaças;
- 2) **Análise de impacto:** de que forma eventuais ameaças podem impactar o negócio da organização; e
- 3) **Planejamento Estratégico:** Se uma ameaça se apresentar, quais atitudes e ações se fariam necessárias para a retomada das operações da empresa?

Sob o ponto de vista do PCN, o funcionamento de uma empresa **deve-se, fundamentalmente, a duas variáveis:**

1. **processos:** as atividades realizadas para operar os negócios da empresa;
2. **componentes:** todas as variáveis utilizadas para realização dos processos: energia (Operadoras fornecedoras de energia elétrica), **telecomunicações** (empresas que fornecem comunicação usando dados e voz), **infraestrutura** (localização, para-raios, instalações elétricas, segurança física, etc.), **pessoas** (Contingência das atividades e atendimento através de Sites Remotos, etc.); **informática** (Equipamentos, Sistemas, Conectividade, etc.).

O PCN é estruturado em **quatro subplanos** menores ligados entre si, e cada qual para um estágio diferente. São eles:

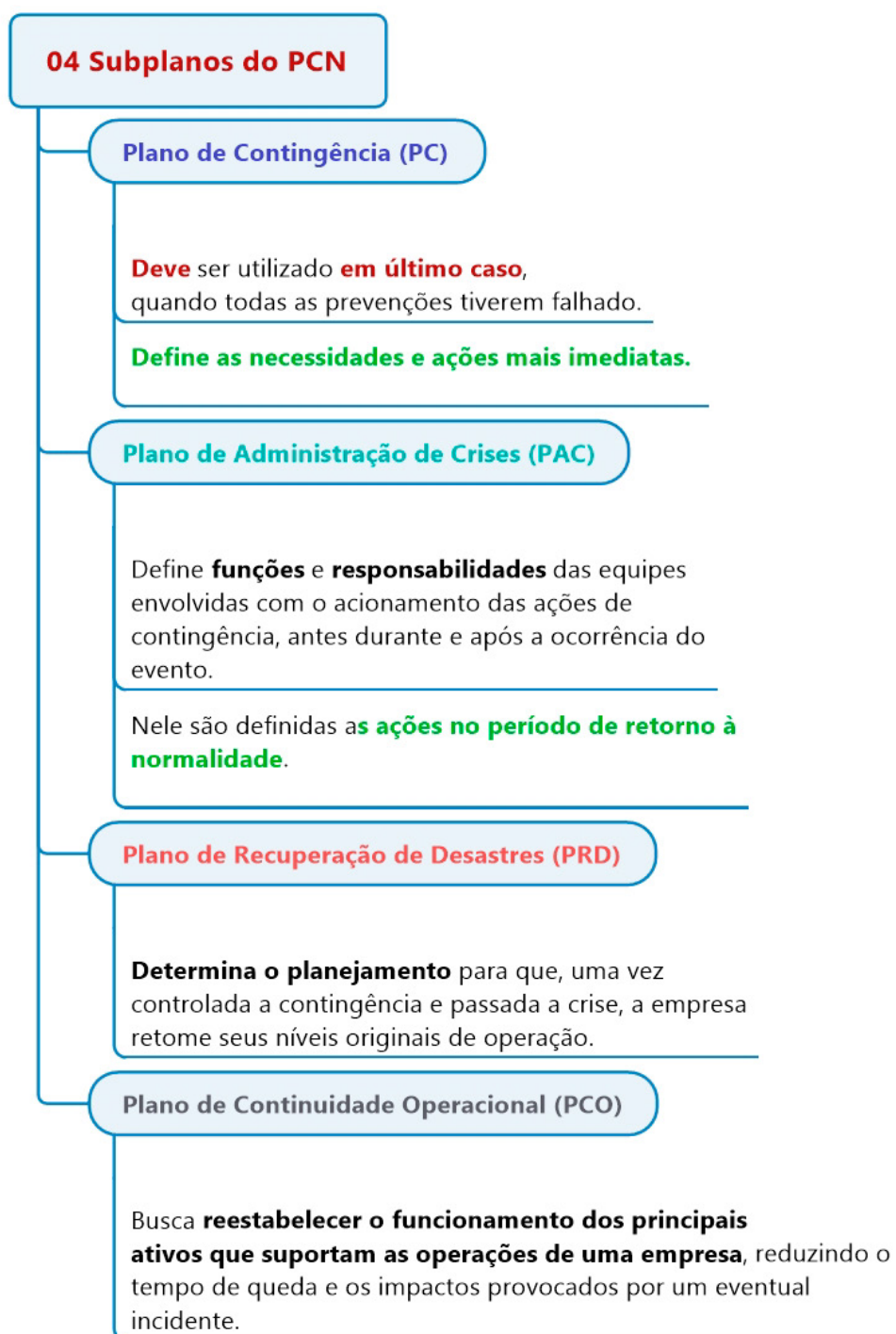
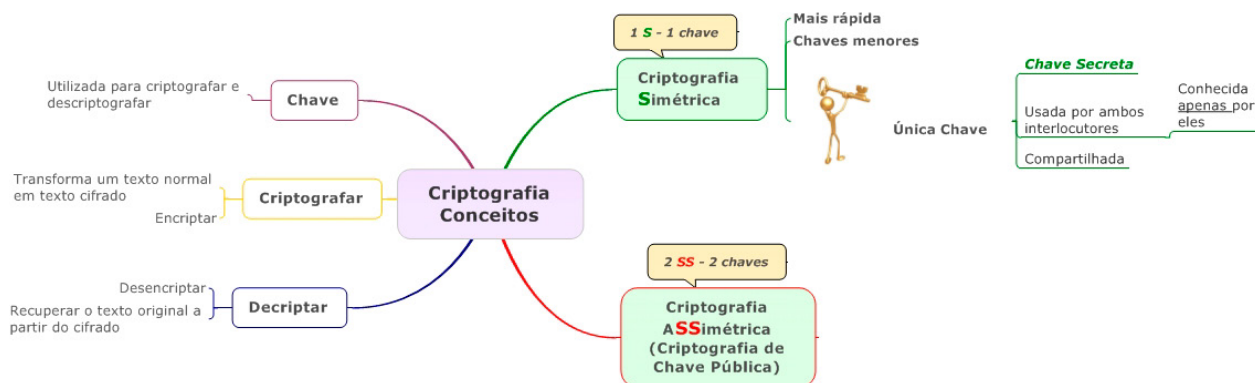


Figura – Subplanos do PCN. Fonte: QUINTÃO (2025)

**** Criptografia**

Texto Cifrado: Dado que foi criptografado.

Texto Claro: Dado que está no estado não cifrado ou decifrado.



- Na **criptografia aSSimétrica (criptografia de chaves públicas)**, as entidades envolvidas possuem duas chaves, uma privada e uma pública.

Quando a intenção é fazer uso da confidencialidade, o emissor/remetente precisa conhecer a chave pública do destinatário/receptor, sendo assim, o emissor/remetente criptografa a mensagem utilizando a chave pública do destinatário/receptor, para descriptografar a mensagem o destinatário utiliza sua própria chave privada.

Quando se quer atestar a autenticidade, o emissor/remetente precisa assinar o documento a ser transmitido. O remetente/emissor criptografa o documento utilizando sua chave privada, e disponibiliza sua chave pública ao destinatário/receptor.

Entre os algoritmos que usam **chaves assimétricas** têm-se:

- **RSA** (o mais conhecido),
- **DSA** (Digital Signature Algorithm),
- Schnorr (praticamente usado apenas em assinaturas digitais);
- **Diffie-Hellman**.

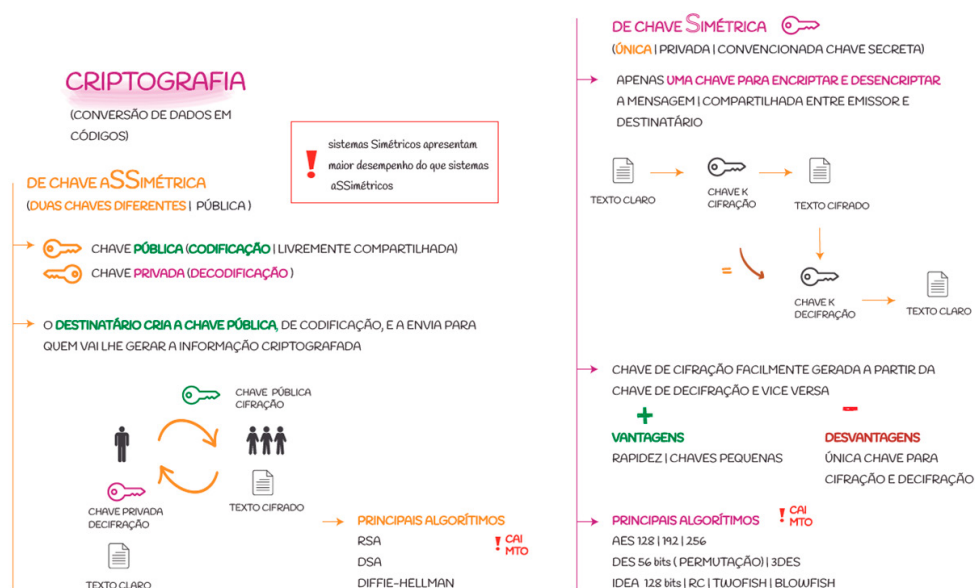
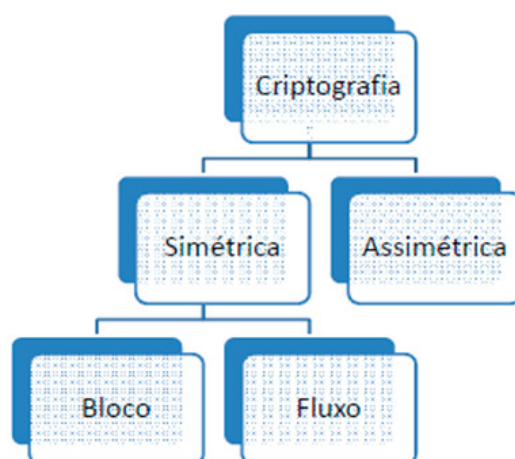


Figura. Criptografia. Fonte: Clube dos Mapas por @paola.tuzani

Existem vários algoritmos que usam **chaves simétricas**, como:

- **DES** (Data Encryption Standard),
- **IDEA** (International Data Encryption Algorithm),
- **RC** (Ron's Code ou Rivest Cipher)
- **AES** (*Advanced Encryption Standard*) – que é baseado no DES;
- **3DES**,
- **Twofish** e sua **variante Blowfish**, por exemplo.

As **Cifras de fluxo** são um tipo de **algoritmos de chave privada (chave simétrica)**. **Cifra de fluxo**: é um algoritmo de codificação simétrico que não utiliza bloco fixo, criptografando a informação no tamanho em que ela for recebida. Segundo Stallings (2008) uma cifra de fluxo é aquela que codifica um fluxo de dados digital um bit ou um byte de cada vez!



**** Hashes Criptográficos e Assinatura Digital**

Alguns algoritmos de *hash*: **MD4**, **MD5**, **SHA-1**, SHA-256, TIGER, etc.

A assinatura digital fornece uma prova inegável de que uma mensagem veio do emissor.

Para verificar esse requisito, uma assinatura deve ter as seguintes propriedades:

- **autenticidade**: o receptor (destinatário de uma mensagem) pode confirmar que a assinatura foi feita pelo emissor;
- **integridade**: qualquer alteração da mensagem faz com que a assinatura seja invalidada;
- **não repúdio** (irretratabilidade): o emissor (aquele que assinou digitalmente a mensagem) não pode negar que foi o autor da mensagem, ou seja, não pode dizer mais tarde que a sua assinatura foi falsificada.

A assinatura digital, por si só, **NÃO garante a confidencialidade (sigilo) dos dados**, pois, teoricamente, todos possuem a chave pública do remetente. Essa confidencialidade é obtida por meio de técnicas de criptografia, que são utilizadas em conjunto com as assinaturas digitais!

HASHES CRIPTOGRAFICOS

(RESUMO DE MENSAGEM | FUNÇÕES DE CONDENSAÇÃO)

- GARANTIR **INTEGRIDADE**
- NÃO ALTERA O DOCUMENTO ORIGINAL
- **UNIDIRECIONAL** (não é possível reconstruir a mensagem a partir do HASH)
- **FUNÇÃO MATEMÁTICA | RESULTADO ÚNICO**



ASSINATURA DIGITAL

- MECANISMO DE **AUTENTICAÇÃO** (permite de forma única e exclusiva a confirmação de autoria da mensagem)
(COMPROVAÇÃO DE AUTORIA + INTEGRIDADE + NÃO REPÚDIO)
- NÃO GARANTE SIGILO
- CRIAÇÃO DO CÓDIGO (chave privada | codificação HASH)
- VERIFICAÇÃO DO CÓDIGO (chave pública)

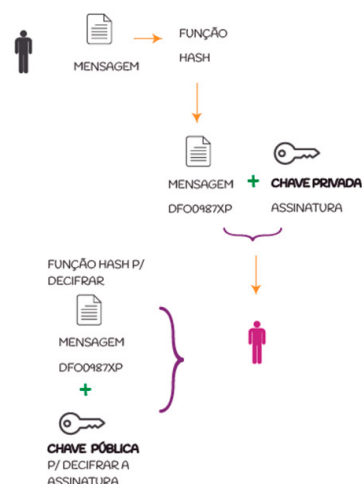


Figura. Hashes e Assinatura Digital. Fonte: Clube dos Mapas por @paola.tuzani

** Certificado Digital

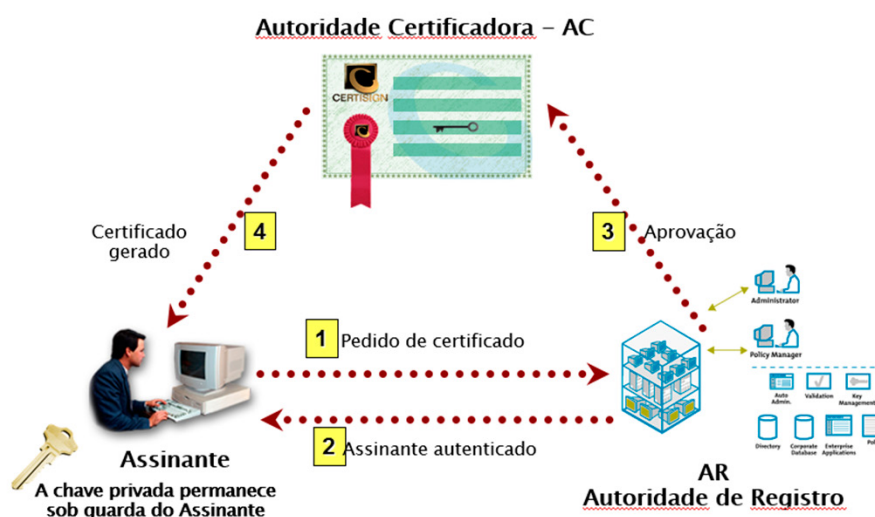
Um **certificado digital** é um documento eletrônico que identifica pessoas, físicas ou jurídicas, URLs, contas de usuário, servidores (computadores) dentre outras entidades.



Figura. Certificado Digital. Fonte: Clube dos Mapas por @paola.tuzani

Esse “documento” na verdade é uma estrutura de dados que contém a chave pública do seu titular e outras informações de interesse. Contêm informações relevantes para a identificação “real” da entidade a que visam certificar (CPF, CNPJ, endereço, nome, etc.) e informações relevantes para a aplicação a que se destinam.

O certificado digital precisa ser emitido por uma autoridade reconhecida pelas partes interessadas na transação. Chamamos essa autoridade de **Autoridade Certificadora, ou AC**.



- A **Infraestrutura de Chaves Públicas Brasileira – ICP-Brasil** é uma **cadeia hierárquica de confiança que viabiliza a emissão de certificados digitais para identificação virtual do cidadão**.

Observa-se que o modelo adotado pelo Brasil foi o de certificação com raiz única, sendo que o ITI, além de desempenhar o papel de Autoridade Certificadora Raiz – AC-Raiz, também tem o papel de credenciar e descredenciar os demais participantes da cadeia, supervisionar e fazer auditoria dos processos.

Veja mais: <https://www.gov.br/iti/pt-br/assuntos/icp-brasil>

- O **X.509** é um **padrão internacional para certificação digital**. Veja a seguir uma descrição desse padrão: **X.509** é um formato padrão para **certificados de chave pública**, documentos digitais que associam com segurança pares de chaves criptográficas a identidades como sites, indivíduos ou organizações.

Os aplicativos comuns dos certificados X.509 incluem:

- SSL /TLS e HTTPS para navegação na web autenticada e criptografada;
- E-mail assinado e criptografado via S/MIME protocolo;
- Assinatura de código;
- Assinatura de documento;
- **Autenticação de cliente;**
- **ID eletrônico emitido pelo governo.**

Veja mais: <https://www.ssl.com/pt/faqs/o-que-%C3%A9-um-certificado-x-509/>

**** Hardening**

É um processo de mapeamento das ameaças, mitigação dos riscos e execução das atividades corretivas, com o objetivo de “endurecer” o sistema contra as brechas de segurança (vulnerabilidades), tomando determinadas ações sobre o *host*, como por exemplo: acesso restrito a ferramentas administrativas, aplicação de patches de segurança atualizados (correções disponibilizadas a um sistema), tanto do sistema operacional quanto de aplicações, remoção de softwares e pastas compartilhadas desnecessárias, remoção de contas de usuários inativos, dentre outros.

Esta técnica **NÃO** deve ser implementada somente em servidores que ficam conectados diretamente à Internet, muitas vezes fornecendo serviços como, por exemplo servidores web, **mas também em máquinas que provêm serviços internos de rede como servidores de arquivos e de impressão.**

Segundo Hassell (2005), *hardening* é o processo de proteger um sistema contra ameaças desconhecidas. Os administradores de sistema devem endurecer uma instalação contra o que eles acham que poderia ser uma ameaça.

Quando uma técnica de *hardening* é aplicada, há **três fatores que devem ser levados em consideração, são eles: segurança, risco e flexibilidade.** O administrador de redes deve dosar bem esses três fatores e levar o sistema a uma alta produtividade, garantindo segurança e tendo um nível de risco aceitável. Ter total segurança não é possível, mas quanto mais segura for sua rede, menos riscos ocorrerão.

A seguir são listadas algumas **vantagens de se utilizar técnicas de hardening:**

- permitir mapear ameaças e evitar que ocorram falhas e invasões em um sistema;
- evitar que *scripts* maliciosos sejam executados;
- proteger a conta do usuário root de acessos indevidos;
- liberar apenas serviços que estejam realmente ativos no sistema;
- aplicar controles aos serviços disponíveis na rede;
- aplicar limite de acesso aos usuários.

Com a blindagem de sistemas é possível aumentar o desempenho do *hardware*, liberando recursos que estão sendo utilizados por aplicativos desnecessários, implementando configurações específicas em alguns serviços, além de gerar um ambiente mais seguro.

Situação em que o **hardening** é útil: evitar que usuários mal intencionados aproveitem da ausência do administrador e implantem *scripts* maliciosos em servidores infectando toda a rede, bloquear que o usuário administrador faça login diretamente no terminal, efetuar logout por tempo de inatividade, remover pacotes que não são utilizados, remover permissões especiais de binários executáveis, etc.

RESUMO

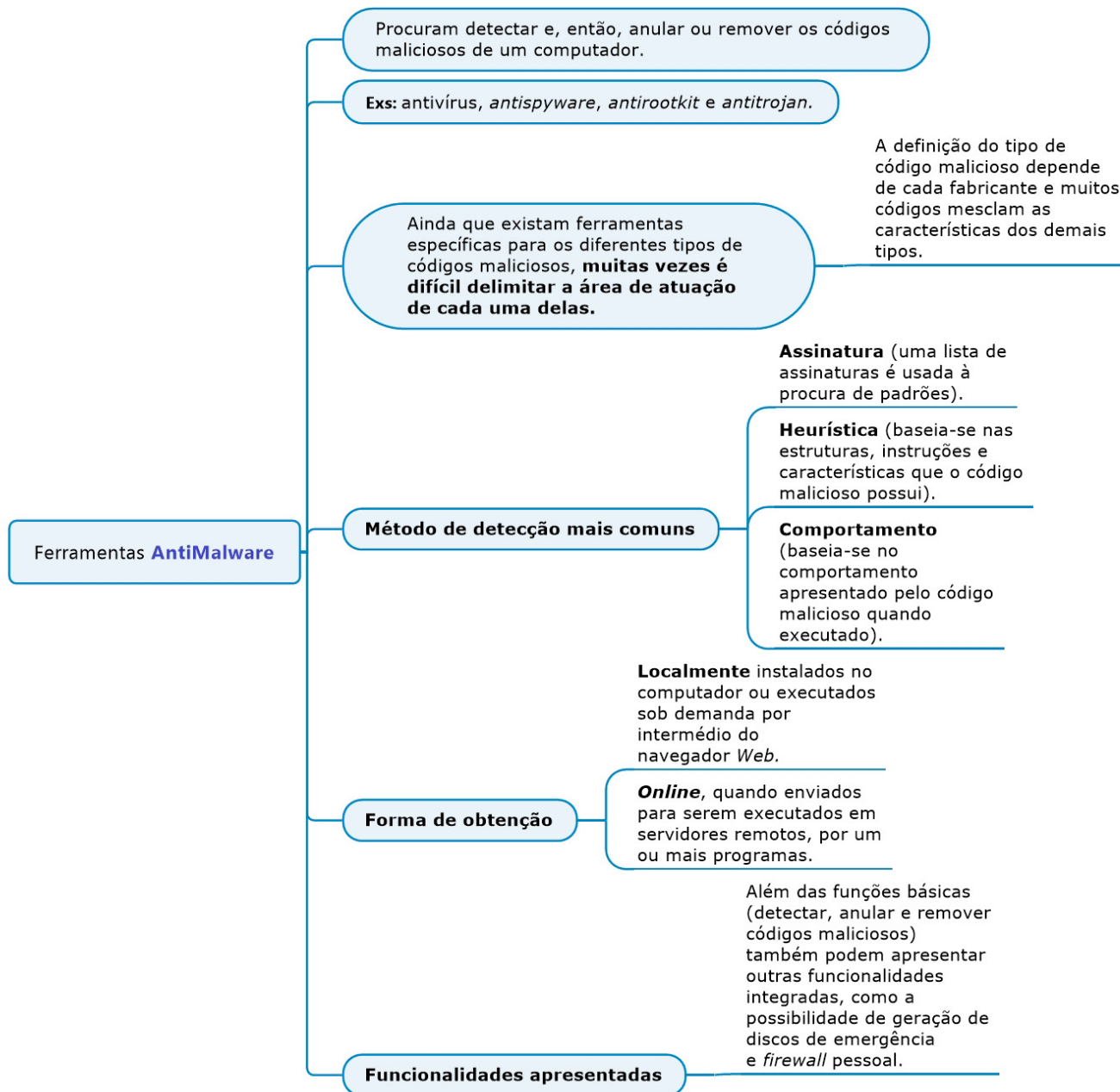


Figura. Ferramentas AntiMalware. Fonte: Quintão (2020)

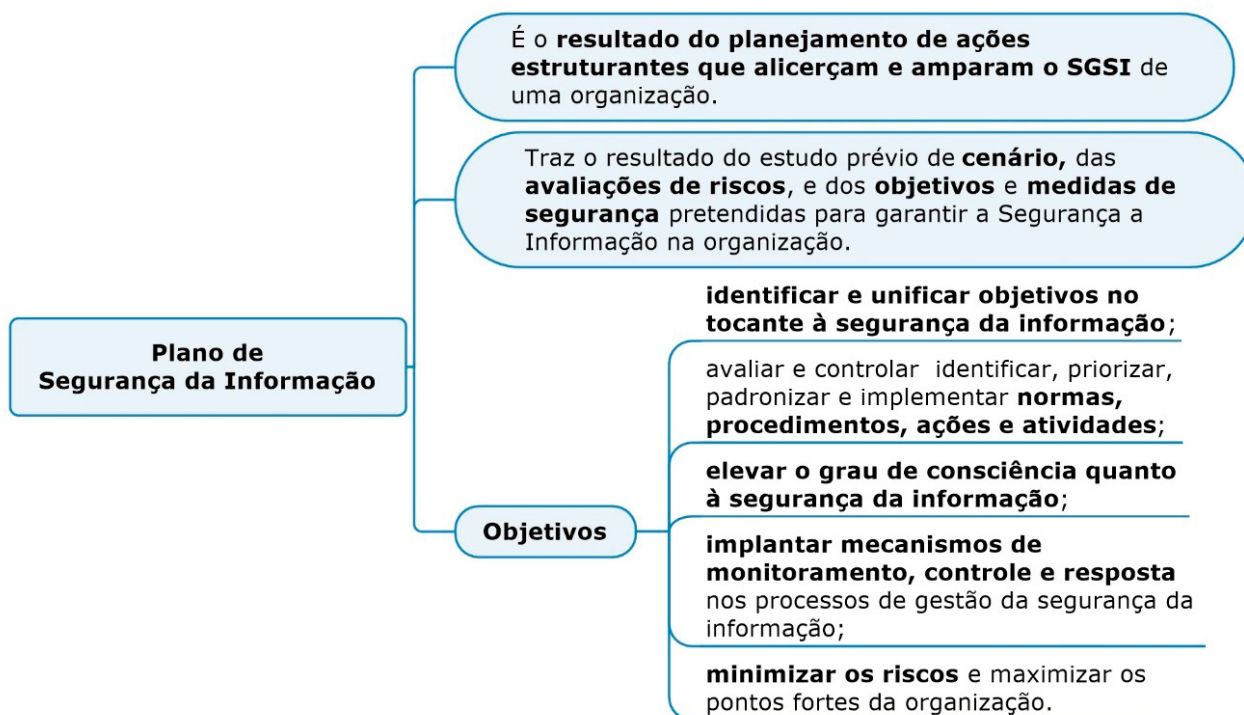
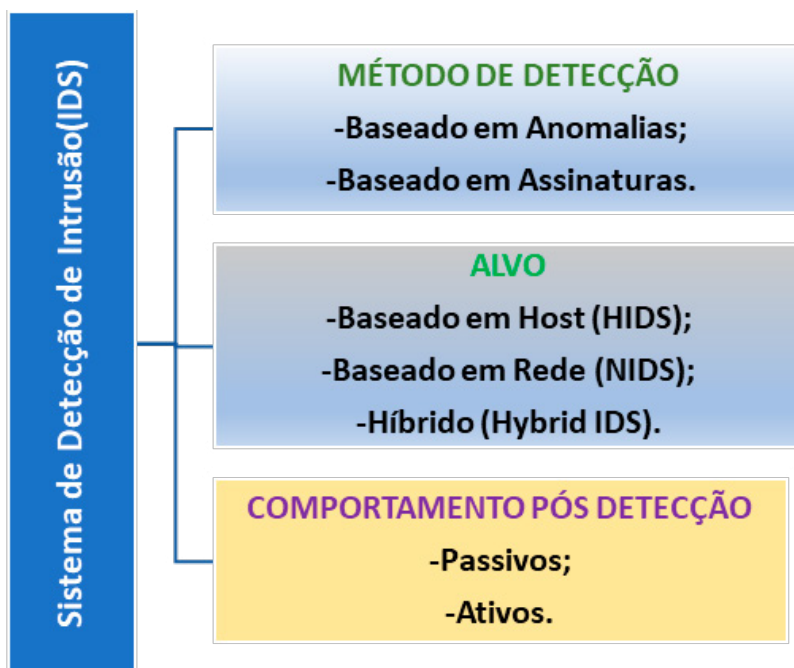
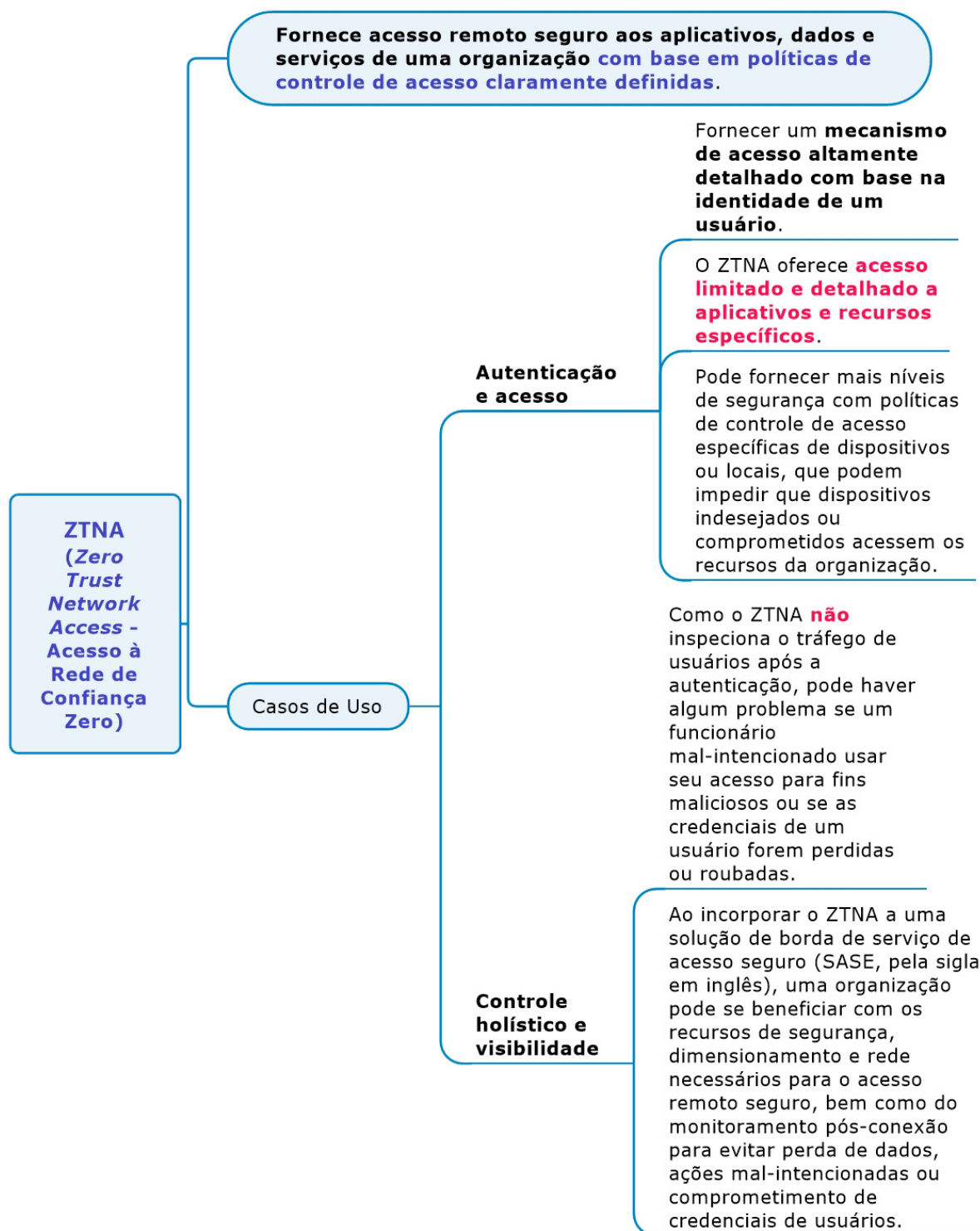
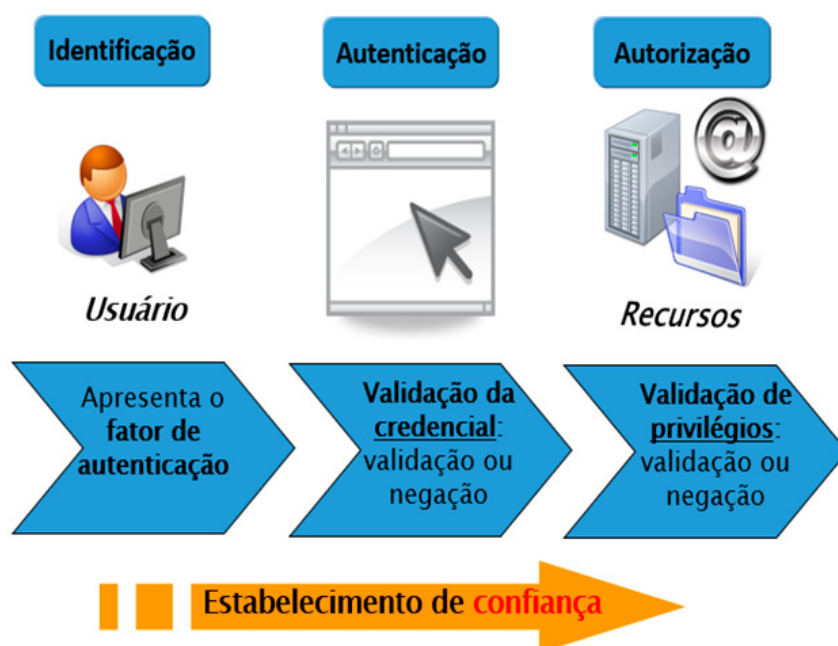


Figura. Plano de Segurança da Informação. Fonte: Quintão (2022)



- **Sniffers**, para capturar informações na rede em que o computador está localizado, como por exemplo senhas que estejam trafegando em claro, ou seja, sem qualquer método de criptografia;



Obs.: IDENTIFICAÇÃO: é a capacidade de extrair informações de um usuário ou aplicação as quais o identifiquem unicamente.

AUTENTICAÇÃO: é a capacidade de garantir que um usuário, sistema ou informação é mesmo quem alega ser. A autenticação é essencial para a segurança dos sistemas, ao validar a identificação dos usuários, concedendo-lhes a **AUTORIZAÇÃO** para o acesso aos recursos.

A **autenticação**, em regra, **depende** de um ou mais **modos ou fatores de autenticação**, listados a seguir:

Algo que o usuário TEM/ POSSUI	São utilizados objetos específicos como cartões de identificação, <i>smart cards</i> , <i>tokens</i> USB.
Algo que o usuário CONHECE /SABE	São utilizadas senhas fixas, <i>one-time passwords</i> , sistemas de desafio-resposta.
Algo que o usuário É	Geralmente são usados <u>meios biométricos</u> , como impressão digital, padrão retinal, padrão de voz, reconhecimento de assinatura, reconhecimento facial.
ONDE o usuário ESTÁ	Quando o acesso a sistemas só pode ser realizado em uma máquina específica, cujo acesso é restrito.

Autenticação forte consiste na autenticação por mais de um modo, ou seja, da **combinação de mais de uma maneira de autenticação**. Um exemplo disso são as transações de saque num caixa rápido. Em regra, se utiliza:

- algo que você **TEM**: um cartão da conta bancária; e
- algo que você **SABE**: a senha do cartão.

Obs.: Redes Privadas Virtuais (*Virtual Private Network – VPN*): túneis de **criptografia** entre pontos autorizados, criados por meio da *Internet* ou outras redes públicas e/ou privadas para transferência de informações.

O uso de VPNs representa uma alternativa para a redução dos custos de redes corporativas oferecendo **confidencialidade, autenticação e integridade** no transporte de informação por meio de redes públicas.

QUESTÕES COMENTADAS EM AULA

001. (CESGRANRIO/PROFISSIONAL PETROBRÁS DE NÍVEL TÉCNICO/PETROBRAS/INFORMÁTICA/PSP-RH-1/2011) Considere as afirmativas a seguir sobre segurança da informação.

I – Os softwares de segurança como firewalls e antivírus são o principal patrimônio de uma empresa, e os investimentos devem ser predominantes nesses produtos.

II – O plano de segurança da informação tem que contemplar os aspectos legais da informação, tais como propriedade intelectual e política de privacidade, entre outros.

III – O plano de segurança da informação é um processo que depende da visão estratégica do negócio e visa a proteger a rede interna de invasões indesejadas.

É correto APENAS o que se afirma em

- a) I
- b) II
- c) III
- d) I e II
- e) II e III

002. (CEBRASPE-CESPE/ATIVIDADES TÉCNICAS DE COMPLEXIDADE INTELECTUAL/MEC/ANALISTA DE SEGURANÇA/2015) A equipe de analistas apresentou um plano de segurança da informação a um dos mais tradicionais e capilarizados ministérios do Brasil, desenvolvido após um extenso trabalho de pesquisa, ao longo de alguns meses. O documento, que aborda um grande número de tópicos sobre segurança da informação no ministério, contém análises, diagnósticos, problemas, soluções possíveis e propostas, organizados na forma de capítulos. Alguns dos capítulos são listados a seguir.

- < Conceitos de segurança da informação
- < Proposta de política de segurança
- < Classificação de informações
- < Auditoria e conformidade
- < Controle de acessos físicos e lógicos
- < Indicadores e métricas
- < Gestão de vulnerabilidades
- < Gestão de riscos
- < Criptografia
- < Gestão de continuidade de negócio
- < Terceirização de atividades ligadas à segurança da informação
- < Segurança em bancos de dados
- < Segurança no desenvolvimento de aplicações web

< Segurança em redes de computadores

< Resposta a incidentes computacionais em redes

O plano também contém um capítulo de revisão de normas brasileiras de segurança da informação, da série NBR da ABNT, tais como NBR 27001, NBR 27002 e NBR 27005.

Após a apresentação do plano de segurança à administração superior do ministério, aos assessores e aos convidados por meio de chamada pública, vários debates foram realizados, e foi variado o grau de conhecimento sobre os conceitos e as características do plano, de sua elaboração e do projeto de implantação.

Tendo como referência a situação hipotética apresentada, julgue o item a seguir, acerca de conceitos de segurança da informação possivelmente articulados no plano.

Os procedimentos de auditoria interna de segurança da informação precisam levar em consideração não só os requisitos normatizados em normas aplicáveis como a NBR 27001:2006, mas também a legislação aplicável e existente sobre o tema, no âmbito da administração pública federal.

003. (CEBRASPE-CESPE/OFFICIAL TÉCNICO DE INTELIGÊNCIA/ÁREA 8/2018) Acerca de sistemas de aplicação web, julgue o item a seguir.

O WAF (web application firewall) avalia o tráfego comparando assinaturas e comportamentos anômalos, enquanto o IPS (intrusion prevention system) avalia o comportamento e a lógica do que é solicitado e devolvido.

004. (CEBRASPE-CESPE/PROFISSIONAL DE TECNOLOGIA DA INFORMAÇÃO (ME)/ATIVIDADES TÉCNICAS DE COMPLEXIDADE GERENCIAL, DE TECNOLOGIA DA INFORMAÇÃO E DE ENGENHARIA SÊNIOR/SEGURANÇA DA INFORMAÇÃO E PROTEÇÃO DE DADOS/2020) No que se refere a NAC (network access control) e NAP (network access protection), julgue o próximo item. As soluções NAC oferecem visibilidade à rede e gerenciamento de acesso por meio da aplicação de políticas em dispositivos e usuários de redes corporativas; essas soluções ajudam as organizações a controlar o acesso às suas redes, por meio de recursos tais como a política de gerenciamento do ciclo de vida, a criação de perfil e visibilidade e o acesso à rede de convidados.

005. (CEBRASPE-CESPE/PROFISSIONAL DE TECNOLOGIA DA INFORMAÇÃO (ME)/ATIVIDADES TÉCNICAS DE COMPLEXIDADE GERENCIAL, DE TECNOLOGIA DA INFORMAÇÃO E DE ENGENHARIA SÊNIOR/SEGURANÇA DA INFORMAÇÃO E PROTEÇÃO DE DADOS/2020) No que se refere a NAC (network access control) e NAP (network access protection), julgue o próximo item. O NAP é um conjunto de componentes do sistema operacional que fornece uma plataforma para acesso protegido a redes públicas.

006. (CESPE/MEC/ADMINISTRADOR DE REDE/2015) Julgue o item seguinte, referente a Firewall, VPN e sistemas de detecção de intrusão. Sistemas para detecção de intrusão são capazes de criar regras de bloqueio ou limitações para o tráfego de rede quando detectam anomalias com seus próprios recursos.

007. (CESPE/POLÍCIA FEDERAL/PAPILOSCOPISTA POLICIAL FEDERAL/2018) No que se refere à segurança de computadores, julgue o item subsecutivo. Para a melhoria de desempenho, vários produtos de segurança (firewall e antispymware, por exemplo) podem ser substituídos por um sistema de gerenciamento unificado de ameaça (UTM – unified threat management).

008. (CEBRASPE-CESPE/PROFISSIONAL DE TECNOLOGIA DA INFORMAÇÃO (ME)/ATIVIDADES TÉCNICAS DE COMPLEXIDADE GERENCIAL, DE TECNOLOGIA DA INFORMAÇÃO E DE ENGENHARIA SÊNIOR/SEGURANÇA DA INFORMAÇÃO E PROTEÇÃO DE DADOS/2020) Em relação ao SIEM (security information and event management), julgue o item subsequente.

As ferramentas SIEM geralmente fornecem dois resultados principais: os relatórios, que agregam e exibem incidentes e eventos relacionados à segurança; e os alertas, que serão acionados se o mecanismo de análise da ferramenta detectar atividades que violam um conjunto de regras.

009. (CESGRANRIO/PETROBRÁS – ANALISTA DE SISTEMAS JÚNIOR – INFRAESTRUTURA/REDES DE COMPUTADORES/2010) Uma vez que as VPNs (Virtual Private Networks) não utilizam linhas dedicadas nem links de rede remota e os dados corporativos precisam atravessar a Internet, as VPNs devem fornecer mecanismos para garantir a segurança dos dados. Os protocolos CHAP e RADIUS são utilizados pelas VPNs para fornecer

- a) autenticação e autorização.
- b) confidencialidade e autenticação.
- c) confidencialidade e integridade.
- d) autorização e confidencialidade.
- e) integridade e autorização.

010. (CESPE/TRT-1ªR/ANALISTA JUDICIÁRIO/2008/ADAPTADA) Uma característica das redes do tipo VPN (virtual private networks) é que elas nunca devem usar criptografia, devido a requisitos de segurança e confidencialidade.

011. (CESGRANRIO/PETROBRÁS/TÉCNICO EM INFORMÁTICA/SEGURANÇA DA INFORMAÇÃO/2010) A VPN (Virtual Private Network) é uma rede de comunicação privada que utiliza meios públicos. Com relação à segurança dos dados que trafegam por meio da VPN, afirma-se que

- a) muitos dados se perdem pela baixa qualidade dos meios públicos de comunicação, não sendo uma rede adequada para tráfego de aplicações críticas.
- b) os dados podem ser acessados por pessoas não autorizadas no caso de serem encapsulados sem criptografia.
- c) é uma rede segura de transmissão de dados onde, mesmo utilizando canais públicos de comunicação, usa-se o protocolo padrão da Internet.
- d) a segurança padrão oferecida pelos gestores da Internet torna viável o tráfego de dados críticos a baixos custos.
- e) a utilização de soluções de VPN comerciais garante a confidencialidade dos dados e a estabilidade das redes privadas.

EXERCÍCIOS

012. (CESPE-CEBRASPE/SEFAZ-AL/AUDITOR FISCAL DE FINANÇAS E CONTROLE DE ARRECADAÇÃO DA FAZENDA ESTADUAL/2021) Quanto à segurança da informação, julgue o item subsecutivo. O uso de senhas ou a adoção de identificação física, como biometrias, são formas de autenticação para fins de identificação única e exclusiva de usuários.

013. (CEBRASPE-CESPE/ANALISTA DE PLANEJAMENTO E ORÇAMENTO/MPO/TECNOLOGIA DA INFORMAÇÃO/GESTÃO DE INFRAESTRUTURA DE TI/2024) A respeito de métodos e protocolos de autenticação, hardening de sistemas e criptografia de dados, julgue o item subsecutivo. A autenticação, processo cujo objetivo é garantir a legitimidade do usuário, em geral, baseia-se em comprovar a autenticidade do usuário a partir de algo que somente o usuário sabe, algo que somente o usuário tem e algo que somente o usuário é.

014. (CESPE/POLÍCIA FEDERAL/ESCRIVÃO DE POLÍCIA FEDERAL/2018) Acerca de redes de computadores e segurança, julgue o item que segue.

Os aplicativos de antivírus com escaneamento de segunda geração utilizam técnicas heurísticas para identificar códigos maliciosos.

015. (CESPE/PC-MA/2018) Julgue o item subsequente, relativo a software para o ambiente de microinformática e a proteção e segurança da informação. Fazer becape regularmente é uma conduta que permite minimizar os danos decorrentes de um ataque do tipo ransomware locker, que impede o acesso ao equipamento infectado, visto que o pagamento do resgate não garante acesso aos dados.

016. (CESPE/INSS/TÉCNICO DO INSS/2016) A infecção de um computador por vírus enviado via correio eletrônico pode se dar quando se abre arquivo infectado que porventura esteja anexado à mensagem eletrônica recebida.

017. (CESPE/INSS/ANALISTA DO SEGURO SOCIAL COM FORMAÇÃO EM SERVIÇO SOCIAL/2016) Cada um dos próximos itens, que abordam procedimentos de informática e conceitos de Internet e intranet, apresenta uma situação hipotética, seguida de uma assertiva a ser julgada. Ao iniciar seu dia de trabalho, Daniel se deparou com inúmeros aplicativos abertos em seu computador de trabalho, o que deixava sua máquina lenta e sujeita a travamentos frequentes. Ele constatou, ainda, que somente um desses aplicativos era necessário para a execução de suas atividades.

Nessa situação, para melhorar o desempenho do seu computador, Daniel deve utilizar um aplicativo de antivírus instalado localmente, para eliminar os aplicativos que estiverem consumindo recursos além do normal.

018. (CESPE/TRE-PI/CONHECIMENTOS GERAIS PARA OS CARGOS 1, 2 E 4/2016) A remoção de códigos maliciosos de um computador pode ser feita por meio de

- a) anti-spyware.
- b) detecção de intrusão.
- c) anti-spam.
- d) anti-phishing.
- e) filtro de aplicações.

019. (CESPE/TRE-RS/TÉCNICO JUDICIÁRIO/CONHECIMENTOS BÁSICOS PARA OS CARGOS 6 A 8/2015) Em relação a vírus, worms e pragas virtuais, assinale a opção correta.

- a) Para garantir a segurança da informação, é suficiente instalar e manter atualizados antivírus.
- b) Não há diferença — seja conceitual, seja prática — entre worms e vírus; ambos são arquivos maliciosos que utilizam a mesma forma para infectar outros computadores.
- c) Rootkits é um arquivo que infecta o computador sem causar maiores danos, ainda que implique a pichação da tela inicial do navegador.
- d) A segurança da informação em uma organização depende integralmente de a sua área de tecnologia optar pela adoção de recursos de segurança atualizados, como firewall e antivírus.
- e) Em segurança da informação, denominam-se engenharia social as práticas utilizadas para obter acesso a informações importantes ou sigilosas sem necessariamente utilizar falhas no software, mas, sim, mediante ações para ludibriar ou explorar a confiança das pessoas.

020. (CESPE/TJ-DFT/ANALISTA JUDICIÁRIO/CONHECIMENTOS BÁSICOS PARA OS CARGOS 2, 3 E 5 A 12/2015) Com relação a redes de computadores, Internet e respectivas ferramentas e tecnologias, julgue o item a seguir.

Na segurança da informação, controles físicos são soluções implementadas nos sistemas operacionais em uso nos computadores para garantir, além da disponibilidade das informações, a integridade e a confidencialidade destas.

021. (CESPE/TRE-MT/TÉCNICO JUDICIÁRIO/CONHECIMENTOS GERAIS PARA O CARGO 6/2015) A função principal de uma ferramenta de segurança do tipo antivírus é

- a) monitorar o tráfego da rede e identificar possíveis ataques de invasão.
- b) verificar arquivos que contenham códigos maliciosos.
- c) fazer *backupe* de segurança dos arquivos considerados críticos para o funcionamento do computador.
- d) bloquear sítios de propagandas na Internet.
- e) evitar o recebimento de mensagens indesejadas de *email*, tais como mensagens do tipo spams.

022. (CESPE/TELEBRÁS/ANALISTA SUPERIOR – COMERCIAL/2015) A respeito de segurança da informação, julgue o item subsecutivo.

Uma das formas de manter o aparelho de telefone celular livre de vírus é deixar o bluetooth habilitado constantemente, para que ele possa identificar possíveis anexos maliciosos às mensagens recebidas.

023. (CESPE/TRE-GO/ANALISTA JUDICIÁRIO/2015) Acerca de procedimentos de segurança e de ensino a distância, julgue o item subsecutivo. Quanto à segurança da informação, sugere-se que se crie um disco de recuperação do sistema, assim como se desabilite a autoexecução de mídias removíveis e de arquivos anexados.

024. (CESPE/CADE/NÍVEL INTERMEDIÁRIO-NÍVEL MÉDIO/2014) Acerca dos conceitos de gerenciamento de arquivos e de segurança da informação, julgue o item subsequente. O computador utilizado pelo usuário que acessa salas de bate-papo não está vulnerável à infecção por worms, visto que esse tipo de ameaça não se propaga por meio de programas de chat.

025. (FCC/TRT – 14ª REGIÃO (RO E AC)/ANALISTA JUDICIÁRIO – ESTATÍSTICA/2018) Crime cibernético é todo crime que é executado online e inclui, por exemplo, o roubo de informações no meio virtual. Uma recomendação correta de segurança aos usuários da internet, para se proteger contra a variedade de crimes cibernéticos é

a) usar a mesma senha (composta por letras maiúsculas e minúsculas, números e símbolos) em todos os sites com conteúdo de acesso restrito, mantendo esta senha protegida em um aplicativo de gerenciamento de senhas.

b) manter os softwares atualizados, exceto os sistemas operacionais, pois estes já possuem mecanismos de segurança como firewall, antivírus e antispymware.

c) gerenciar as configurações de mídias sociais para manter a maior parte das informações pessoais e privadas bloqueadas.

d) proteger a rede wireless com senha que utiliza criptografia Wired Equivalent Privacy – WEP ou com uma Virtual Protect Network – VPN.

e) usar uma suíte de segurança para a internet com serviços como firewall, blockwall e antivírus, como o LibreOffice Security Suit.

026. (FCC/AL-PE/ANALISTA LEGISLATIVO – INFRAESTRUTURA/2014) Os programas antivírus: I – Protegem contra phishing de páginas web quando o usuário está em navegação utilizando livremente o browser.

II – Protegem contra trojan embarcado em uma aplicação quando o usuário aceita a sua instalação em sua máquina.

III – Criptografam comunicações em rede, sejam elas por meio de envio de mensagens ou navegação na Internet através de browser.

IV – Protegem contra códigos maliciosos embutidos em macros, as quais são utilizadas por um software aplicativo ou utilitário do computador do usuário.

V – Previnem a instalação de aplicativos infectados, no momento da solicitação de sua instalação, ao gerarem um alerta sobre conteúdo suspeito ou ao bloquearem a operação de instalação.

Está correto o que se afirma APENAS em:

- a) I e II.
- b) II e III.
- c) III e IV.
- d) IV e V.
- e) II e V.

027. (CESGRANRIO/PETROBRÁS/ANALISTA DE SISTEMAS PLENO – ESPECIALIDADE – INFRAESTRUTURA/2006) Assinale a afirmação INCORRETA sobre os firewalls e sistemas de detecção de intrusão (IDS – Intrusion Detection Systems).

- a) Os IDS podem ser utilizados para detectar e bloquear tentativas feitas por invasores para determinar as regras de filtragem de um firewall.
- b) Os IDS podem monitorar em tempo real os servidores de uma rede e/ou auditar os logs dos servidores à procura de padrões específicos de comportamento.
- c) Os IDS podem ser utilizados para detectar falhas de segurança em uma rede ou computadores antes mesmo que um ataque ou falha ocorra.
- d) Mesmo que os firewalls de uma rede estejam bem configurados, os sistemas IDS continuam necessários.
- e) Um firewall bem configurado deve responder a mensagens ICMP Echo Request.

028. (CESPE/EMAP/ANALISTA PORTUÁRIO – TECNOLOGIA DA INFORMAÇÃO/2018) Acerca das boas práticas de segurança da informação, julgue o item subsequente. O dispositivo de IPS (do inglês intrusion prevention system) utilizado em redes corporativas tem como objetivo bloquear ataques a partir da identificação de assinaturas e(ou) anomalias.

029. (FCC/TRF – 3ª REGIÃO/ANALISTA JUDICIÁRIO – INFORMÁTICA/2014) Os responsáveis pela Segurança da Informação do TRF da 3ª Região foram encarregados de produzir dois documentos:

1. Documenta procedimentos de gerenciamento, desenhados para manter ou recuperar operações de negócio, incluindo operações de computadores, no caso de eventuais emergências, desastres ou falhas de sistemas. É elaborado para situações em que exista perda de recursos, porém, esses recursos podem ser recuperados de uma forma menos traumática.
2. Documenta uma série de instruções ou procedimentos pré-determinados que descrevam como as funções de negócios da organização serão sustentadas durante e após uma interrupção significativa. É elaborado para possibilitar que a organização funcione em um nível aceitável para sua sobrevivência e absorva possíveis impactos financeiros, operacionais e de imagem.

Os documentos 1 e 2 são, respectivamente,

- a) Plano de Emergência e Política de Segurança da Informação.
- b) Plano de Contingência e Plano de Continuidade de Negócios.
- c) Plano de Administração de Crises e Plano de Auditoria.
- d) Política de Recuperação de Desastres e Política de Segurança da Informação.
- e) Plano de Continuidade Operacional e Plano de Negócios.

030. (FCC/TRE-CE/TÉCNICO JUDICIÁRIO/PROGRAMAÇÃO DE SISTEMAS/2012) Sobre segurança da informação, analise:

I – É obtida a partir da implementação de um conjunto de controles adequados, incluindo políticas, processos, procedimentos, estruturas organizacionais e funções de software e hardware.

II – A interconexão de redes públicas e privadas e o compartilhamento de recursos de informação aumentam a dificuldade de se controlar o acesso. A tendência da computação distribuída aumenta a eficácia da implementação de um controle de acesso centralizado.

III – Os controles de segurança precisam ser estabelecidos, implementados, monitorados, analisados criticamente e melhorados, onde necessário, para garantir que os objetivos do negócio e de segurança da organização sejam atendidos. Convém que isto seja feito em conjunto com outros processos de gestão do negócio.

IV – É importante para os negócios, tanto do setor público como do setor privado, e para proteger as infraestruturas críticas. Em ambos os setores, a função da segurança da informação é viabilizar os negócios como o governo eletrônico (*e-gov*) ou o comércio eletrônico (*e-business*), e evitar ou reduzir os riscos relevantes.

Está correto o que consta em

- a) I, II, III e IV.
- b) I, III e IV, apenas
- c) I e IV, apenas.
- d) III e IV, apenas.
- e) I e II, apenas.

031. (FCC/ TRT – 12ª REGIÃO (SC)/ANALISTA JUDICIÁRIO – TECNOLOGIA DA INFORMAÇÃO/2013)

Luiza trabalha em uma empresa com 500 funcionários. A empresa tem centenas de computadores com placas de rede conectando-os. A empresa também tem uma ou mais conexões de alta velocidade com a internet. Luiza foi contratada para evitar que um *hacker* possa sondar esses computadores, tentar estabelecer conexões FTP com eles, fazer conexões *telnet* e assim por diante. Ainda, se um funcionário cometer um erro e deixar uma vulnerabilidade na segurança, Luiza deve evitar que os *hackers* possam chegar nessa máquina e explorar essa fraqueza.

Para evitar esta situação de risco, Luiza deve instalar na rede um

- a) sistema de criptografia assimétrica.
- b) *firewall* em cada conexão com a internet.
- c) filtro de conteúdo de *e-mails*.
- d) poderoso antivírus.
- e) sistema de criptografia simétrica.

032. (FCC/TCE-CE/ANALISTA DE CONTROLE EXTERNO – AUDITORIA DE TECNOLOGIA DA INFORMAÇÃO/2015) Uma Política de Tratamento de Incidentes de Segurança da Informação deve conter um procedimento padronizado para o tratamento de incidentes que compreende, nesta ordem, as etapas:

- 1. Recepção da denúncia ou alerta interno de atividade suspeita, 2. Medidas de contenção imediata do incidente,
 - a) 3. Definição do Plano de ação; 4. Coleta de informações e evidências; 5. Notificação do incidente ao CGI.br; 6. Notificação dos envolvidos.
 - b) 3. Notificação dos envolvidos; 4. Aplicação de solução de contorno; 5. Aplicação de solução de contenção definitiva; 6. Definição das lições aprendidas.
 - c) 3. Coleta de informações e evidências; 4. Análise das informações e evidências; 5. Notificação dos envolvidos; 6. Análise crítica e determinação das medidas corretivas.
 - d) 3. Definição do Plano de ação; 4. Aplicação de solução de contorno; 5. Classificação do incidente; 6. Notificação dos envolvidos.
 - e) 3. Coleta de informações e evidências; 4. Análise crítica e aplicação de medidas corretivas; 5. Análise das informações e evidências; 6. Notificação dos envolvidos.

033. (CESPE/TCE RN/ASSESSOR TÉCNICO DE INFORMÁTICA – CONTROLE EXTERNO/2015) Julgue os próximos itens, referentes à prevenção e tratamento de ataques a redes de computadores. A fim de tratar os incidentes de segurança, a equipe de tratamento e resposta a incidentes nas redes computacionais de uma organização deve apresentar os serviços: resposta, triagem, coordenação de incidentes em redes computacionais e emissão de boletins de segurança.

034. (CESPE/MEC/GERENTE DE SEGURANÇA/2015) Em relação à política de segurança da informação e à gestão de continuidade do negócio, julgue o item a seguir.

A política de informação deve ser escrita e assinada pelo chefe da SOC (security operation center), responsável máximo pela informação organizacional, que, durante a escrita desse documento, deverá ouvir as demais áreas institucionais, de modo a incrementar a audiência e o entendimento do funcionamento da organização.

035. (FCC/MPE-PE/ANALISTA MINISTERIAL – INFORMÁTICA/2018) Estabelecer um plano de continuidade de negócios é primordial para as empresas, sendo que o plano de continuidade é constituído de subplanos. O subplano estabelecido para ser utilizado em último caso quando todas as prevenções tiverem falhado é conhecido como Plano de

- a) Gerenciamento de Crises.
- b) Contingência.
- c) Recuperação de Desastres.
- d) Administração.
- e) Continuidade Operacional.

036. (INSTITUTO ACCESS/INSTITUTO DE ACESSO À EDUCAÇÃO, CAPACITAÇÃO PROFISSIONAL E DESENVOLVIMENTO HUMANO – PREFEITURA DE DOMINGOS MARTINS/TÉCNICO DE INFORMÁTICA/2024) Sobre as cópias de segurança (backups), é correto afirmar que

- a) os backups são apenas necessários para grandes empresas, não para usuários individuais.
- b) os backups devem ser realizados apenas quando ocorrer uma falha no sistema.
- c) o backup incremental consiste na realização de uma cópia de segurança dos dados que foram alterados desde a última operação de backup.
- d) é recomendável armazenar cópias de segurança exclusivamente em discos rígidos locais para facilitar o acesso.

037. (COSEAC UFF/INSPETOR DE POLÍCIA PENAL/SEAP RJ/2025) Ana fez o backup dos arquivos de trabalho dos dias pares do seu computador utilizando uma mídia removível por meio dos comandos “copiar e colar” do sistema operacional. Nesse caso ela utilizou um backup do tipo

- a) diferencial.
- b) diário.
- c) incremental.
- d) de cópia.
- e) normal.

038. (IADES/SEASTER-PA/TÉCNICO DE ENFERMAGEM/2019) Acerca dos procedimentos de segurança que devem ser adotados ao utilizar-se um computador, assinale a alternativa correta.

- a) Não é recomendável utilizar CD-ROM para gravar cópias de arquivos.
- b) Cópias de segurança de arquivos confiáveis devem ser feitas, mas somente em servidores on-line.
- c) Qualquer arquivo importante deve ser copiado, seja ele confiável ou infectado.
- d) Toda cópia de arquivo é confiável.
- e) A manutenção de cópias de segurança redundantes de arquivos importantes é recomendável.

039. (FGV/TECNÓLOGO/FUNSAÚDE CE/SUPORTE OPERACIONAL EM HARDWARE E SOFTWARE/2021) Leia o fragmento a seguir.

“X.509 é um padrão importante porque a estrutura de certificado e os protocolos de autenticação definidos nele são usados em diversos contextos. O núcleo do esquema X.509 é o certificado de ____ associado a cada usuário. Esses certificados do usuário são considerados como sendo criados por alguma ____ confiável e colocados no diretório pela CA ou pelo usuário. O próprio ____ não é responsável pela criação das chaves públicas ou pela função de certificação; ele simplesmente oferece um local de fácil acesso para os usuários obterem certificados”.

Assinale a opção cujos itens completem corretamente as lacunas do fragmento acima.

- a) confiabilidade – instituição – usuário.
- b) segurança cibernética – empresa – servidor de segurança.
- c) transparência digital – autoridade certificadora – administrador.
- d) chave privada – autarquia – servidor de autenticação.
- e) chave pública – autoridade certificadora – servidor de diretório.

040. (FGV/IBGE/ANALISTA CENSITÁRIO – ANÁLISE DE SISTEMAS – SUPORTE À COMUNICAÇÃO E REDE/2017) Analise as afirmativas a seguir em relação à criptografia assimétrica:

I – O uso de criptografia assimétrica evita ataques baseados na técnica de Man-in-the-middle.

II – Criptografia por curvas elípticas é uma forma de implementação de criptografia por chave pública.

III – A criptografia assimétrica pode ter sua eficiência aumentada por meio do uso de cifras de fluxo.

Está correto somente o que se afirma em:

- a) I;
- b) II;
- c) III;
- d) I e II;
- e) I e III.

041. (FGV/ALERJ/ESPECIALISTA LEGISLATIVO/TECNOLOGIA DA INFORMAÇÃO/2017) O protocolo SSL (Secure Sockets Layer) combina as criptografias assimétrica e simétrica para garantir a confidencialidade e a autenticidade na comunicação entre computadores na Internet. São exemplos, respectivamente, de algoritmos de criptografia assimétrica e simétrica:

- a) SHA e RSA;
- b) IDEA e SHA;
- c) RSA e MD5;
- d) AES e DES;
- e) RSA e IDEA.

042. (FGV/TCM-SP/AGENTE DE FISCALIZAÇÃO – TECNOLOGIA DA INFORMAÇÃO/2015) Pedro quer enviar uma mensagem para Maria, porém o sigilo é importante nesta comunicação. Somente Maria deve ser capaz de ler a mensagem. Por outro lado, Maria precisa ter a garantia de que a mensagem foi enviada por Pedro. Para garantir a autenticação do autor e a confidencialidade dos dados, será necessário utilizar:

- a) dois algoritmos fortes de criptografia simétrica;
- b) criptografia simétrica para garantir a autoria e assimétrica para ciframento dos dados;
- c) dois pares de chaves públicas e privadas;
- d) criptografia assimétrica para assinatura digital;
- e) assinatura digital para autoria e um algoritmo de hashing para assegurar a confidencialidade.

043. (FCC/ICMS-RJ/AUDITOR FISCAL DA RECEITA ESTADUAL/2014) A política de segurança da informação da Receita Estadual inclui um conjunto de diretrizes que determinam as linhas mestras que devem ser seguidas pela instituição para que sejam assegurados seus recursos computacionais e suas informações. Dentre estas diretrizes encontram-se normas que garantem

I. a fidedignidade de informações, sinalizando a conformidade dos dados armazenados com relação às inserções, alterações e processamentos autorizados efetuados. Sinalizam, ainda, a conformidade dos dados transmitidos pelo emissor com os recebidos pelo destinatário, garantindo a não violação dos dados com intuito de alteração, gravação ou exclusão, seja ela acidental ou proposital.

II. que as informações estejam acessíveis às pessoas e aos processos autorizados, a qualquer momento requerido, assegurando a prestação contínua do serviço, sem interrupções no fornecimento de informações para quem é de direito.

III. que somente pessoas autorizadas tenham acesso às informações armazenadas ou transmitidas por meio das redes de comunicação, assegurando que as pessoas não tomem conhecimento de informações, de forma acidental ou proposital, sem que possuam autorização para tal procedimento.

Em relação às informações, as normas definidas em **I**, **II** e **III** visam garantir

- a) fidedignidade, acessibilidade e disponibilidade.
- b) integridade, disponibilidade e confidencialidade.
- c) confidencialidade, integridade e autenticidade.
- d) integridade, ininterruptibilidade e autenticidade.
- e) confidencialidade, integridade e disponibilidade.

044. (INÉDITA/2025) Os graus de sigilo das informações são determinados exclusivamente pela quantidade de dados armazenados, sem considerar a sensibilidade ou o potencial impacto de sua divulgação.

045. (INSTITUTO VERBENA/ASSISTENTE/CM ANÁPOLIS/ADMINISTRATIVO/TÉCNICO DE INFORMÁTICA/2024) A manutenção preventiva, tem por objeto a prevenção de pane ou situações que comprometam o correto funcionamento de um computador. O tipo mais comum de manutenção preventiva utilizado para garantir a segurança contra ataques de malwares ou outro tipo de vírus é a

- a) atualização do antivírus.
- b) troca da placa mãe.
- c) nova instalação do sistema operacional.
- d) troca da impressora.

046. (INÉDITA/2025) A capacidade de um agente de segurança de agir com discrição pode contribuir para identificar ameaças potenciais sem alertar os agressores ou pessoas não autorizadas.

047. (INÉDITA/2025) A discrição nas atividades de segurança da informação implica que todos os funcionários devem ter acesso irrestrito a dados sensíveis para garantir a transparência dentro da organização.

048. (PUC PR/ANALISTA DE INFORMÁTICA/DPE PR/2012) Política de segurança que define como são tratadas as informações institucionais, indicando se elas podem ser repassadas a terceiros. Está-se falando:

- a) Política de privacidade.
- b) Política de confidencialidade.
- c) Política de backup.
- d) Política de termo de uso.
- e) Política de quebra de sigilo.

049. (FGV/BANESTES/ANALISTA EM TECNOLOGIA DA INFORMAÇÃO/SEGURANÇA DA INFORMAÇÃO/2021) Um pequeno dispositivo que contém um código de proteção precisa necessariamente ficar conectado à porta USB do computador para que determinado software possa ser utilizado.

Esse dispositivo utilizado para prevenir o uso não autorizado de determinado software é conhecido como:

- a) Vault;
- b) Keycloak;
- c) KeePass;
- d) Keylogger;
- e) Hardlock.

050. (FGV/BANESTES/ANALISTA EM TECNOLOGIA DA INFORMAÇÃO – SEGURANÇA DA INFORMAÇÃO/2021) Monitorar e auditar o tráfego de informação corporativa é uma prática comumente utilizada por organizações para detectar atividades não autorizadas de processamento da informação.

A técnica utilizada nas atividades de gerência para capturar e interpretar as informações sobre aquilo que trafega em cada segmento de rede é:

- a) NTP;
- b) SMI;
- c) Kibana;
- d) Sniffing;
- e) Vishing.

051. (FGV/DPE-RJ/TÉCNICO SUPERIOR ESPECIALIZADO – GESTÃO EM TECNOLOGIA DA INFORMAÇÃO/2014) Você é o responsável pela segurança de informação da organização em que trabalha e recebeu um e-mail automático do sistema de controle de acesso dos servidores da empresa informando que houve um ‘evento inesperado com probabilidade de ameaçar a segurança da informação’. Nesse contexto, é correto afirmar que, de acordo com a NBR ISO/IEC 27001, houve

- a) um problema de indisponibilidade de ao menos um dos servidores.
- b) um incidente de segurança da informação.
- c) a detecção de uma vulnerabilidade nos servidores.
- d) a ocorrência de um risco.
- e) uma falha na segurança da informação.

052. (FGV/ALERJ/ESPECIALISTA LEGISLATIVO – TECNOLOGIA DA INFORMAÇÃO/2017) Ataques cibernéticos podem causar graves prejuízos a pessoas e empresas. Recentemente João recebeu uma mensagem de alerta por e-mail com um pedido para ele atualizar seus dados cadastrais na página do seu Internet Banking.

João não prestou muita atenção em quem enviou a mensagem, nem se era um remetente confiável, e clicou no link presente no corpo do e-mail, que o levou para uma página web, réplica do website real criada por um cyber criminoso.

Como a mensagem de e-mail e o website eram muito bem elaborados, João acreditou estar acessando algo verdadeiro e informou suas credenciais para acesso, quando na verdade ele as entregou a um criminoso.

João foi vítima de um ataque cibernético denominado:

- a) DDoS;
- b) sniffer;
- c) spam;
- d) phishing;
- e) spoofing.

053. (FGV/SUSAM/ANALISTA DE SISTEMAS/2014) Um certificado digital é um arquivo de dados contendo segmentos ou seções que possuem informações obrigatórias e adicionais armazenada em extensões. A utilização de certificados digitais permite que sejam agregados requisitos de segurança na tramitação de informações. Dentre esses requisitos, está a garantia da impossibilidade de que o autor recuse a autoria.

Esse é o requisito de

- a) integridade.
- b) não repúdio.
- c) privacidade.
- d) autenticidade.
- e) sigilo.

054. (FGV/TJ-GO/ANALISTA JUDICIÁRIO – ANÁLISE DE SISTEMAS – INFRAESTRUTURA DE REDES E COMUNICAÇÃO DE DADOS/2014) Mesmo com a utilização de um firewall na rede, um dos servidores HTTP de uma empresa foi atacado. O ataque em questão pôde ser identificado e bloqueado automaticamente porque na mesma rede tinha sido instalado um:

- a) servidor DNS interno;
- b) IPS;
- c) proxy;
- d) servidor VPN;
- e) PDC.

055. (FGV/FIOCRUZ/TECNOLOGISTA EM SAÚDE PÚBLICA/SEGURANÇA DA INFORMAÇÃO/2010) Com relação à análise de risco em segurança da informação, considere os tipos de risco a seguir.

I – Dano físico, como fogo, vandalismo e desastres naturais.

II – Perda de dados, seja intencional ou não.

III – Falha de equipamento.

IV – Risco de mercado e perda de investimento.

Assinale:

- a) se uma empresa deve estar atenta, em sua análise, somente aos riscos I, II e III.
- b) se uma empresa deve estar atenta, em sua análise, a todos esses tipos de riscos.
- c) se uma empresa deve estar atenta, em sua análise, somente aos riscos I e II.
- d) se uma empresa deve estar atenta, em sua análise, somente aos riscos II e III.
- e) se uma empresa deve estar atenta, em sua análise, somente aos riscos I e IV.

056. (FGV/FIOCRUZ/TECNOLOGISTA EM SAÚDE PÚBLICA/SEGURANÇA DA INFORMAÇÃO/2010) O roubo ou a perda de *laptops* é atualmente um dos piores problemas para a segurança da informação corporativa. A respeito da segurança da informação em ambientes e equipamentos, considere as afirmativas a seguir.

I – Realizar o inventário de todos os *laptops*, de forma que possam ser identificados caso sejam recuperados.

II – Criptografar todos os dados sensíveis.

III – Proteger o BIOS com senha.

IV – Em viagens aéreas, enviar o *laptop* separadamente com a bagagem.

Assinale:

a) se somente as afirmativas I, II e III ajudam a proteger tais equipamentos e os dados que contêm.

b) se todas as afirmativas ajudam a proteger tais equipamentos e os dados que contêm.

c) se somente as afirmativas I e II ajudam a proteger tais equipamentos e os dados que contêm.

d) se somente as afirmativas II e III ajudam a proteger tais equipamentos e os dados que contêm.

e) se somente as afirmativas I e IV ajudam a proteger tais equipamentos e os dados que contêm.

057. (FGV/AUDITOR DA RECEITA DO ESTADO DO AMAPÁ/2010) De tempos em tempos, observa-se na imprensa que *sites* ficam inoperantes. Os ataques conseguem derrubar o tráfego de rede, inundados por solicitações até saírem do ar, por esgotamento da capacidade de processamento. Os especialistas em segurança de redes e na internet creditam os ataques a algum *hacker* que utiliza as chamadas *botnets*, definidas como redes de computadores infectadas por códigos maliciosos. Nesses casos, as máquinas funcionam normalmente até que o *hacker* envie um comando remoto ordenando que todas acessem um site ao mesmo tempo, tirando-o do ar por excesso de tráfego.

Esse tipo de ataque é conhecido pelo termo técnico:

a) Negação por Excesso de Força Bruta.

b) Negação de Acesso por Colisão.

c) Negação de Tráfego por Telnet.

d) Negação por Intrusão.

e) Negação de Serviço.

058. (CEBRASPE-CESPE/ANALISTA EM DESENVOLVIMENTO REGIONAL/CODEVASF/TECNOLOGIA DA INFORMAÇÃO/2021) Em determinada organização, não existem vulnerabilidades de segurança conhecidas nos servidores e os sistemas estão atualizados e bem configurados. Considerando essa situação hipotética, julgue o item seguinte.

Eventual ocorrência de um ataque de phishing em que um usuário seja convencido a clicar um link malicioso específico recebido em uma mensagem de email poderá viabilizar um subsequente ataque de ransomware contra os computadores dessa organização.

059. (INÉDITA/2025) A autenticação de um fator é suficiente para proteger informações sensíveis em sistemas modernos.

060. (INÉDITA/2025) A autenticação de dois fatores pode incluir algo que o usuário possui, como um token físico ou um código enviado por SMS.

061. (INÉDITA/2025) A autenticação de um fator é suficiente para proteger informações sensíveis em sistemas modernos.

062. (INÉDITA/2025) A autenticação de dois fatores pode incluir algo que o usuário possui, como um token físico ou um código enviado por SMS.

GABARITO

- | | |
|-------|-------|
| 1. e | 35. b |
| 2. C | 36. c |
| 3. E | 37. d |
| 4. C | 38. e |
| 5. E | 39. e |
| 6. E | 40. b |
| 7. C | 41. e |
| 8. C | 42. c |
| 9. a | 43. b |
| 10. E | 44. E |
| 11. b | 45. a |
| 12. C | 46. C |
| 13. C | 47. E |
| 14. C | 48. b |
| 15. C | 49. e |
| 16. C | 50. d |
| 17. E | 51. b |
| 18. a | 52. d |
| 19. e | 53. b |
| 20. E | 54. b |
| 21. b | 55. a |
| 22. E | 56. a |
| 23. C | 57. e |
| 24. E | 58. C |
| 25. b | 59. E |
| 26. d | 60. C |
| 27. e | 61. E |
| 28. C | 62. C |
| 29. b | |
| 30. b | |
| 31. b | |
| 32. c | |
| 33. C | |
| 34. E | |

GABARITO COMENTADO

012. (CESPE-CEBRASPE/SEFAZ-AL/AUDITOR FISCAL DE FINANÇAS E CONTROLE DE ARRECAÇÃO DA FAZENDA ESTADUAL/2021) Quanto à segurança da informação, julgue o item subsecutivo. O uso de senhas ou a adoção de identificação física, como biometrias, são formas de autenticação para fins de identificação única e exclusiva de usuários.



A **autenticação**, em regra, **depende** de um ou mais **modos ou fatores de autenticação**, os quais ajudam a verificar a identidade dos usuários. Os fatores de identificação mais comumente usados são listados a seguir:

Algo que o usuário CONHECE /SABE	São utilizadas senhas fixas , <i>one-time passwords</i> , sistemas de desafio-resposta.
Algo que o usuário TEM /Possui	São utilizados objetos específicos como cartões de identificação, <i>tokens</i> USB, smartphone que receberá e-mail ou SMS com código a ser apresentado.
Algo que o usuário É	Geralmente são usados meios biométricos , como impressão digital, padrão retinal, padrão de voz, reconhecimento de assinatura, reconhecimento facial.
ONDE o usuário ESTÁ	Quando o acesso a sistemas só pode ser realizado em uma máquina específica, cujo acesso é restrito.

Certo.

013. (CEBRASPE-CESPE/ANALISTA DE PLANEJAMENTO E ORÇAMENTO/MPO/TECNOLOGIA DA INFORMAÇÃO/GESTÃO DE INFRAESTRUTURA DE TI/2024) A respeito de métodos e protocolos de autenticação, hardening de sistemas e criptografia de dados, julgue o item subsecutivo. A autenticação, processo cujo objetivo é garantir a legitimidade do usuário, em geral, baseia-se em comprovar a autenticidade do usuário a partir de algo que somente o usuário sabe, algo que somente o usuário tem e algo que somente o usuário é.



A questão aborda o conceito de **autenticação** no campo da segurança da informação. O objetivo da autenticação é, como a própria questão menciona, **garantir a legitimidade do usuário**; ou seja, confirmar que a pessoa ou entidade que está tentando acessar um sistema ou recurso é realmente quem ela afirma ser.

A pergunta afirma que essa comprovação de identidade se baseia, em geral, em três pilares:

- **Algo que somente o usuário sabe:** refere-se a informações confidenciais que o usuário deve guardar para si. O exemplo mais comum e cotidiano é a senha ou um PIN. Para provar sua identidade por este fator, o usuário precisa fornecer essa informação secreta.

- **Algo que somente o usuário tem:** Diz respeito a um objeto físico ou digital que está em posse exclusiva do usuário legítimo. Exemplos incluem um token de segurança (que gera códigos), um cartão inteligente, um dispositivo móvel que recebe códigos por SMS ou notificação, ou até mesmo uma chave física. Para autenticar-se, o usuário precisa apresentar ou usar este item que possui.
- **Algo que somente o usuário é:** Baseia-se em características inerentes e únicas do indivíduo, sejam elas biológicas ou comportamentais. Impressões digitais, reconhecimento facial, escaneamento da íris ou retina, padrões de voz, ou até mesmo a forma de digitar são exemplos deste fator. A autenticação ocorre ao verificar e comparar essa característica biológica ou comportamental única.

A questão está correta porque descreve precisamente os **três fatores clássicos de autenticação** que são utilizados, isoladamente ou, mais frequentemente em combinação (Autenticação de Múltiplos Fatores – MFA), para comprovar a identidade de um usuário e garantir sua legitimidade antes de conceder acesso a sistemas e dados. Estes três fatores formam a base conceitual sobre a qual a maioria dos mecanismos de autenticação modernos são construídos.

Portanto, a afirmação apresentada na questão está alinhada com os princípios fundamentais da autenticação em segurança da informação.

Certo.

014. (CESPE/POLÍCIA FEDERAL/ESCRIVÃO DE POLÍCIA FEDERAL/2018) Acerca de redes de computadores e segurança, julgue o item que segue.

Os aplicativos de antivírus com escaneamento de segunda geração utilizam técnicas heurísticas para identificar códigos maliciosos.



Quanto ao **método de detecção**, os antivírus geralmente utilizam:

- **Assinatura:** uma lista de assinaturas é usada à procura de padrões;
- **Heurística:** baseia-se nas estruturas, instruções e características que o código malicioso possui; e
- **Comportamento:** baseia-se no comportamento apresentado pelo código malicioso quando executado.

Os aplicativos de **antivírus com escaneamento de segunda geração** utilizam técnicas heurísticas para identificar códigos maliciosos.

Certo.

015. (CESPE/PC-MA/2018) Julgue o item subsequente, relativo a software para o ambiente de microinformática e a proteção e segurança da informação. Fazer *backups* regularmente é uma conduta que permite minimizar os danos decorrentes de um ataque do tipo ransomware locker, que impede o acesso ao equipamento infectado, visto que o pagamento do resgate não garante acesso aos dados.



Para se proteger de **ransomware** você deve tomar os mesmos cuidados que toma para evitar os outros códigos maliciosos, como ter um antivírus instalado e ser cuidadoso ao clicar em *links* ou abrir arquivos. Fazer *backups* regularmente também é essencial para proteger os seus dados pois, se seu equipamento for infectado, a única solução realmente efetiva para acessá-los novamente é buscá-los em seus *backups*.

Certo.

016. (CESPE/INSS/TÉCNICO DO INSS/2016) A infecção de um computador por vírus enviado via correio eletrônico pode se dar quando se abre arquivo infectado que porventura esteja anexado à mensagem eletrônica recebida.



Isso mesmo! Se o usuário fizer a abertura de um arquivo com vírus, a execução do arquivo infectado aciona o vírus, causando a infecção do computador.

É interessante manter, em seu computador:

- um antivírus funcionando constantemente (preventivamente);
- esse programa antivírus verificando os e-mails constantemente (preventivo);
- o recurso de atualizações automáticas das definições de vírus habilitado;
- as definições de vírus atualizadas constantemente (nem que para isso seja necessário, todos os dias, executar a atualização manualmente).

Certo.

017. (CESPE/INSS/ANALISTA DO SEGURO SOCIAL COM FORMAÇÃO EM SERVIÇO SOCIAL/2016) Cada um dos próximos itens, que abordam procedimentos de informática e conceitos de Internet e intranet, apresenta uma situação hipotética, seguida de uma assertiva a ser julgada. Ao iniciar seu dia de trabalho, Daniel se deparou com inúmeros aplicativos abertos em seu computador de trabalho, o que deixava sua máquina lenta e sujeita a travamentos frequentes. Ele constatou, ainda, que somente um desses aplicativos era necessário para a execução de suas atividades.

Nessa situação, para melhorar o desempenho do seu computador, Daniel deve utilizar um aplicativo de antivírus instalado localmente, para eliminar os aplicativos que estiverem consumindo recursos além do normal.



O antivírus não será utilizado para eliminar os aplicativos que estão consumindo recursos além do normal. Uma ação possível para eliminar esses aplicativos seria fechar os demais aplicativos que não são de interesse do usuário.

Errado.

018. (CESPE/TRE-PI/CONHECIMENTOS GERAIS PARA OS CARGOS 1, 2 E 4/2016) A remoção de códigos maliciosos de um computador pode ser feita por meio de

- a) anti-spyware.
- b) detecção de intrusão.
- c) anti-spam.
- d) anti-phishing.
- e) filtro de aplicações.



a) Certa. A ferramenta **anti-spyware** é uma forte aliada do antivírus, permitindo a localização e bloqueio de códigos maliciosos do tipo *spywares*. Exemplo de ferramentas *anti-spyware*: Windows Defender, Spybot, etc.

Obs.: Nem toda ferramenta anti-spyware é necessariamente antivírus e vice-versa.

Há programas que apresentam as duas funções, mas isso nem sempre acontece!

b) Errada. Para detecção de intrusão o **IDS (Intrusion Detection Systems – Sistemas de Detecção de Intrusos)** é a ferramenta utilizada. IDS são sistemas de detecção de intrusos, que têm por finalidade detectar atividades incorretas, maliciosas ou anômalas, em tempo real, permitindo que algumas ações sejam tomadas. O IDS procura por ataques já catalogados e registrados, podendo, em alguns casos, fazer análise comportamental do sistema.

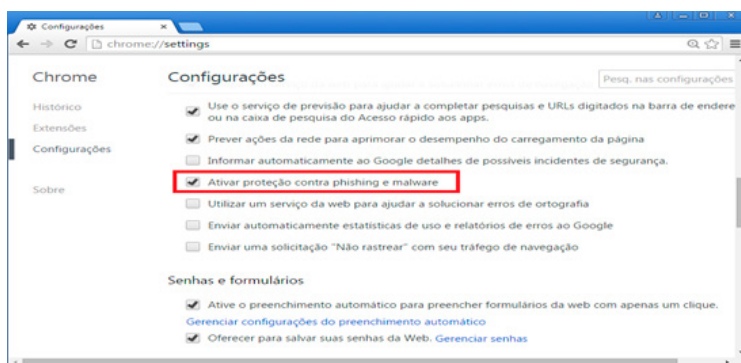
- Geram **logs** para casos de tentativas de ataques e para casos em que um ataque teve sucesso.
- Assim como os *firewalls*, os IDSs também podem gerar falsos positivos (Uma situação em que o *firewall* ou IDS aponta uma atividade como sendo um ataque, quando na verdade não é).

Um **IPS (Intrusion Prevention System – Sistema de Prevenção de Intrusos)** é um sistema que detecta e obstrui automaticamente ataques computacionais a recursos protegidos. Diferente dos IDS tradicionais, que localizam e notificam os administradores sobre anomalias, um IPS defende o alvo SEM uma participação direta humana.

c) Errada. **Anti-spam**: ferramenta utilizada para filtro de mensagens indesejadas.

d) Errada. **Phishing** ou **scam**: não é um programa que pode ser instalado no computador do usuário, mas sim um nome dado a um tipo de golpe eletrônico que tem o objetivo de “pescar” (roubar) informações e dados pessoais importantes (como senhas, dados bancários, etc.) da vítima por meio da criação de um website falso e/ou do envio de uma mensagem eletrônica falsa.

Para não ser vítima desse tipo de golpe, o usuário precisa estar muito atento e prevenido, e ferramentas *anti-phishing* gratuitas ou pagas, como Internet Explorer, Chrome, etc. podem ser utilizadas. No entanto, essa proteção não irá fazer a remoção de códigos maliciosos do computador do usuário. Veja a seguir a caixa de seleção que pode ser ativada no Google Chrome para ativação da proteção contra *phishing* e *malware*.



e) Errada. **Filtro de aplicações** possibilita conhecer aplicações e seus comportamentos, estabelecendo bloqueios quando não estiverem em conformidade com a Política de Segurança da organização.

Letra a.

019. (CESPE/TRE-RS/TÉCNICO JUDICIÁRIO/CONHECIMENTOS BÁSICOS PARA OS CARGOS 6 A 8/2015) Em relação a vírus, worms e pragas virtuais, assinale a opção correta.

- a) Para garantir a segurança da informação, é suficiente instalar e manter atualizados antivírus.
- b) Não há diferença — seja conceitual, seja prática — entre worms e vírus; ambos são arquivos maliciosos que utilizam a mesma forma para infectar outros computadores.
- c) Rootkits é um arquivo que infecta o computador sem causar maiores danos, ainda que implique a pichação da tela inicial do navegador.
- d) A segurança da informação em uma organização depende integralmente de a sua área de tecnologia optar pela adoção de recursos de segurança atualizados, como firewall e antivírus.
- e) Em segurança da informação, denominam-se engenharia social as práticas utilizadas para obter acesso a informações importantes ou sigilosas sem necessariamente utilizar falhas no software, mas, sim, mediante ações para ludibriar ou explorar a confiança das pessoas.



a) Errada. O antivírus é uma das ferramentas de segurança que devem ser implementadas para resguardar a segurança dos ativos (o que tem valor para o indivíduo ou organização e que merece ser protegido). Outras práticas de segurança também são recomendadas, como: conscientização de usuários, utilização de *firewall*, etc.

b) Errada. **Worms** são programas parecidos com vírus, mas que na verdade são capazes de se propagarem **automaticamente** por meio de redes, enviando cópias de si mesmo de computador para computador (observe que **os worms apenas se copiam, não infectam outros arquivos**, eles mesmos são os arquivos!).

Veja as principais diferenças entre essas ameaças na tabela seguinte:

VÍRUS	WORM
É um programa (ou parte de um programa) que se anexa a um arquivo de programa qualquer.	Programa.
Propaga-se inserindo cópias de si mesmo e se tornando parte de outros programas e arquivos.	Não embute cópias de si mesmo em outros programas ou arquivos. Propaga-se automaticamente pelas redes , enviando cópias de si mesmo de computador para computador.
Depende da execução do programa ou arquivo hospedeiro para ser ativado.	Não necessita ser explicitamente executado para se propagar. Basta que se tenha execução direta de suas cópias ou a exploração automática de vulnerabilidades existentes em programas instalados em computadores.

c) Errada. **Rootkit** é um tipo de malware cuja **principal intenção é se camuflar, para assegurar a sua presença no computador comprometido, impedindo que seu código seja encontrado por qualquer antivírus**. Isto é possível porque esta aplicação tem a capacidade de interceptar as solicitações feitas ao sistema operacional, podendo alterar o seu resultado.

O invasor, após instalar o *rootkit*, terá **acesso privilegiado ao computador** previamente comprometido, sem precisar recorrer novamente aos métodos utilizados na realização da invasão, e suas atividades serão escondidas do responsável e/ou dos usuários do computador. Um *rootkit* pode fornecer programas com as mais diversas funcionalidades. Dentre eles, merecem destaque:

- programas para esconder atividades e informações deixadas pelo invasor, tais como arquivos, diretórios, processos etc.;
- *backdoors*, para assegurar o acesso futuro do invasor ao computador comprometido;
- programas para remoção de evidências em arquivos de *logs*;
- **sniffers**, para capturar informações na rede onde o computador está localizado, como por exemplo senhas que estejam trafegando em claro, ou seja, sem qualquer método de criptografia;
- *scanners*, para mapear potenciais vulnerabilidades em outros computadores.

Rootkit é um tipo de praga virtual de difícil detecção, visto que é ativado antes que o sistema operacional tenha sido completamente inicializado (CESPE/2013/PCDF).

d) Errada. Todas as áreas da organização devem estar envolvidas! Não adianta ter a melhor tecnologia se as pessoas não estão envolvidas com a temática de segurança e não colocam em ação no seu dia a dia as boas práticas de segurança.

e) Certa. **Engenharia Social** é a técnica de ataque utilizada para se obter informações sigilosas ou importantes de empresas e sistemas, **enganando e explorando a confiança dos usuários**.

Letra e.

020. (CESPE/TJ-DFT/ANALISTA JUDICIÁRIO/CONHECIMENTOS BÁSICOS PARA OS CARGOS 2, 3 E 5 A 12/2015) Com relação a redes de computadores, Internet e respectivas ferramentas e tecnologias, julgue o item a seguir.

Na segurança da informação, controles físicos são soluções implementadas nos sistemas operacionais em uso nos computadores para garantir, além da disponibilidade das informações, a integridade e a confidencialidade destas.



Controles físicos visam proteger equipamentos e informações contra usuários não autorizados, prevenindo o acesso a esses recursos. Devem se basear em perímetros predefinidos nas imediações dos recursos computacionais, podendo ser explícitos como uma sala, cofre, etc. ou implícitos, como áreas de acesso restrito.

Controles lógicos compreendem inúmeros procedimentos, adotados pela empresa ou intrínsecos aos sistemas utilizados, cujo objetivo é **proteger os dados, programas e sistemas contra tentativas de acessos não autorizados, feitas por usuários ou outros programas**. Assim, as soluções implementadas nos sistemas operacionais estão relacionadas aos controles lógicos.

Errado.

021. (CESPE/TRE-MT/TÉCNICO JUDICIÁRIO/CONHECIMENTOS GERAIS PARA O CARGO 6/2015)

A função principal de uma ferramenta de segurança do tipo antivírus é

- a) monitorar o tráfego da rede e identificar possíveis ataques de invasão.
- b) verificar arquivos que contenham códigos maliciosos.
- c) fazer *back-up* de segurança dos arquivos considerados críticos para o funcionamento do computador.
- d) bloquear sítios de propagandas na Internet.
- e) evitar o recebimento de mensagens indesejadas de *email*, tais como mensagens do tipo spams.



Malwares (combinação de **malicious software – programa malicioso**) são softwares maliciosos, programados com o intuito de **prejudicar os sistemas de informação, alterar o funcionamento de programas, roubar informações, causar lentidões de redes computacionais**, dentre outros. A principal função de uma ferramenta de **antivírus** é verificar arquivos quanto à presença de códigos maliciosos (malware).

Letra b.

022. (CESPE/TELEBRÁS/ANALISTA SUPERIOR – COMERCIAL/2015) A respeito de segurança da informação, julgue o item subsecutivo.

Uma das formas de manter o aparelho de telefone celular livre de vírus é deixar o bluetooth habilitado constantemente, para que ele possa identificar possíveis anexos maliciosos às mensagens recebidas.



A utilização do *bluetooth* (ativada durante todo o tempo) irá contribuir para disseminar códigos maliciosos (vírus de celular, *worms*, etc.) no aparelho de telefone celular reportado na questão, possibilitando a invasão por terceiros naquele dispositivo.

Depois de **infectar** um telefone celular, o vírus de celular pode realizar diversas atividades, tais como:

- destruir/sobrescrever arquivos;
- remover contatos da agenda;
- efetuar ligações telefônicas;
- o aparelho fica desconfigurado e tentando se conectar via Bluetooth com outros celulares;
- a bateria do celular dura menos do que o previsto pelo fabricante, mesmo quando você não fica horas pendurado nele;
- emitir algumas mensagens multimídia esquisitas;
- tentar se propagar para outros telefones.

A ativação do *bluetooth* não tem relação com a identificação de possíveis anexos maliciosos nas mensagens recebidas.

Errado.

023. (CESPE/TRE-GO/ANALISTA JUDICIÁRIO/2015) Acerca de procedimentos de segurança e de ensino a distância, julgue o item subsecutivo. Quanto à segurança da informação, sugere-se que se crie um disco de recuperação do sistema, assim como se desabilite a autoexecução de mídias removíveis e de arquivos anexados.



Todas as atividades mencionadas na questão são boas práticas de segurança. Um disco de recuperação de sistema pode ser usado para reiniciar o computador. Ele também contém ferramentas que podem ajudá-lo a recuperar o sistema operacional do computador de erros sérios ou restaurar o computador usando uma imagem do sistema.

A desativação da autoexecução de mídias removíveis e de arquivos anexados é um dos itens para que se evite a contaminação por *malwares* (códigos maliciosos).

Certo.

024. (CESPE/CADE/NÍVEL INTERMEDIÁRIO-NÍVEL MÉDIO/2014) Acerca dos conceitos de gerenciamento de arquivos e de segurança da informação, julgue o item subsequente. O computador utilizado pelo usuário que acessa salas de bate-papo não está vulnerável à infecção por worms, visto que esse tipo de ameaça não se propaga por meio de programas de chat.



O **malware (código malicioso)** do tipo **Worm** pode infectar máquinas desprotegidas, a partir da utilização de programas de *chat*. A contaminação pode acontecer, por exemplo, por meio de textos e fotografias enviados por meio do programa de chat, com o auxílio de encurtadores de URL. Caso uma pessoa clique em um dos endereços falsos, a máquina é contaminada automaticamente pelo *malware*, que em seguida pode se espalhar pela rede de contatos do usuário.



Figura. Bate-Papo

Para prevenção contra *worms*, mantenha o sistema operacional e demais *softwares* do equipamento sempre atualizados; aplique todas as correções de segurança (**patches**) disponibilizadas pelos fabricantes, para corrigir eventuais vulnerabilidades existentes nos *softwares* utilizados; instale um *firewall* pessoal, que **em alguns casos** pode evitar que uma vulnerabilidade existente seja explorada (**observe que o firewall não corrige as vulnerabilidades!**) ou que um *worm* se propague.

Errado.

025. (FCC/TRT – 14ª REGIÃO (RO E AC)/ANALISTA JUDICIÁRIO – ESTATÍSTICA/2018) Crime cibernético é todo crime que é executado online e inclui, por exemplo, o roubo de informações no meio virtual. Uma recomendação correta de segurança aos usuários da internet, para se proteger contra a variedade de crimes cibernéticos é

- a) usar a mesma senha (composta por letras maiúsculas e minúsculas, números e símbolos) em todos os sites com conteúdo de acesso restrito, mantendo esta senha protegida em um aplicativo de gerenciamento de senhas.
- b) manter os softwares atualizados, exceto os sistemas operacionais, pois estes já possuem mecanismos de segurança como firewall, antivírus e antispyware.
- c) gerenciar as configurações de mídias sociais para manter a maior parte das informações pessoais e privadas bloqueadas.
- d) proteger a rede wireless com senha que utiliza criptografia Wired Equivalent Privacy – WEP ou com uma Virtual Protect Network – VPN.
- e) usar uma suíte de segurança para a internet com serviços como firewall, blockwall e antivírus, como o LibreOffice Security Suit.



a) Errada. Alguns elementos que você **deve** usar na elaboração de suas senhas são: **números aleatórios; grande quantidade de caracteres; diferentes tipos de caracteres** (CERT. BR, 2013). Mais dicas:

- crie uma senha que contenha pelo menos oito caracteres, compostos de letras, números e símbolos.
- utilize **uma senha diferente para cada serviço** (por exemplo, uma senha para o banco, outra para acesso à rede corporativa da sua empresa, outra para acesso a seu provedor de Internet etc.);
- altere a senha com frequência;
- crie tantos usuários com privilégios normais, quantas forem as pessoas que utilizam seu computador;
- utilize o usuário *Administrator* (ou *root*) somente quando for estritamente necessário.

b) Errada. É importante fazer a instalação de *patches* de segurança e atualizações corretivas de softwares e do sistema operacional quando forem disponibilizadas.

c) Certa. Tal cuidado é de grande valia, principalmente no que diz respeito à segurança pessoal. Publicar fotos com uniforme escolar, que sugerem ostentação e os locais que costuma frequentar pode ser um grande atrativo para ações criminosas, por exemplo.

d) Errada. **WEP (Wired Equivalency Privacy – sigla de “Privacidade Equivalente à de Redes com Fios”)** foi a primeira tentativa de se criar um protocolo eficiente de proteção de redes WI-FI em 1997. Hoje é um protocolo **obsoleto no quesito segurança**. **WPA (Wi-Fi Protected Access – sigla de “Acesso Protegido a Wi-Fi”)** é um subconjunto dos padrões 802.11i, e serviu como um padrão de “transição” entre o WEP e o WPA2. O **WPA2 segue o padrão 802.11i e substitui formalmente o WEP**. Assim, é mais seguro do que o WEP!

Uma **VPN (Virtual Private Network – Rede Privada Virtual)** é uma rede **privada** (não é de acesso público!) que usa a infraestrutura de uma rede pública já existente (como, por exemplo, a **Internet**) para transferir seus dados (os dados devem estar **criptografados** para passarem despercebidos e inacessíveis pela Internet).

As VPNs são muito utilizadas para interligar filiais de uma mesma empresa, ou fornecedores com seus clientes (em negócios eletrônicos), por meio da estrutura física de uma rede pública. O tráfego de dados é levado pela rede pública utilizando protocolos não necessariamente seguros. e) Errada. LibreOffice Security Suit não é um produto existente no mercado.

Letra b.

026. (FCC/AL-PE/ANALISTA LEGISLATIVO – INFRAESTRUTURA/2014) Os programas antivírus:

I – Protegem contra phishing de páginas web quando o usuário está em navegação utilizando livremente o browser.

II – Protegem contra trojan embarcado em uma aplicação quando o usuário aceita a sua instalação em sua máquina.

III – Criptografam comunicações em rede, sejam elas por meio de envio de mensagens ou navegação na Internet através de browser.

IV – Protegem contra códigos maliciosos embutidos em macros, as quais são utilizadas por um software aplicativo ou utilitário do computador do usuário.

V – Previnem a instalação de aplicativos infectados, no momento da solicitação de sua instalação, ao gerarem um alerta sobre conteúdo suspeito ou ao bloquearem a operação de instalação.

Está correto o que se afirma APENAS em:

- a) I e II.
- b) II e III.
- c) III e IV.
- d) IV e V.
- e) II e V.



I – Errada. O tipo de golpe **Phishing** faz uso de pretextos falsos, na tentativa de enganar o receptor da mensagem, induzindo-o a fornecer informações sensíveis (como números de cartões de crédito, senhas, dados de contas bancárias, etc.). O antivírus não atuará nesse caso.

II – Errada. O antivírus não irá proteger contra **trojan** (cavalo de troia) embarcado em uma aplicação quando o usuário aceita a sua instalação em sua máquina.

Trojan horse (Cavalo de troia): é um programa aparentemente inofensivo que entra em seu computador na forma de cartão virtual, álbum de fotos, protetor de tela, jogo, etc., e que, quando executado (**com a sua autorização!**), parece lhe divertir, mas, por trás abre portas de comunicação do seu computador para que ele possa ser invadido.

III – Errada. As informações não são criptografadas com o antivírus.

IV – Certa. Faz proteção contra códigos maliciosos (*malwares*) embutidos em macros, as quais são utilizadas por um software aplicativo ou utilitário do computador do usuário.

V – Certa. Os antivírus previnem a instalação de aplicativos infectados, no momento da solicitação de sua instalação, ao gerarem um alerta sobre conteúdo suspeito ou ao bloquearem a operação de instalação.

Obs.: Nota: Mesmo tendo um antivírus atualizado, isso não garantirá que o arquivo será identificado e bloqueado. Mas um antivírus atualizado aumenta as chances de detecção desses programas.

Letra d.

027. (CESGRANRIO/PETROBRÁS/ANALISTA DE SISTEMAS PLENO – ESPECIALIDADE – INFRAESTRUTURA/2006) Assinale a afirmação INCORRETA sobre os firewalls e sistemas de detecção de intrusão (IDS – Intrusion Detection Systems).

- a) Os IDS podem ser utilizados para detectar e bloquear tentativas feitas por invasores para determinar as regras de filtragem de um firewall.
- b) Os IDS podem monitorar em tempo real os servidores de uma rede e/ou auditar os logs dos servidores à procura de padrões específicos de comportamento.
- c) Os IDS podem ser utilizados para detectar falhas de segurança em uma rede ou computadores antes mesmo que um ataque ou falha ocorra.
- d) Mesmo que os firewalls de uma rede estejam bem configurados, os sistemas IDS continuam necessários.
- e) Um firewall bem configurado deve responder a mensagens ICMP Echo Request.



Em um sistema em segurança de redes de computadores, a **intrusão** é qualquer conjunto de ações que tendem a comprometer a integridade, confidencialidade ou disponibilidade dos dados ou sistemas.

Os intrusos em uma rede podem ser de dois tipos: internos (que tentam acessar informações não autorizadas para ele); externos (tentam acessar informações via Internet).

IDS (Intrusion Detection Systems) são sistemas de detecção de intrusos, que têm por finalidade detectar atividades incorretas, maliciosas ou anômalas, em tempo real, permitindo que algumas ações sejam tomadas.

- Geram **logs** para casos de tentativas de ataques e para casos em que um ataque teve sucesso.
- Mesmo sistemas com Firewall devem ter formas para detecção de intrusos.
- Assim como os *firewalls*, os IDSs também podem gerar falsos positivos (Uma situação em que o firewall ou IDS aponta uma atividade como sendo um ataque, quando na verdade não é).

As informações podem ser coletadas em redes, de várias formas:

- Sistemas de detecção de intrusão **baseados em rede (NIDS)**

Neste tipo de sistema, as informações são coletadas na rede, normalmente por dispositivos dedicados que funcionam de forma similar a *sniffers* de pacotes.

Vantagens: diversas máquinas podem ser monitoradas utilizando-se apenas um agente (componente que coleta os dados).

Desvantagens: o IDS “enxerga” apenas os pacotes trafegando, sem ter visão do que ocorre na máquina atacada.

- Sistemas de detecção de intrusão **baseados em host (HIDS)**

Coletam informações dentro das máquinas monitoradas, o que normalmente é feito por meio de um software instalado dentro delas.

- **Hybrid IDS**

Combina as 2 soluções anteriores!!

Cabe ressaltar que o IDS (**Intrusion Detection Systems**) procura por ataques já catalogados e registrados, podendo, em alguns casos, fazer análise comportamental.

O *firewall* não tem a função de procurar por ataques. Ele realiza a filtragem dos pacotes e, então, bloqueia as transmissões não permitidas. O *firewall* atua entre a rede externa e interna, controlando o tráfego de informações que existem entre elas, procurando certificar-se de que este tráfego é confiável, em conformidade com a política de segurança do site acessado. Também pode ser utilizado para atuar entre redes com necessidades de segurança distintas.

O **IPS (Sistema de Prevenção de Intrusão)** é que faz a detecção de ataques e intrusões, e não o *firewall*!!! Um IPS é um sistema que detecta e obstrui automaticamente ataques computacionais a recursos protegidos. Diferente dos IDS tradicionais, que localizam e notificam os administradores sobre anomalias, um IPS defende o alvo sem uma participação direta humana.

Em outras palavras, **os IDS podem ser classificados em (importante):**

- **passivos:** fazem a análise das informações recebidas, SEM interferir no funcionamento da rede, comunicando os administradores em caso de alerta;
- **reativos:** chamados de **Intrusion Prevention Systems (IPS)**, pois, além de emitir o alerta, podem tomar contramedidas, como resetar conexões suspeitas e fazer reprogramações no firewall de acordo com a situação detectada.

IDS e IPS são sistemas que protegem a rede de intrusões, diferindo no tratamento dado quando uma intrusão é detectada. **IDS limita-se a gerar alertas e ativar alarmes, e o IPS executa contramedidas, como interromper o fluxo de dados referente à intrusão detectada.**

Um dos grandes desafios dos sistemas de detecção de intrusos é **Minimizar FALSOS POSITIVOS e FALSOS NEGATIVOS!**

- **Falso Positivo:** o IDS gera um alarme de ataque na ocorrência de um evento ou tráfego normal.
- **Falso Negativo:** o IDS não gera alarme na ocorrência de um evento ou tráfego mal intencionado.

Cabe destacar que o falso positivo é um evento observável e relevante, que é classificado pelo IDS como um **evento intrusivo!!**

Seu maior problema é a geração de um grande **número de alertas**, o que dificulta a administração e a análise das informações do IDS.

A ocorrência de falsos positivos normalmente acarreta consequências mais graves para as redes que utilizam IPS do que para aquelas que usam IDS!!

As consequências mais graves ocorrerão com a utilização do IPS, já que executa contramedidas, como resetar conexões suspeitas e fazer reprogramações no firewall de acordo com a situação detectada.

Após a análise da questão, vimos que a assertiva incorreta é a letra e.

Um firewall bem configurado irá restringir o ICMP Echo Request, quando o mesmo é solicitado a partir da Internet com destino ao perímetro da rede, pois esse protocolo pode ser utilizado por invasores para levantar informações do ambiente, de forma a descobrir máquinas na rede, dentre outros.

Letra e.

028. (CESPE/EMAP/ANALISTA PORTUÁRIO – TECNOLOGIA DA INFORMAÇÃO/2018) Acerca das boas práticas de segurança da informação, julgue o item subsequente. O dispositivo de IPS (do inglês intrusion prevention system) utilizado em redes corporativas tem como objetivo bloquear ataques a partir da identificação de assinaturas e(ou) anomalias.



Quanto ao **MÉTODO DE DETECÇÃO** utilizado, os IDS podem ser dos seguintes **tipos** (STRINGFIXER, 2020):

Baseado em Anomalias	Criado principalmente para detectar ataques desconhecidos, em parte devido ao rápido desenvolvimento de malwares. Um IDS baseado em anomalia monitorará o tráfego da rede e o comparará com uma linha de base estabelecida. A abordagem básica é utilizar o aprendizado de máquina para criar um modelo de atividade confiável e comparar o novo comportamento com o modelo confiável.
Baseado em Assinaturas	Monitora pacotes na rede e os compara com padrões de ataques pré-configurados e predeterminados , conhecidos como assinaturas . Embora o IDS baseado em assinatura possa detectar facilmente ataques conhecidos, não é capaz de detectar novos ataques.

Certo.

029. (FCC/TRF – 3ª REGIÃO/ANALISTA JUDICIÁRIO – INFORMÁTICA/2014) Os responsáveis pela Segurança da Informação do TRF da 3ª Região foram encarregados de produzir dois documentos:

1. Documenta procedimentos de gerenciamento, desenhados para manter ou recuperar operações de negócio, incluindo operações de computadores, no caso de eventuais emergências, desastres ou falhas de sistemas. É elaborado para situações em que exista perda de recursos, porém, esses recursos podem ser recuperados de uma forma menos traumática.

2. Documenta uma série de instruções ou procedimentos pré-determinados que descrevam como as funções de negócios da organização serão sustentadas durante e após uma interrupção significativa. É elaborado para possibilitar que a organização funcione em um nível aceitável para sua sobrevivência e absorva possíveis impactos financeiros, operacionais e de imagem.

Os documentos 1 e 2 são, respectivamente,

- a) Plano de Emergência e Política de Segurança da Informação.
- b) Plano de Contingência e Plano de Continuidade de Negócios.
- c) Plano de Administração de Crises e Plano de Auditoria.
- d) Política de Recuperação de Desastres e Política de Segurança da Informação.
- e) Plano de Continuidade Operacional e Plano de Negócios.



Observe que inicialmente já conseguimos eliminar os itens Política de Segurança da Informação, Plano de Negócios e Plano de Auditoria. Sobrou, então, a letra B.

- a) Errada. Plano de Emergência e **Política de Segurança da Informação**.
- c) Errada. Plano de Administração de Crises e **Plano de Auditoria**.
- d) Errada. Política de Recuperação de Desastres e **Política de Segurança da Informação**.
- e) Errada. Plano de Continuidade Operacional e **Plano de Negócios**.

Plano de Contingência	Documenta procedimentos de gerenciamento, desenhados para manter ou recuperar operações de negócio, incluindo operações de computadores, no caso de eventuais emergências, desastres ou falhas de sistemas. É elaborado para situações em que exista perda de recursos, porém, esses recursos podem ser recuperados de uma forma menos traumática.
Plano de Continuidade de Negócios	Documenta uma série de instruções ou procedimentos predeterminados que descrevam como as funções de negócios da organização serão sustentadas durante e após uma interrupção significativa. É elaborado para possibilitar que a organização funcione em um nível aceitável para sua sobrevivência e absorva possíveis impactos financeiros, operacionais e de imagem.

Letra b.

030. (FCC/TRE-CE/TÉCNICO JUDICIÁRIO/PROGRAMAÇÃO DE SISTEMAS/2012) Sobre segurança da informação, analise:

I – É obtida a partir da implementação de um conjunto de controles adequados, incluindo políticas, processos, procedimentos, estruturas organizacionais e funções de software e hardware.

II – A interconexão de redes públicas e privadas e o compartilhamento de recursos de informação aumentam a dificuldade de se controlar o acesso. A tendência da computação distribuída aumenta a eficácia da implementação de um controle de acesso centralizado.

III – Os controles de segurança precisam ser estabelecidos, implementados, monitorados, analisados criticamente e melhorados, onde necessário, para garantir que os objetivos do negócio e de segurança da organização sejam atendidos. Convém que isto seja feito em conjunto com outros processos de gestão do negócio.

IV – É importante para os negócios, tanto do setor público como do setor privado, e para proteger as infraestruturas críticas. Em ambos os setores, a função da segurança da informação é viabilizar os negócios como o governo eletrônico (e-gov) ou o comércio eletrônico (e-business), e evitar ou reduzir os riscos relevantes.

Está correto o que consta em

- a) I, II, III e IV.
- b) I, III e IV, apenas
- c) I e IV, apenas.
- d) III e IV, apenas.
- e) I e II, apenas.



A única assertiva indevida é a II. A tendência da computação distribuída REDUZ a eficácia da implementação de um controle de acesso centralizado.

Letra b.

031. (FCC/ TRT – 12ª REGIÃO (SC)/ANALISTA JUDICIÁRIO – TECNOLOGIA DA INFORMAÇÃO/2013)
Luiza trabalha em uma empresa com 500 funcionários. A empresa tem centenas de computadores com placas de rede conectando-os. A empresa também tem uma ou mais conexões de alta velocidade com a internet. Luiza foi contratada para evitar que um *hacker* possa sondar esses computadores, tentar estabelecer conexões FTP com eles, fazer conexões *telnet* e assim por diante. Ainda, se um funcionário cometer um erro e deixar uma vulnerabilidade na segurança, Luiza deve evitar que os *hackers* possam chegar nessa máquina e explorar essa fraqueza.

Para evitar esta situação de risco, Luiza deve instalar na rede um

- a) sistema de criptografia assimétrica.
- b) *firewall* em cada conexão com a internet.
- c) filtro de conteúdo de e-mails.
- d) poderoso antivírus.
- e) sistema de criptografia simétrica.



Para evitar esta situação de risco, Luiza deve instalar na rede um **firewall**, em cada conexão com a internet, para evitar acessos não autorizados à sua rede local.

Letra b.

032. (FCC/TCE-CE/ANALISTA DE CONTROLE EXTERNO – AUDITORIA DE TECNOLOGIA DA INFORMAÇÃO/2015) Uma Política de Tratamento de Incidentes de Segurança da Informação deve conter um procedimento padronizado para o tratamento de incidentes que compreende, nesta ordem, as etapas:

1. Recepção da denúncia ou alerta interno de atividade suspeita, 2. Medidas de contenção imediata do incidente,
- a) 3. Definição do Plano de ação; 4. Coleta de informações e evidências; 5. Notificação do incidente ao CGI.br; 6. Notificação dos envolvidos.
- b) 3. Notificação dos envolvidos; 4. Aplicação de solução de contorno; 5. Aplicação de solução de contenção definitiva; 6. Definição das lições aprendidas.
- c) 3. Coleta de informações e evidências; 4. Análise das informações e evidências; 5. Notificação dos envolvidos; 6. Análise crítica e determinação das medidas corretivas.
- d) 3. Definição do Plano de ação; 4. Aplicação de solução de contorno; 5. Classificação do incidente; 6. Notificação dos envolvidos.
- e) 3. Coleta de informações e evidências; 4. Análise crítica e aplicação de medidas corretivas; 5. Análise das informações e evidências; 6. Notificação dos envolvidos.



Uma **Política de Tratamento de Incidentes de Segurança da Informação** deve conter um procedimento padronizado para o tratamento de incidentes que compreende, nesta ordem, as seguintes etapas:

1. Recepção da denúncia ou alerta interno de atividade suspeita,
2. Medidas de contenção imediata do incidente,
3. Coleta de informações e evidências;
4. Análise das informações e das evidências;
5. Notificação dos envolvidos;
6. Análise crítica e determinação das medidas corretivas.

Leitura recomendada: Veja a seguir uma matéria interessante sobre os CSIRTs: <https://technet.microsoft.com/pt-br/Library/cc700825.aspx>

Letra c.

033. (CESPE/TCE RN/ASSESSOR TÉCNICO DE INFORMÁTICA – CONTROLE EXTERNO/2015) Julgue os próximos itens, referentes à prevenção e tratamento de ataques a redes de computadores. A fim de tratar os incidentes de segurança, a equipe de tratamento e resposta a incidentes nas redes computacionais de uma organização deve apresentar os serviços: resposta, triagem, coordenação de incidentes em redes computacionais e emissão de boletins de segurança.



Incidente de segurança é qualquer evento adverso, confirmado ou sob suspeita, relacionado à segurança dos sistemas de computação ou das redes de computadores

Segundo http://dsic.planalto.gov.br/documentos/nc_05_etir.pdf, a **Equipe de Tratamento e Resposta a Incidentes em Redes Computacionais – ETIR** – é um grupo de pessoas com a responsabilidade de receber, analisar e responder às notificações e atividades relacionadas a incidentes de segurança em redes de computadores.

Tratamento de Incidentes de Segurança em Redes Computacionais: é o serviço que consiste em receber, filtrar, classificar e responder às solicitações e alertas e realizar as análises dos incidentes de segurança, procurando extrair informações que permitam **impedir a continuidade** da ação maliciosa e também a identificação de tendências.

Veja mais:

- http://dsic.planalto.gov.br/documentos/nc_05_etir.pdf
- <http://www.gsi.gov.br/arquivos/centro-de-tratamento-de-incidentes-de-seguranca-de-redes-de-computadores-da-apf-ctir-gov>

Certo.

034. (CESPE/MEC/GERENTE DE SEGURANÇA/2015) Em relação à política de segurança da informação e à gestão de continuidade do negócio, julgue o item a seguir.

A política de informação deve ser escrita e assinada pelo chefe da SOC (security operation center), responsável máximo pela informação organizacional, que, durante a escrita desse documento, deverá ouvir as demais áreas institucionais, de modo a incrementar a audiência e o entendimento do funcionamento da organização.



A Política de segurança da informação deve ser estabelecida pela alta direção da organização. O **Security Operations Center (SOC) – ou Centro de Operações de Segurança** irá prestar serviços de detecção e reação a incidentes de segurança.

Errado.

035. (FCC/MPE-PE/ANALISTA MINISTERIAL – INFORMÁTICA/2018) Estabelecer um plano de continuidade de negócios é primordial para as empresas, sendo que o plano de continuidade é constituído de subplanos. O subplano estabelecido para ser utilizado em último caso quando todas as prevenções tiverem falhado é conhecido como Plano de

- a) Gerenciamento de Crises.
- b) Contingência.
- c) Recuperação de Desastres.
- d) Administração.
- e) Continuidade Operacional.



Um **Plano de Continuidade de Negócios** pode ser estruturado em **quatro outros planos ligados entre si**, cada qual criado para cuidar de um estágio diferente. **São eles:**

1. Plano de Contingência ou Emergência (PC): deve ser utilizado em último caso, quando todas as prevenções tiverem falhado. Define as necessidades e ações mais imediatas.

2. Plano de Administração ou Gerenciamento de Crises (PAC): define funções e responsabilidades das equipes envolvidas com o acionamento das ações de contingência, antes durante e após a ocorrência.

3. Plano de Continuidade Operacional (PCO): seu objetivo é reestabelecer o funcionamento dos principais ativos que suportam as operações de uma empresa, reduzindo o tempo de queda e os impactos provocados por um eventual incidente. Um exemplo simples é a queda de conexão à internet.

4. Plano de Recuperação de Desastres (PRD): determina o planejamento para que, uma vez controlada a contingência e passada a crise, a empresa retome seus níveis originais de operação.

Letra b.

036. (INSTITUTO ACCESS/INSTITUTO DE ACESSO À EDUCAÇÃO, CAPACITAÇÃO PROFISSIONAL E DESENVOLVIMENTO HUMANO – PREFEITURA DE DOMINGOS MARTINS/TÉCNICO DE INFORMÁTICA/2024) Sobre as cópias de segurança (backups), é correto afirmar que

- a) os backups são apenas necessários para grandes empresas, não para usuários individuais.
- b) os backups devem ser realizados apenas quando ocorrer uma falha no sistema.
- c) o backup incremental consiste na realização de uma cópia de segurança dos dados que foram alterados desde a última operação de backup.
- d) é recomendável armazenar cópias de segurança exclusivamente em discos rígidos locais para facilitar o acesso.



a) Errada. *Backups* são necessários para todos, sejam empresas ou usuários individuais, pois ambos estão sujeitos a falhas, perdas de dados e ataques. O *backup* protege informações críticas, independente do seu ambiente de uso.

- b) Errada. *Backups* devem ser realizados de forma **regular** e preventiva, não apenas após falhas no sistema. *Backup* reativo impossibilita a recuperação de dados anteriores ao evento.
- c) Certa. O *backup* incremental faz a cópia somente dos dados **alterados ou criados desde o último backup**, otimizando o armazenamento e o tempo de execução.
- d) Errada. Não é recomendável armazenar *backups* **exclusivamente** em discos rígidos locais, pois eles ficam sujeitos aos mesmos riscos (roubo, falhas físicas, incêndio). É necessário diversificar, com backups externos ou na nuvem (*offsite*).

Letra c.

037. (COSEAC UFF/INSPETOR DE POLÍCIA PENAL/SEAP RJ/2025) Ana fez o backup dos arquivos de trabalho dos dias pares do seu computador utilizando uma mídia removível por meio dos comandos “copiar e colar” do sistema operacional. Nesse caso ela utilizou um backup do tipo

- a) diferencial.
- b) diário.
- c) incremental.
- d) de cópia.
- e) normal.



O **backup de cópia**, também conhecido como “cópia pontual” ou “cópia de segurança auxiliar”, refere-se a *backups* fora da rotina programada, sem alterar os atributos dos arquivos (como a marcação do arquivo). O uso de “copiar e colar” para criar manualmente uma cópia dos arquivos é uma operação típica de **backup de cópia**.

Cópia (Auxiliar ou Secundária)	- Faz o <i>backup</i> de arquivos e pastas selecionados. - O atributo de arquivamento (arquivo morto) NÃO É ALTERADO: não limpa os marcadores!
--------------------------------	--

Letra d.

038. (IADES/SEASTER-PA/TÉCNICO DE ENFERMAGEM/2019) Acerca dos procedimentos de segurança que devem ser adotados ao utilizar-se um computador, assinale a alternativa correta.

- a) Não é recomendável utilizar CD-ROM para gravar cópias de arquivos.
- b) Cópias de segurança de arquivos confiáveis devem ser feitas, mas somente em servidores on-line.
- c) Qualquer arquivo importante deve ser copiado, seja ele confiável ou infectado.
- d) Toda cópia de arquivo é confiável.
- e) A manutenção de cópias de segurança redundantes de arquivos importantes é recomendável.



Backup é um procedimento através do qual são criadas cópias de arquivos de dados importantes que poderão ser recuperadas caso aconteça algum imprevisto com os arquivos originais.

Para a realização de um backup, podemos utilizar: pen drive, CD, DVD, HD externo, pastas compartilhadas na rede, armazenamento na nuvem ou “cloud storage” (uso do OneDrive – antigo SkyDrive, Dropbox, ou outro ambiente), Fitbit, etc.

Seja ele qual for a sua escolha, todos têm a mesma finalidade. **A diferença está na capacidade, vida útil e segurança de cada um.** Não é aconselhável o uso de outra partição do HD principal ou HD Interno, pois se acontecer algum problema com a máquina, todos os dados (originais e backup) serão perdidos.

A cópia de segurança dos dados do usuário (ou *backup*), poderá estar corrompida quando for necessária a restauração.

Assim, uma das recomendações é **manter cópias redundantes (duplicadas) de arquivos importantes. Para maior segurança é sempre recomendável que as cópias sejam armazenadas em locais diferentes dos arquivos originais.**

Por exemplo uma cópia pode estar em um HD local e a outra na nuvem. As chances de perda da cópia de segurança serão mínimas nesse contexto.

Letra e.

039. (FGV/TECNOLOGO/FUNSAÚDE CE/SUPORTE OPERACIONAL EM HARDWARE E SOFTWARE/2021) Leia o fragmento a seguir.

“X.509 é um padrão importante porque a estrutura de certificado e os protocolos de autenticação definidos nele são usados em diversos contextos. O núcleo do esquema X.509 é o certificado de ____ associado a cada usuário. Esses certificados do usuário são considerados como sendo criados por alguma ____ confiável e colocados no diretório pela CA ou pelo usuário. O próprio ____ não é responsável pela criação das chaves públicas ou pela função de certificação; ele simplesmente oferece um local de fácil acesso para os usuários obterem certificados”.

Assinale a opção cujos itens completem corretamente as lacunas do fragmento acima.

- a) confiabilidade – instituição – usuário.
- b) segurança cibernética – empresa – servidor de segurança.
- c) transparência digital – autoridade certificadora – administrador.
- d) chave privada – autarquia – servidor de autenticação.
- e) chave pública – autoridade certificadora – servidor de diretório.



O núcleo do **esquema X.509** é o certificado de **CHAVE PÚBLICA** associado a cada usuário. Esses certificados do usuário são considerados como sendo criados por alguma **AUTORIDADE CERTIFICADORA** confiável e colocados no diretório pela CA ou pelo usuário. O próprio **SERVIDOR DE DIRETÓRIO** não é responsável pela criação das chaves públicas ou pela função de certificação; ele simplesmente oferece um local de fácil acesso para os usuários obterem certificados”.

X – 509 é um formato padrão para **certificados de chave pública**, documentos digitais que associam com segurança pares de chaves criptográficas a identidades como sites, indivíduos ou organizações.

Veja mais:

<https://www.ssl.com/pt/faqs/o-que-%C3%A9-um-certificado-x-509/#>

Letra e.

040. (FGV/IBGE/ANALISTA CENSITÁRIO – ANÁLISE DE SISTEMAS – SUPORTE À COMUNICAÇÃO E REDE/2017) Analise as afirmativas a seguir em relação à criptografia assimétrica:

I – O uso de criptografia assimétrica evita ataques baseados na técnica de Man-in-the-middle.

II – Criptografia por curvas elípticas é uma forma de implementação de criptografia por chave pública.

III – A criptografia assimétrica pode ter sua eficiência aumentada por meio do uso de cifras de fluxo.

Está correto somente o que se afirma em:

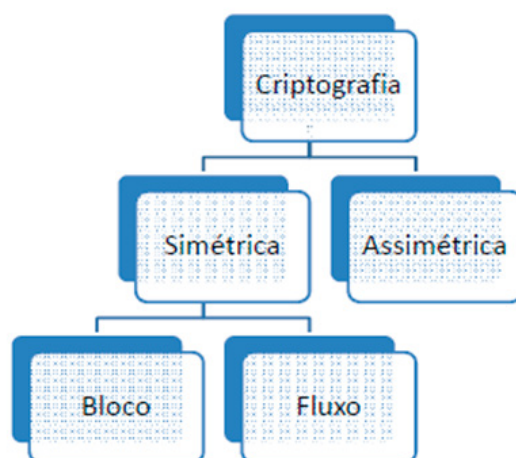
- a) I;
- b) II;
- c) III;
- d) I e II;
- e) I e III.



I – Errada. No ataque **Man-in-the-middle (MITM)** o invasor se posiciona entre duas partes que tentam comunicar-se, intercepta mensagens enviadas e depois se passa por uma das partes envolvidas. A criptografia não evita o ataque MITM, pois os dados podem ser interceptados, apesar de estarem cifrados.

II – Certa. **Criptografia por curvas elípticas** é uma variante da criptografia assimétrica ou de chave pública, baseada na matemática das curvas elípticas. Provê a maioria das funcionalidades do RSA, só que utilizando menos recursos.

III – Errada. As **Cifras de fluxo** são um tipo de **algoritmos de chave privada (chave simétrica)**. **Cifra de fluxo:** é um algoritmo de codificação simétrico que não utiliza bloco fixo, criptografando a informação no tamanho em que ela for recebida. Segundo Stallings (2008) uma cifra de fluxo é aquela que codifica um fluxo de dados digital um bit ou um byte de cada vez!



Letra b.

041. (FGV/ALERJ/ESPECIALISTA LEGISLATIVO/TECNOLOGIA DA INFORMAÇÃO/2017) O protocolo SSL (Secure Sockets Layer) combina as criptografias assimétrica e simétrica para garantir a confidencialidade e a autenticidade na comunicação entre computadores na Internet. São exemplos, respectivamente, de algoritmos de criptografia assimétrica e simétrica:

- a) SHA e RSA;
- b) IDEA e SHA;
- c) RSA e MD5;
- d) AES e DES;
- e) RSA e IDEA.



Alguns algoritmos de *hash*: **MD4**, **MD5**, **SHA-1**, SHA-256, TIGER, etc.

Existem vários algoritmos que usam **chaves simétricas**, como:

- **DES** (Data Encryption Standard),
- **IDEA** (International Data Encryption Algorithm),
- **RC** (Ron's Code ou Rivest Cipher)
- **AES** (*Advanced Encryption Standard*) – que é baseado no DES;
- **3DES**,
- **Twofish** e sua **variante Blowfish**, por exemplo.

Entre os algoritmos que usam **chaves assimétricas** têm-se;

- **RSA** (o mais conhecido),
- **DSA** (Digital Signature Algorithm),
- Schnorr (praticamente usado apenas em assinaturas digitais);
- **Diffie-Hellman**.

Assim, temos:

- a) Errada. SHA (Hash) e RSA (Assimétrico).
- b) Errada. IDEA (Simétrico) e SHA (Hash).
- c) Errada. RSA (Assimétrico) e MD5 (Hash).
- d) Errada. AES (Simétrico) e DES (Simétrico).
- e) Certa. RSA (Assimétrico) e IDEA (Simétrico).

São exemplos, respectivamente, de algoritmos de criptografia assimétrica e simétrica: RSA e IDEA, o que torna a letra E a resposta da questão.

Letra e.

042. (FGV/TCM-SP/AGENTE DE FISCALIZAÇÃO – TECNOLOGIA DA INFORMAÇÃO/2015) Pedro quer enviar uma mensagem para Maria, porém o sigilo é importante nesta comunicação. Somente Maria deve ser capaz de ler a mensagem. Por outro lado, Maria precisa ter a garantia de que a mensagem foi enviada por Pedro. Para garantir a autenticação do autor e a confidencialidade dos dados, será necessário utilizar:

- a) dois algoritmos fortes de criptografia simétrica;
- b) criptografia simétrica para garantir a autoria e assimétrica para ciframento dos dados;
- c) dois pares de chaves públicas e privadas;
- d) criptografia assimétrica para assinatura digital;
- e) assinatura digital para autoria e um algoritmo de hashing para assegurar a confidencialidade.



Como somente Maria deve ser capaz de ler a mensagem, Pedro utilizará a chave pública de Maria na origem, para cifrar o texto, e Maria utilizará a chave privada dela para decifrar a mensagem. Por outro lado, Maria precisa ter a garantia de que a mensagem foi enviada por Pedro. Então Pedro na origem irá criptografar a mensagem também com a chave privada dele, e, no destino, Maria com a chave pública de Pedro, conseguirá abrir a mensagem, tendo a garantia de que a mensagem foi enviada por Pedro.

Assim, nesse contexto será utilizada a criptografia assimétrica, com dois pares de chaves públicas e privadas.

Letra c.

043. (FCC/ICMS-RJ/AUDITOR FISCAL DA RECEITA ESTADUAL/2014) A política de segurança da informação da Receita Estadual inclui um conjunto de diretrizes que determinam as linhas mestras que devem ser seguidas pela instituição para que sejam assegurados seus recursos computacionais e suas informações. Dentre estas diretrizes encontram-se normas que garantem

I. a fidedignidade de informações, sinalizando a conformidade dos dados armazenados com relação às inserções, alterações e processamentos autorizados efetuados. Sinalizam, ainda, a conformidade dos dados transmitidos pelo emissor com os recebidos pelo destinatário, garantindo a não violação dos dados com intuito de alteração, gravação ou exclusão, seja ela acidental ou proposital.

II. que as informações estejam acessíveis às pessoas e aos processos autorizados, a qualquer momento requerido, assegurando a prestação contínua do serviço, sem interrupções no fornecimento de informações para quem é de direito.

III. que somente pessoas autorizadas tenham acesso às informações armazenadas ou transmitidas por meio das redes de comunicação, assegurando que as pessoas não tomem conhecimento de informações, de forma acidental ou proposital, sem que possuam autorização para tal procedimento.

Em relação às informações, as normas definidas em **I**, **II** e **III** visam garantir

- a) fidedignidade, acessibilidade e disponibilidade.
- b) integridade, disponibilidade e confidencialidade.
- c) confidencialidade, integridade e autenticidade.
- d) integridade, ininterruptibilidade e autenticidade.
- e) confidencialidade, integridade e disponibilidade.



A análise das diretrizes mencionadas nos itens **I**, **II** e **III** da política de segurança da informação da Receita Estadual revela que cada uma está associada a um dos três principais princípios da segurança da informação: integridade, disponibilidade e confidencialidade. Vamos ver como cada item se relaciona com esses princípios:

Item	Princípio	Característica
I	Integridade	Item I descreve a fidedignidade das informações, garantindo que os dados armazenados sejam consistentes e correspondam às operações autorizadas. Isso está relacionado com o princípio da integridade , que assegura que os dados não sejam alterados de forma não autorizada ou acidental. É a garantia de que a informação que foi armazenada é a que será recuperada. A integridade busca proteção contra codificação não autorizada. Modificação deve ser realizada somente pelas partes devidamente autorizadas.
II	Disponibilidade	Item II trata da acessibilidade das informações para pessoas e processos autorizados, a qualquer momento. Isso se refere ao princípio da disponibilidade , garantindo que as informações estejam disponíveis quando necessário. Busca acesso disponível às entidades autorizadas sempre que necessário .
III	Confidencialidade (ou sigilo)	Item III aborda o acesso às informações exclusivamente por pessoas autorizadas, prevenindo acessos não autorizados, acidentais ou intencionais. Esse é o princípio da confidencialidade. É a garantia de que a informação não será conhecida por quem não deve. O acesso às informações deve ser limitado, ou seja, somente as pessoas explicitamente autorizadas podem acessá-las .

Portanto, as normas definidas em I, II e III visam garantir, respectivamente, integridade, disponibilidade e confidencialidade. A resposta correta é:

b) integridade, disponibilidade e confidencialidade.

Letra b.

044. (INÉDITA/2025) Os graus de sigilo das informações são determinados exclusivamente pela quantidade de dados armazenados, sem considerar a sensibilidade ou o potencial impacto de sua divulgação.



Os graus de sigilo são determinados com base na sensibilidade das informações e no impacto potencial de sua divulgação não autorizada, não apenas na quantidade de dados.

Errado.

045. (INSTITUTO VERBENA/ASSISTENTE/CM ANÁPOLIS/ADMINISTRATIVO/TÉCNICO DE INFORMÁTICA/2024) A manutenção preventiva, tem por objeto a prevenção de paneiras ou situações que comprometam o correto funcionamento de um computador. O tipo mais comum de manutenção preventiva utilizado para garantir a segurança contra ataques de malwares ou outro tipo de vírus é a

- a) atualização do antivírus.
- b) troca da placa mãe.
- c) nova instalação do sistema operacional.
- d) troca da impressora.



A resposta correta para o tipo mais comum de manutenção preventiva utilizado para garantir a segurança contra ataques de malwares ou outros tipos de vírus é:

- a) Certa. A atualização regular do software antivírus é fundamental para proteger um computador contra malwares e vírus. Isso porque os softwares antivírus dependem de definições de vírus atualizadas para detectar e neutralizar novas ameaças. Manter o antivírus atualizado é uma prática essencial de manutenção preventiva que ajuda a garantir que o sistema esteja protegido contra as ameaças mais recentes.
- b) Errada. Trocar a placa mãe não está relacionada à proteção contra malwares ou vírus. Este tipo de manutenção é mais relevante em casos de falhas de hardware ou atualização de componentes, mas não tem impacto direto na segurança contra ameaças de software.
- c) Errada. Embora reinstalar o sistema operacional possa remover malwares existentes, não é uma prática preventiva, mas sim corretiva. É usada quando o sistema já foi comprometido ou apresenta problemas graves.

d) Errada. A troca da impressora não tem relação com a segurança do computador contra malwares ou vírus. Este tipo de manutenção seria relevante apenas em casos onde a impressora apresenta defeitos ou precisa ser atualizada por outras razões, mas não afeta diretamente a proteção do sistema contra ameaças de software.

Portanto, manter o antivírus atualizado é a prática preventiva adequada para proteger o computador contra malwares.

Letra a.

046. (INÉDITA/2025) A capacidade de um agente de segurança de agir com discrição pode contribuir para identificar ameaças potenciais sem alertar os agressores ou pessoas não autorizadas.



A discrição permite que agentes de segurança observem e avaliem situações de forma eficaz e sem chamar a atenção, aumentando a chance de detectar e mitigar ameaças potenciais de maneira eficiente.

Certo.

047. (INÉDITA/2025) A discrição nas atividades de segurança da informação implica que todos os funcionários devem ter acesso irrestrito a dados sensíveis para garantir a transparência dentro da organização.



A discrição requer que apenas pessoas autorizadas tenham acesso a informações sensíveis, garantindo proteção contra acessos não autorizados e mantendo a confidencialidade dos dados.

Errado.

048. (PUC PR/ANALISTA DE INFORMÁTICA/DPE PR/2012) Política de segurança que define como são tratadas as informações institucionais, indicando se elas podem ser repassadas a terceiros.

Está-se falando:

- a) Política de privacidade.
- b) Política de confidencialidade.
- c) Política de backup.
- d) Política de termo de uso.
- e) Política de quebra de sigilo.



Vamos definir as políticas apresentadas:

- a) Errada. A **política de privacidade** define **como são tratadas as informações pessoais**, sejam elas de clientes, usuários ou funcionários.
- b) Certa. Uma política de confidencialidade **define como são tratadas as informações institucionais**, ou seja, se elas podem ser repassadas a terceiros.
- c) Errada. Uma política de backup define as **regras sobre a realização de cópias de segurança**, como tipo de mídia utilizada, período de retenção e frequência de execução.
- d) Errada. Os termos de serviço (também conhecidos como termos de uso e termos e condições **definem as regras de uso dos recursos computacionais, os direitos e as responsabilidades de quem os utiliza e as situações que são consideradas abusivas**).
- e) Errada. Conforme visto, não existe essa política específica dentro da política de segurança.

Letra b.

049. (FGV/BANESTES/ANALISTA EM TECNOLOGIA DA INFORMAÇÃO/SEGURANÇA DA INFORMAÇÃO/2021) Um pequeno dispositivo que contém um código de proteção precisa necessariamente ficar conectado à porta USB do computador para que determinado software possa ser utilizado.

Esse dispositivo utilizado para prevenir o uso não autorizado de determinado software é conhecido como:

- a) Vault;
- b) Keycloak;
- c) KeePass;
- d) Keylogger;
- e) Hardlock.



O *hardlock* é um dispositivo de segurança que se conecta pela porta USB do seu computador, sendo utilizado para prevenir o uso não autorizado de determinado aplicativo.

Letra e.

050. (FGV/BANESTES/ANALISTA EM TECNOLOGIA DA INFORMAÇÃO – SEGURANÇA DA INFORMAÇÃO/2021) Monitorar e auditar o tráfego de informação corporativa é uma prática comumente utilizada por organizações para detectar atividades não autorizadas de processamento da informação.

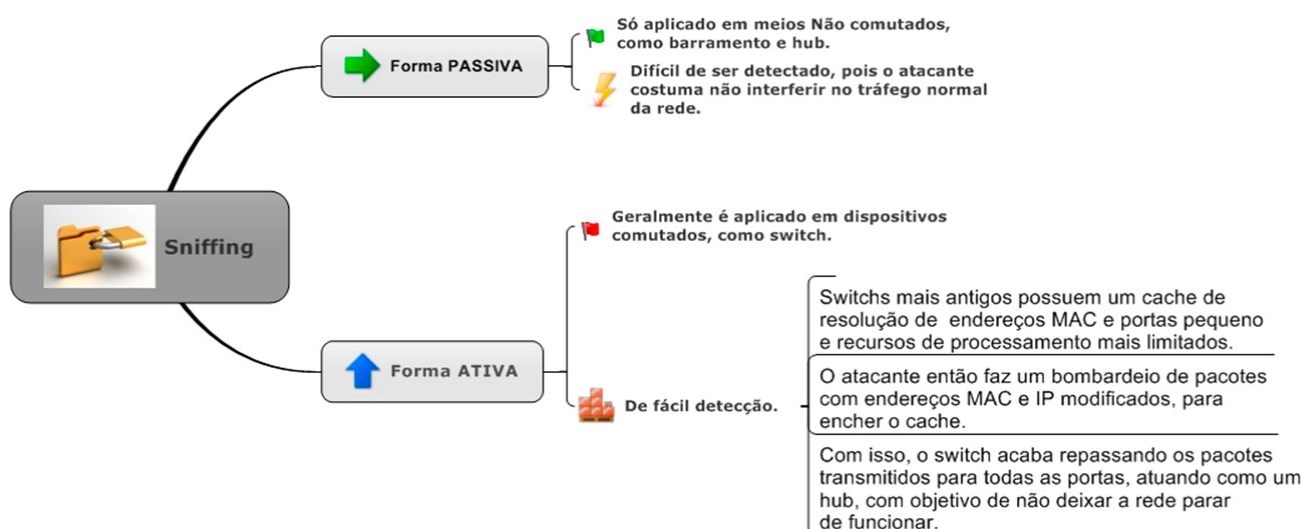
A técnica utilizada nas atividades de gerência para capturar e interpretar as informações sobre aquilo que trafega em cada segmento de rede é:

- a) NTP;
- b) SMI;
- c) Kibana;
- d) Sniffing;
- e) Vishing.



Sniffing é:

o processo de captura das informações da rede por meio de um software de escuta de rede (conhecido como **sniffer**, **farejador** ou ainda **capturador de pacote**), capaz de interpretar as informações transmitidas no meio físico.



Letra d.

051. (FGV/DPE-RJ/TÉCNICO SUPERIOR ESPECIALIZADO – GESTÃO EM TECNOLOGIA DA INFORMAÇÃO/2014) Você é o responsável pela segurança de informação da organização em que trabalha e recebeu um e-mail automático do sistema de controle de acesso dos servidores da empresa informando que houve um 'evento inesperado com probabilidade de ameaçar a segurança da informação'. Nesse contexto, é correto afirmar que, de acordo com a NBR ISO/IEC 27001, houve

- a) um problema de indisponibilidade de ao menos um dos servidores.
- b) um incidente de segurança da informação.
- c) a detecção de uma vulnerabilidade nos servidores.
- d) a ocorrência de um risco.
- e) uma falha na segurança da informação.



De acordo com a NBR ISO/IEC 27001, **incidente de segurança da informação** é “um **simples** ou uma série de **eventos de segurança da informação** indesejados ou **inesperados**, que tenham uma **grande probabilidade de** comprometer as operações do negócio e **ameaçar a segurança da informação**”. Assim, o evento inesperado com probabilidade de ameaçar a segurança da informação é considerado um incidente de segurança da informação.

Letra b.

052. (FGV/ALERJ/ESPECIALISTA LEGISLATIVO – TECNOLOGIA DA INFORMAÇÃO/2017) Ataques cibernéticos podem causar graves prejuízos a pessoas e empresas. Recentemente João recebeu uma mensagem de alerta por e-mail com um pedido para ele atualizar seus dados cadastrais na página do seu Internet Banking.

João não prestou muita atenção em quem enviou a mensagem, nem se era um remetente confiável, e clicou no link presente no corpo do e-mail, que o levou para uma página web, réplica do website real criada por um cyber criminoso.

Como a mensagem de e-mail e o website eram muito bem elaborados, João acreditou estar acessando algo verdadeiro e informou suas credenciais para acesso, quando na verdade ele as entregou a um criminoso.

João foi vítima de um ataque cibernético denominado:

- a) DDoS;
- b) sniffer;
- c) spam;
- d) phishing;
- e) spoofing.



a) Errada. No **ataque de negação de serviço (denial of service – DoS)** o atacante utiliza um computador para tirar de operação um serviço ou computador(es) conectado(s) à Internet!! No **ataque de negação de serviço distribuído (DDoS)**, um conjunto de computadores é utilizado para tirar de operação um ou mais serviços ou computadores conectados à Internet.

b) Errada. **Sniffer** é uma ferramenta capaz de interceptar e registrar o tráfego de dados em uma rede de computadores.

c) Errada. **Spams** são mensagens de correio eletrônico não autorizadas ou não solicitadas pelo destinatário, geralmente de conotação publicitária ou obscena. **Anti-spam**: ferramenta utilizada para filtro de mensagens indesejadas.

d) Certa. **Phishing** (também conhecido como *Phishing scam*, ou apenas *scam*) é um tipo de fraude eletrônica projetada para roubar informações particulares que sejam valiosas para cometer um roubo ou fraude posteriormente. João foi vítima de um ataque cibernético desse tipo. O golpe de phishing é realizado por uma pessoa mal-intencionada através da

criação de um website falso e/ou do envio de uma mensagem eletrônica falsa, geralmente um e-mail ou recado através de redes sociais, entre outros exemplos. Utilizando de pretextos falsos, tenta enganar o receptor da mensagem e induzi-lo a fornecer informações sensíveis (números de cartões de crédito, senhas, dados de contas bancárias, entre outras).

A palavra *phishing* (de *fishing*) vem de uma analogia criada pelos fraudadores, em que “iscas” (e-mails) são usadas para “pescar” informações sensíveis (senhas e dados financeiros, por exemplo) de usuários da Internet.

Atualmente, este termo vem sendo utilizado também para se referir aos seguintes casos:

- mensagem que procura induzir o usuário à instalação de códigos maliciosos, projetados para furtar dados pessoais e financeiros;
- mensagem que, no próprio conteúdo, apresenta formulários para o preenchimento e envio de dados pessoais e financeiros de usuários.

e) Errada. **Spoofing (Falsificação de Endereço)** é a modificação de campos de identificação de pacotes de forma que o atacante possa atuar se passando por outro *host*.

Pode ser considerado como sendo uma técnica utilizada por invasores para conseguirem se autenticar a serviços, ou outras máquinas, falsificando o seu endereço de origem. Ou seja, é uma técnica de ataque contra a autenticidade, uma forma de personificação que consiste em um usuário externo assumir a identidade de um usuário ou computador interno, atuando no seu lugar legítimo.

A técnica de *spoofing* pode ser utilizada para acessar serviços que são controlados apenas pelo endereço de rede de origem da entidade que irá acessar o recurso específico, como também para evitar que o endereço real de um atacante seja reconhecido durante uma tentativa de invasão.

Essa técnica é utilizada constantemente pelos Hackers, sendo que existem várias ferramentas que facilitam o processo de geração de pacotes de rede com endereços falsos.

Letra d.

053. (FGV/SUSAM/ANALISTA DE SISTEMAS/2014) Um certificado digital é um arquivo de dados contendo segmentos ou seções que possuem informações obrigatórias e adicionais armazenada em extensões. A utilização de certificados digitais permite que sejam agregados requisitos de segurança na tramitação de informações. Dentre esses requisitos, está a garantia da impossibilidade de que o autor recuse a autoria.

Esse é o requisito de

- a) integridade.
- b) não repúdio.
- c) privacidade.
- d) autenticidade.
- e) sigilo.



Com o não repúdio (irretratabilidade) o emissor (aquele que assinou digitalmente a mensagem) não pode negar que foi o autor da mensagem, ou seja, não pode dizer mais tarde que a sua assinatura foi falsificada.

Letra b.

054. (FGV/TJ-GO/ANALISTA JUDICIÁRIO – ANÁLISE DE SISTEMAS – INFRAESTRUTURA DE REDES E COMUNICAÇÃO DE DADOS/2014) Mesmo com a utilização de um firewall na rede, um dos servidores HTTP de uma empresa foi atacado. O ataque em questão pôde ser identificado e bloqueado automaticamente porque na mesma rede tinha sido instalado um:

- a) servidor DNS interno;
- b) IPS;
- c) proxy;
- d) servidor VPN;
- e) PDC.



O ataque em questão pôde ser identificado e bloqueado automaticamente porque na mesma rede tinha sido instalado um **IPS (Sistema de Prevenção de Intrusão)** – um sistema que detecta e obstrui automaticamente ataques computacionais a recursos protegidos. IDS e IPS são sistemas que protegem a rede de intrusões, diferindo no tratamento dado quando uma intrusão é detectada. **IDS limita-se a gerar alertas e ativar alarmes, e o IPS executa contramedidas, como interromper o fluxo de dados referente à intrusão detectada.**

Letra b.

055. (FGV/FIOCRUZ/TECNOLOGISTA EM SAÚDE PÚBLICA/SEGURANÇA DA INFORMAÇÃO/2010) Com relação à análise de risco em segurança da informação, considere os tipos de risco a seguir.

I – Dano físico, como fogo, vandalismo e desastres naturais.

II – Perda de dados, seja intencional ou não.

III – Falha de equipamento.

IV – Risco de mercado e perda de investimento.

Assinale:

- a) se uma empresa deve estar atenta, em sua análise, somente aos riscos I, II e III.
- b) se uma empresa deve estar atenta, em sua análise, a todos esses tipos de riscos.
- c) se uma empresa deve estar atenta, em sua análise, somente aos riscos I e II.
- d) se uma empresa deve estar atenta, em sua análise, somente aos riscos II e III.
- e) se uma empresa deve estar atenta, em sua análise, somente aos riscos I e IV.



Risco é a probabilidade de que as ameaças explorem os pontos fracos, causando perda ou danos aos ativos e impacto nos negócios.

A **análise de riscos** é uma atividade voltada para a identificação de falhas de segurança que evidenciem vulnerabilidades presentes nos ativos da empresa, que possam ser exploradas por ameaças, provocando impactos nos negócios da organização.

A empresa deverá estar atenta aos riscos que podem causar a perda da integridade, disponibilidade e/ou confidencialidade (sigilo), e, nesse caso, destacamos os tipos de risco assinalados nos itens I, II e III como de grande importância dentro do contexto da segurança da informação. São eles:

I – Dano físico, como fogo, vandalismo e desastres naturais.

II – Perda de dados, seja intencional ou não.

III – Falha de equipamento.

O risco de mercado e perda de investimento é motivo de preocupação para a área de finanças!

Letra a.

056. (FGV/FIOCRUZ/TECNOLOGISTA EM SAÚDE PÚBLICA/SEGURANÇA DA INFORMAÇÃO/2010)

O roubo ou a perda de *laptops* é atualmente um dos piores problemas para a segurança da informação corporativa. A respeito da segurança da informação em ambientes e equipamentos, considere as afirmativas a seguir.

I – Realizar o inventário de todos os *laptops*, de forma que possam ser identificados caso sejam recuperados.

II – Criptografar todos os dados sensíveis.

III – Proteger o BIOS com senha.

IV – Em viagens aéreas, enviar o *laptop* separadamente com a bagagem.

Assinale:

a) se somente as afirmativas I, II e III ajudam a proteger tais equipamentos e os dados que contêm.

b) se todas as afirmativas ajudam a proteger tais equipamentos e os dados que contêm.

c) se somente as afirmativas I e II ajudam a proteger tais equipamentos e os dados que contêm.

d) se somente as afirmativas II e III ajudam a proteger tais equipamentos e os dados que contêm.

e) se somente as afirmativas I e IV ajudam a proteger tais equipamentos e os dados que contêm.



Os itens assinalados nas opções I, II e III irão contribuir para melhorar a segurança dos ambientes e equipamentos. No entanto, o item IV não é recomendado, pois essa ação facilitaria o roubo dos notebooks. A portabilidade e a mobilidade, exaltadas quando se fala em notebooks, podem virar uma grande preocupação. É importante que o usuário tenha cuidado ao usar o aparelho e o aconselhável nesse caso é colocá-lo junto a você (por exemplo debaixo do assento em viagens aéreas) e não despachá-lo com a bagagem.

Letra a.

057. (FGV/AUDITOR DA RECEITA DO ESTADO DO AMAPÁ/2010) De tempos em tempos, observa-se na imprensa que *sites* ficam inoperantes. Os ataques conseguem derrubar o tráfego de rede, inundados por solicitações até saírem do ar, por esgotamento da capacidade de processamento. Os especialistas em segurança de redes e na internet creditam os ataques a algum *hacker* que utiliza as chamadas *botnets*, definidas como redes de computadores infectadas por códigos maliciosos. Nesses casos, as máquinas funcionam normalmente até que o *hacker* envie um comando remoto ordenando que todas acessem um site ao mesmo tempo, tirando-o do ar por excesso de tráfego.

Esse tipo de ataque é conhecido pelo termo técnico:

- a) Negação por Excesso de Força Bruta.
- b) Negação de Acesso por Colisão.
- c) Negação de Tráfego por Telnet.
- d) Negação por Intrusão.
- e) Negação de Serviço.



O termo técnico utilizado nesse caso é denominado **negação de serviço (*Denial of Service*)**. Nesse caso, a ordem foi repassada a uma rede Botnet contaminada, cujas máquinas dispararam o ataque que provocará a paralisação dos serviços do site, deixando-o inoperante.

Letra e.

058. (CEBRASPE-CESPE/ANALISTA EM DESENVOLVIMENTO REGIONAL/CODEVASF/TECNOLOGIA DA INFORMAÇÃO/2021) Em determinada organização, não existem vulnerabilidades de segurança conhecidas nos servidores e os sistemas estão atualizados e bem configurados. Considerando essa situação hipotética, julgue o item seguinte.

Eventual ocorrência de um ataque de phishing em que um usuário seja convencido a clicar um link malicioso específico recebido em uma mensagem de email poderá viabilizar um subsequente ataque de ransomware contra os computadores dessa organização.



Ransomwares são softwares maliciosos que, ao infectarem um computador, criptografam todo ou parte do conteúdo do disco rígido. Os responsáveis pelo software exigem da vítima um pagamento pelo “resgate” dos dados em dinheiro eletrônico, conhecido como Bitcoin (moeda virtual, **para que seja fornecida a senha de recuperação desses dados**. Além de infectar o equipamento **o ransomware também costuma buscar outros dispositivos conectados, locais ou em rede, e criptografá-los também**.

Os ataques de **phishing** caracterizam-se pelo envio de mensagens eletrônicas que despertam a atenção de usuários por meio da sugestão de vantagens ou ameaças de prejuízos e também por induzirem os usuários a fornecer dados pessoais e(ou) financeiros.

O **Phishing** é o tipo de ataque mais comumente utilizado como **precursor para viabilizar ataques de ransomware** contra estações de trabalho de usuários. Ao clicar no *link*, e realizar o processo de instalação, então já está infectada com o *malware*.

A palavra **phishing** (de *fishing*) vem de uma analogia criada pelos fraudadores, em que “iscas” (e-mails) são usadas para “pescar” informações sensíveis (senhas e dados financeiros, por exemplo) de usuários da Internet.

Certo.

059. (INÉDITA/2025) A autenticação de um fator é suficiente para proteger informações sensíveis em sistemas modernos.



A autenticação de um fator é geralmente considerada insuficiente para proteger informações sensíveis, pois depende de um único ponto de falha.

Errado.

060. (INÉDITA/2025) A autenticação de dois fatores pode incluir algo que o usuário possui, como um token físico ou um código enviado por SMS.



A **Autenticação de Dois Fatores (2FA)** é uma **camada adicional de segurança** que **exige que os usuários forneçam dois fatores de autenticação diferentes para verificar sua identidade**.

Funcionamento: após fornecer sua senha (primeiro fator), o usuário é solicitado a fornecer um segundo fator de autenticação, como um código enviado para seu *smartphone* via SMS, um código gerado por um aplicativo autenticador ou uma impressão digital (BROWN, 2024).

Certo.

061. (INÉDITA/2025) A autenticação de um fator é suficiente para proteger informações sensíveis em sistemas modernos.



A autenticação de um fator é geralmente considerada insuficiente para proteger informações sensíveis, pois depende de um único ponto de falha.

Errado.

062. (INÉDITA/2025) A autenticação de dois fatores pode incluir algo que o usuário possui, como um token físico ou um código enviado por SMS.



A **Autenticação de Dois Fatores (2FA)** é uma **camada adicional de segurança** que **exige que os usuários forneçam dois fatores de autenticação diferentes para verificar sua identidade**.

Funcionamento: após fornecer sua senha (primeiro fator), o usuário é solicitado a fornecer um segundo fator de autenticação, como um código enviado para seu *smartphone* via SMS, um código gerado por um aplicativo autenticador ou uma impressão digital (BROWN, 2024).

Certo.

REFERÊNCIAS

ALBUQUERQUE, R.; RIBEIRO, B. **Segurança no Desenvolvimento de Software**. Rio de Janeiro: Campus, 2002.

AUDERE. **Next Generation Antivírus (NGAV)**. 2021. Disponível em: <<https://www.audere.com.br/post/next-generation-antivirus-ngav>>. Acesso em ago. de 2022.

CERTBR. **Cartilha de Segurança para Internet**. Versão 4.0. Disponível em: <<http://cartilha.cert.br/livro/cartilha-seguranca-internet.pdf>>. 2012.

Cisco. **O que é o controle de acesso à rede**. 2020. Disponível em: <https://www.cisco.com/c/pt_br/products/security/what-is-network-access-control-nac.html>. Acesso em: jul. de 2022.

DIAS, C. **Segurança e auditoria da tecnologia da informação**. Axcel Books, 2000.

FRUHLINGER, J. **What is SIEM? Security information and event management explained**. Disponível em: <<https://www.csoonline.com/article/2124604/what-is-siem-security-information-and-event-management-explained.html>>. Acesso em: set. 2022.

GEUS, Paulo Lício; NAKAMURA, Emilio Tissato. **Segurança de Redes em Ambiente Corporativos**. São Paulo: Novatec, 2007.

GOCACHE. WAF. **Web Application Firewall**. Disponível em: <<https://www.gocache.com.br/waf/>>. 2020. Acesso em: jul. 2022.

Kaspersky. **O que é gerenciamento unificado de ameaças (UTM)?** Disponível em: <<https://www.kaspersky.com.br/resource-center/definitions/utm>>. Acesso em: jul. 2022.

LAUDON, K. C; LAUDON, J. P. **Sistemas de Informações Gerenciais**. São Paulo: Pearson Prentice Hall, 2007.

LAUREANO, MARCOS A. P.; MORAES, PAULO E. S.. **Segurança como estratégia de gestão da informação**. Revista Economia & Tecnologia – ISSN 1415-451X, Vol. 8 – Fascículo 3 – P. 38-44. 2005.

MARCONDES, J. S. **Plano de Segurança da Informação (PSI): O que, Como Elaborar, Exemplo**. Disponível em: <[https://gestaodesegurancaprivada.com.br/plano-de-seguranca-da-informacao-psi-o-que-como-elaborar-exemplo/#:~:text=O%20Plano%20de%20Seguran%C3%A7a%20da,\(SGSI\)%20de%20uma%20organiza%C3%A7%C3%A3o](https://gestaodesegurancaprivada.com.br/plano-de-seguranca-da-informacao-psi-o-que-como-elaborar-exemplo/#:~:text=O%20Plano%20de%20Seguran%C3%A7a%20da,(SGSI)%20de%20uma%20organiza%C3%A7%C3%A3o)>. 2020. Acesso em: fev. 2021.

MAUSER, D; Diógenes, y. **Certificação Security +** – 2ª edição. 2013.

Norma ABNT NBR ISO/IEC 27002:2013. **Tecnologia da informação – Técnicas de segurança – Código de prática para a gestão da segurança da informação**. 2013.

O´BRIEN, James A. **Sistemas de Informação e as Decisões Gerenciais na Era da Internet**. São Paulo: Saraiva, 2006. 2ª ed.

Oneidentity. **Gerenciamento de Acesso Privilegiado**. Disponível em: <<https://www.oneidentity.com/br-pt/what-is-privileged-access-management/>>. Acesso em: out. 2022.

PALOALTO. **Saiba mais sobre a segurança de confiança Zero**. Disponível em: <<https://www.paloaltonetworks.com.br/zero-trust>>. Acesso em: out. 2022.

QUINTÃO, PATRÍCIA LIMA. **Tecnologia da Informação para Concursos**. 2022.

QUINTÃO, PATRÍCIA LIMA. **Informática para Concursos**. 2022.

QUINTÃO, PATRÍCIA LIMA. **Informática-FCC-Questões Comentadas e Organizadas por Assunto**, 3ª. Edição. Ed. Gen/Método, 2014.

QUINTÃO, PATRÍCIA LIMA. **1001 Questões Comentadas de Informática Cespe**, 2ª. Edição. Ed. Gen/Método, 2017.

RAMOS, A.; BASTOS, A.; LAYRA, A. **Guia Oficial para Formação de Gestores em Segurança da Informação**. 1. ed. Rio Grande do Sul: ZOUK. 2006.

SCHNEIER, B., **Applied Cryptography: Protocols, Algorithms and Source Code in C**. 2. ed. John Wiley & Sons, 1996.

SEMOLA, Marcos. **Gestão da segurança da informação – uma visão executiva**. Campus, 2003

STAIR, R. M.; REYNOLDS, G. W. **Princípios de sistemas de informação: uma abordagem gerencial**. 4. ed. Rio de Janeiro: Livros Técnicos e Científicos, 2002.

STALLINGS, W., **Criptografia e Segurança de Redes: Princípios e Práticas**., 6. ed. São Paulo: Pearson Prentice-Hall, 2015.

STALLINGS, W. **Network security essentials**. Prentice Hall, 2000.

STRINGFIXER. **Sistema de Detecção de Intrusão**. 2020. Disponível em: <https://stringfixer.com/pt/Intrusion_detection>. Acesso em: jul. 2022.

TURBAN, E. McLean, E., Wetherbe, J. **Tecnologia da informação para gestão**. 3ª Edição, Porto Alegre, Bookman, 2004.

VMWARE. O que é ZTNA? Disponível em: <<https://www.vmware.com/br/topics/glossary/content/zero-trust-network-access-ztna.html#:~:text=O%20acesso%20de%20confian%C3%A7a%20zero,controle%20de%20acesso%20claramente%20definidas>>.
Acesso em: out. 2022.

Abra



caminhos



crie

futuros

gran.com.br

